

Enterprise Information Security & Operational Compliance Manual

(Fictional Demo Version)

This document is a fictional compliance policy manual created solely for software demonstrations, AI research, Retrieval-Augmented Generation (RAG), semantic search, and compliance analysis experiments. It does not represent any real company, government regulation, legal requirement, industry standard, or compliance framework.

Total Policies: 86

Total Categories: 38

Document Version: 1.0 (Fictional Demo Corpus)

Optimized for: Chunking, Embedding, Vector Indexing, RAG Retrieval

Table of Contents

Authentication

- AUTH-001 — Password Complexity Requirements *(High)*
- AUTH-002 — Account Lockout Thresholds *(Medium)*
- AUTH-003 — Single Sign-On Enforcement *(High)*

Authorization

- AUTHZ-001 — Role-Based Access Control Enforcement *(High)*
- AUTHZ-002 — Privilege Escalation Approval Workflow *(Critical)*

Identity Management

- IDM-001 — Joiner-Mover-Leaver Identity Lifecycle *(High)*
- IDM-002 — Service Account Governance *(High)*

Password Security

- PWD-001 — Minimum Password Standards *(High)*
- PWD-002 — Credential Reuse Prevention *(Medium)*

Multi-Factor Authentication

- MFA-001 — Mandatory MFA for Administrative Access *(Critical)*
- MFA-002 — MFA Method Assurance Levels *(High)*

Access Control

- AC-001 — Least Privilege Access Provisioning *(High)*
- AC-002 — Periodic Access Recertification *(Medium)*
- AC-003 — Privileged Access Management *(Critical)*

Encryption

- ENC-001 — Encryption of Data at Rest *(Critical)*
- ENC-002 — Encryption of Data in Transit *(Critical)*
- ENC-003 — Approved Cryptographic Algorithms *(High)*

Key Management

- KEY-001 — Cryptographic Key Rotation *(High)*
- KEY-002 — Hardware Security Module Usage *(Critical)*

API Security

- API-001 — API Authentication and Authorization *(High)*
- API-002 — API Rate Limiting and Abuse Prevention *(Medium)*

Cloud Security

- CLOUD-001 — Cloud Storage Bucket Access Configuration *(Critical)*
- CLOUD-002 — Cloud Identity and Access Federation *(High)*
- CLOUD-003 — Cloud Resource Tagging and Ownership *(Low)*

Network Security

NET-001 — Network Segmentation Standards *(High)*

NET-002 — Remote Network Access via VPN *(Medium)*

Firewall Configuration

FW-001 — Firewall Rule Change Management *(High)*

FW-002 — Default-Deny Firewall Baseline *(High)*

Endpoint Protection

EP-001 — Endpoint Detection and Response Deployment *(High)*

EP-002 — Removable Media Restrictions *(Medium)*

Device Management

DEV-001 — Mobile Device Management Enrollment *(Medium)*

DEV-002 — Bring Your Own Device Standards *(Medium)*

Logging & Monitoring

LOG-001 — Centralized Security Log Collection *(High)*

LOG-002 — Security Alert Triage and Response Times *(High)*

LOG-003 — Log Retention Standards *(Medium)*

Audit Trail

AUD-001 — Immutable Audit Logging for Sensitive Systems *(High)*

AUD-002 — Administrative Action Audit Requirements *(High)*

Incident Response

INC-001 — Security Incident Classification and Escalation *(Critical)*

INC-002 — Incident Response Plan Testing *(High)*

INC-003 — Post-Incident Review Requirements *(Medium)*

Vulnerability Management

VULN-001 — Vulnerability Scanning Cadence *(High)*

VULN-002 — Critical Vulnerability Remediation Timelines *(Critical)*

Patch Management

PATCH-001 — Operating System Patch Deployment *(High)*

PATCH-002 — Third-Party Software Patch Tracking *(Medium)*

Backup & Disaster Recovery

BACKUP-001 — Backup Frequency and Retention *(High)*

BACKUP-002 — Disaster Recovery Testing *(High)*

BACKUP-003 — Backup Encryption and Offsite Storage *(Medium)*

Database Security

DB-001 — Database Access Restriction and Monitoring *(High)*

DB-002 — Database Configuration Hardening *(Medium)*

Data Classification

DC-001 — Data Classification Scheme and Labeling *(Medium)*

DC-002 — Handling Requirements by Classification Tier *(Medium)*

Data Retention

RET-001 — Data Retention Schedule by Data Type *(Medium)*

RET-002 — Legal Hold Procedures *(High)*

Data Disposal

DISP-001 — Secure Media Sanitization *(High)*

DISP-002 — End-of-Life Hardware Disposal *(Medium)*

Customer Privacy

PRIV-001 — Customer Data Collection Minimization *(High)*

PRIV-002 — Customer Data Subject Request Handling *(High)*

Employee Privacy

EMPPRIV-001 — Workplace Monitoring Disclosure *(Medium)*

EMPPRIV-002 — Employee Personal Data Handling *(Medium)*

Third-Party Vendors

VENDOR-001 — Vendor Security Risk Assessment *(High)*

VENDOR-002 — Vendor Contractual Security Requirements *(Medium)*

VENDOR-003 — Fourth-Party Subcontractor Oversight *(Medium)*

Physical Security

PHYS-001 — Data Center Physical Access Control *(High)*

PHYS-002 — Office Badge Access Management *(Medium)*

Remote Work

REMOTE-001 — Secure Remote Access Requirements *(Medium)*

REMOTE-002 — Home Office Security Baseline *(Low)*

Secure Software Development

SDLC-001 — Secure Code Review Requirements *(High)*

SDLC-002 — Static and Dynamic Application Security Testing *(High)*

SDLC-003 — Third-Party Library Dependency Management *(Medium)*

Change Management

CHG-001 — Production Change Approval Process *(Medium)*

CHG-002 — Emergency Change Procedures *(Medium)*

Source Code Management

SCM-001 — Source Code Repository Access Control *(High)*

SCM-002 — Branch Protection and Commit Signing *(Medium)*

Secrets Management

SEC-001 — Centralized Secrets Storage *(Critical)*

SEC-002 — Secret Rotation and Revocation *(High)*

AI Usage

AI-001 — Approved AI Tool Usage *(Medium)*

AI-002 — AI Output Review and Human Oversight *(Medium)*

Generative AI

GENAI-001 — Generative AI Prompt Data Handling *(High)*

GENAI-002 — Generative AI Model Output Validation *(Medium)*

GENAI-003 — Third-Party Generative AI Vendor Review *(Medium)*

Email Security

MAIL-001 — Email Authentication Standards (SPF, DKIM, DMARC) *(High)*

MAIL-002 — Phishing Simulation and Awareness Training *(Medium)*

Business Continuity

BCP-001 — Business Continuity Plan Maintenance *(Medium)*

BCP-002 — Critical Function Dependency Mapping *(Medium)*

Compliance Documentation

DOC-001 — Policy Lifecycle and Version Control *(Low)*

DOC-002 — Control Evidence Repository Management *(Medium)*

Password Complexity Requirements

Category: Authentication

Business Objective

Authentication controls establish confidence that a party requesting access to a system is who they claim to be, forming the first line of defense against unauthorized account use. The Password Complexity Requirements policy applies this principle specifically to password complexity requirements, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Authentication must comply with the requirements defined under Password Complexity Requirements, and exceptions must be formally documented and approved by Director of Identity & Access Management.

Detailed Requirements

1. Credentials must never be transmitted or stored in plaintext.
2. Authentication attempts must be rate-limited to reduce brute-force exposure.
3. Default vendor credentials must be changed prior to production deployment.
4. Authentication events must be logged with timestamp, source IP, and outcome.
5. Session tokens issued after authentication must expire after a defined inactivity period.
6. Authentication mechanisms must be reviewed at least annually for continued adequacy.
7. Fallback or legacy authentication paths must be disabled unless formally approved.

Indicators of Non-Compliance

- Use of shared login credentials across multiple employees
- Authentication endpoints without rate limiting or lockout
- Default or vendor-supplied credentials still active in production
- Absence of authentication event logging

Required Evidence

- Authentication system configuration exports
- Identity provider configuration screenshots
- Sample authentication logs covering a 30-day window
- Password policy configuration from directory services
- Account lockout configuration settings

Recommended Remediation

To remediate a violation of Password Complexity Requirements, the accountable team should: (1) Reconfigure the affected authentication system to align with the documented policy baseline and validate the change in a staging environment before production rollout. (2) Disable non-compliant authentication paths and route all access through the approved identity provider. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

AUTH-002, AUTH-003, AUTHZ-001

AI Summary

This policy defines mandatory controls for password complexity requirements within the Authentication domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Identity & Access Management.

Example Compliant Scenario

A system owner within Identity & Access Management implements Password Complexity Requirements in full: required controls are configured as specified, evidence such as authentication system configuration exports is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant identity provider configuration screenshots without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that use of shared login credentials across multiple employees. Further investigation reveals that authentication endpoints without rate limiting or lockout, and no compensating control was documented. The finding is logged against AUTH-001 with a High risk rating and routed to Director of Identity & Access Management for remediation per the defined timeline.

Metadata

Policy_ID:	AUTH-001	Title:	Password Complexity Requirements
Category:	Authentication	Risk_Level:	High
Department:	Identity & Access Management	Owner:	Director of Identity & Access Management
Version:	3.4	Effective_Date:	March 8, 2025
Review_Cycle:	Annual	Priority:	High
Status:	Active	Related_Policies:	AUTH-002, AUTH-003, AUTHZ-001
Keywords:	authentication, login, credentials, identity, session, password, lockout, brute force, identity provider, single sign-on, SSO, token, verification, access request		
Search_Tags:	Authentication, Identity, IAM, Login, Security, Credentials, Access Control, Session Management, SSO, Policy, Enterprise Security		
Evidence_Types:	Authentication system configuration exports, Identity provider configuration screenshots, Sample authentication logs covering a 30-day window, Password policy configuration from directory services, Account lockout configuration settings		

Account Lockout Thresholds

Category: Authentication

Business Objective

Authentication controls establish confidence that a party requesting access to a system is who they claim to be, forming the first line of defense against unauthorized account use. The Account Lockout Thresholds policy applies this principle specifically to account lockout thresholds, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Authentication must comply with the requirements defined under Account Lockout Thresholds, and exceptions must be formally documented and approved by Director of Identity & Access Management.

Detailed Requirements

1. Default vendor credentials must be changed prior to production deployment.
2. Authentication events must be logged with timestamp, source IP, and outcome.
3. Session tokens issued after authentication must expire after a defined inactivity period.
4. Authentication mechanisms must be reviewed at least annually for continued adequacy.
5. Fallback or legacy authentication paths must be disabled unless formally approved.
6. Shared or generic accounts are prohibited for individual authentication.
7. Authentication failures must not reveal whether a username or password was incorrect.

Indicators of Non-Compliance

- Absence of authentication event logging
- Password reset flows that do not verify identity
- Legacy authentication protocols enabled without justification
- Session tokens that never expire
- Use of shared login credentials across multiple employees
- Authentication endpoints without rate limiting or lockout

Required Evidence

- Account lockout configuration settings
- Session timeout configuration records
- Change tickets related to authentication systems
- Authentication system configuration exports
- Identity provider configuration screenshots

Recommended Remediation

To remediate a violation of Account Lockout Thresholds, the accountable team should: (1) Disable non-compliant authentication paths and route all access through the approved identity provider. (2) Implement centralized logging for authentication events and route logs to the security monitoring platform. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

AUTH-001, AUTH-003, PWD-002

AI Summary

This policy defines mandatory controls for account lockout thresholds within the Authentication domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Identity & Access Management.

Example Compliant Scenario

A system owner within Identity & Access Management implements Account Lockout Thresholds in full: required controls are configured as specified, evidence such as account lockout configuration settings is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant session timeout configuration records without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that absence of authentication event logging. Further investigation reveals that password reset flows that do not verify identity, and no compensating control was documented. The finding is logged against AUTH-002 with a Medium risk rating and routed to Director of Identity & Access Management for remediation per the defined timeline.

Metadata

Policy_ID:	AUTH-002	Title:	Account Lockout Thresholds
Category:	Authentication	Risk_Level:	Medium
Department:	Identity & Access Management	Owner:	Director of Identity & Access Management
Version:	3.6	Effective_Date:	January 1, 2025
Review_Cycle:	Annual	Priority:	Medium
Status:	Active	Related_Policies:	AUTH-001, AUTH-003, PWD-002
Keywords:	credentials, identity, session, password, lockout, brute force, identity provider, single sign-on, SSO, token, verification, access request, login attempt, authentication log		
Search_Tags:	Login, Security, Credentials, Access Control, Session Management, SSO, Policy, Enterprise Security, Identity Provider, Authentication, Identity		
Evidence_Types:	Account lockout configuration settings, Session timeout configuration records, Change tickets related to authentication systems, Authentication system configuration exports, Identity provider configuration screenshots		

Single Sign-On Enforcement

Category: Authentication

Business Objective

Authentication controls establish confidence that a party requesting access to a system is who they claim to be, forming the first line of defense against unauthorized account use. The Single Sign-On Enforcement policy applies this principle specifically to single sign-on enforcement, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Authentication must comply with the requirements defined under Single Sign-On Enforcement, and exceptions must be formally documented and approved by Director of Identity & Access Management.

Detailed Requirements

1. Session tokens issued after authentication must expire after a defined inactivity period.
2. Authentication mechanisms must be reviewed at least annually for continued adequacy.
3. Fallback or legacy authentication paths must be disabled unless formally approved.
4. Shared or generic accounts are prohibited for individual authentication.
5. Authentication failures must not reveal whether a username or password was incorrect.

Indicators of Non-Compliance

- Session tokens that never expire
- Use of shared login credentials across multiple employees
- Authentication endpoints without rate limiting or lockout
- Default or vendor-supplied credentials still active in production
- Absence of authentication event logging
- Password reset flows that do not verify identity

Required Evidence

- Identity provider configuration screenshots
- Sample authentication logs covering a 30-day window
- Password policy configuration from directory services
- Account lockout configuration settings
- Session timeout configuration records

Recommended Remediation

To remediate a violation of Single Sign-On Enforcement, the accountable team should: (1) Implement centralized logging for authentication events and route logs to the security monitoring platform. (2) Conduct a credential audit to identify and rotate any default, shared, or stale credentials. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

AUTH-001, AUTH-002, AC-003

AI Summary

This policy defines mandatory controls for single sign-on enforcement within the Authentication domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Identity & Access Management.

Example Compliant Scenario

A system owner within Identity & Access Management implements Single Sign-On Enforcement in full: required controls are configured as specified, evidence such as identity provider configuration screenshots is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant sample authentication logs covering a 30-day window without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that session tokens that never expire. Further investigation reveals that use of shared login credentials across multiple employees, and no compensating control was documented. The finding is logged against AUTH-003 with a High risk rating and routed to Director of Identity & Access Management for remediation per the defined timeline.

Metadata

Policy_ID:	AUTH-003	Title:	Single Sign-On Enforcement
Category:	Authentication	Risk_Level:	High
Department:	Identity & Access Management	Owner:	Director of Identity & Access Management
Version:	3.3	Effective_Date:	October 21, 2025
Review_Cycle:	Quarterly	Priority:	High
Status:	Under Review	Related_Policies:	AUTH-001, AUTH-002, AC-003
Keywords:	session, password, logout, brute force, identity provider, single sign-on, SSO, token, verification, access request, login attempt, authentication log, recovery workflow, legacy protocol		
Search_Tags:	Access Control, Session Management, SSO, Policy, Enterprise Security, Identity Provider, Authentication, Identity, IAM, Login, Security		
Evidence_Types:	Identity provider configuration screenshots, Sample authentication logs covering a 30-day window, Password policy configuration from directory services, Account logout configuration settings, Session timeout configuration records		

Role-Based Access Control Enforcement

Category: Authorization

Business Objective

Authorization controls ensure that authenticated parties can only perform actions and access resources consistent with their assigned role, limiting the blast radius of any single compromised account. The Role-Based Access Control Enforcement policy applies this principle specifically to role-based access control enforcement, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Authorization must comply with the requirements defined under Role-Based Access Control Enforcement, and exceptions must be formally documented and approved by Director of Identity & Access Management.

Detailed Requirements

1. Authorization policies must be version-controlled and peer-reviewed before deployment.
2. Default-deny must be the standard posture for all new resource types.
3. Access rights must be assigned based on documented job function, not individual request.
4. Authorization decisions must be enforced at the resource layer, not solely in the client application.
5. Elevated privileges must require a documented, time-bound approval.

Indicators of Non-Compliance

- Absence of periodic entitlement review records
- Segregation-of-duties conflicts left unresolved
- New resources deployed with default-allow permissions
- Users retaining access rights inconsistent with their current role
- Standing administrative privileges without expiration

Required Evidence

- Role and permission matrices
- Entitlement review sign-off records
- Access approval tickets
- Identity governance platform exports
- Segregation-of-duties conflict reports
- Authorization policy source files

Recommended Remediation

To remediate a violation of Role-Based Access Control Enforcement, the accountable team should: (1) Move authorization enforcement to the server or API gateway layer. (2) Revoke inconsistent entitlements and re-provision access strictly according to the role-based access model. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

AUTHZ-002, KEY-001, KEY-002

AI Summary

This policy defines mandatory controls for role-based access control enforcement within the Authorization domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Identity & Access Management.

Example Compliant Scenario

A system owner within Identity & Access Management implements Role-Based Access Control Enforcement in full: required controls are configured as specified, evidence such as role and permission matrices is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant entitlement review sign-off records without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that absence of periodic entitlement review records. Further investigation reveals that segregation-of-duties conflicts left unresolved, and no compensating control was documented. The finding is logged against AUTHZ-001 with a High risk rating and routed to Director of Identity & Access Management for remediation per the defined timeline.

Metadata

Policy_ID:	AUTHZ-001	Title:	Role-Based Access Control Enforcement
Category:	Authorization	Risk_Level:	High
Department:	Identity & Access Management	Owner:	Director of Identity & Access Management
Version:	1.2	Effective_Date:	October 14, 2025
Review_Cycle :	Semi-Annual	Priority:	High
Status:	Active	Related_Policies:	AUTHZ-002, KEY-001, KEY-002
Keywords:	least privilege, approval workflow, permission, role, access review, default deny, elevation, governance, standing access, authorization, RBAC, entitlement, privilege, access rights		
Search_Tags:	Least Privilege, Authorization, RBAC, Access Control, IAM, Privilege Management, Entitlements, Security, Governance, Policy		
Evidence_Types:	Role and permission matrices, Entitlement review sign-off records, Access approval tickets, Identity governance platform exports, Segregation-of-duties conflict reports, Authorization policy source files		

Privilege Escalation Approval Workflow

Category: Authorization

Business Objective

Authorization controls ensure that authenticated parties can only perform actions and access resources consistent with their assigned role, limiting the blast radius of any single compromised account. The Privilege Escalation Approval Workflow policy applies this principle specifically to privilege escalation approval workflow, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Authorization must comply with the requirements defined under Privilege Escalation Approval Workflow, and exceptions must be formally documented and approved by Director of Identity & Access Management.

Detailed Requirements

1. Access rights must be assigned based on documented job function, not individual request.
2. Authorization decisions must be enforced at the resource layer, not solely in the client application.
3. Elevated privileges must require a documented, time-bound approval.
4. Entitlement reviews must occur at least quarterly for systems handling sensitive data.
5. Segregation of duties must be maintained for financially or operationally sensitive workflows.

Indicators of Non-Compliance

- Users retaining access rights inconsistent with their current role
- Standing administrative privileges without expiration
- Authorization logic implemented only in the client rather than the server
- Absence of periodic entitlement review records

Required Evidence

- Segregation-of-duties conflict reports
- Authorization policy source files
- Role and permission matrices
- Entitlement review sign-off records
- Access approval tickets
- Identity governance platform exports

Recommended Remediation

To remediate a violation of Privilege Escalation Approval Workflow, the accountable team should: (1) Revoke inconsistent entitlements and re-provision access strictly according to the role-based access model. (2) Introduce time-bound privilege elevation with automatic expiry and mandatory approval logging. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

AUTHZ-001, CLOUD-002, CLOUD-003

AI Summary

This policy defines mandatory controls for privilege escalation approval workflow within the Authorization domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Critical risk and applies to all in-scope systems and personnel under Identity & Access Management.

Example Compliant Scenario

A system owner within Identity & Access Management implements Privilege Escalation Approval Workflow in full: required controls are configured as specified, evidence such as segregation-of-duties conflict reports is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant authorization policy source files without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that users retaining access rights inconsistent with their current role. Further investigation reveals that standing administrative privileges without expiration, and no compensating control was documented. The finding is logged against AUTHZ-002 with a Critical risk rating and routed to Director of Identity & Access Management for remediation per the defined timeline.

Metadata

Policy_ID:	AUTHZ-002	Title:	Privilege Escalation Approval Workflow
Category:	Authorization	Risk_Level:	Critical
Department:	Identity & Access Management	Owner:	Director of Identity & Access Management
Version:	1.1	Effective_Date:	June 4, 2025
Review_Cycle :	Semi-Annual	Priority:	Critical
Status:	Active	Related_Policies:	AUTHZ-001, CLOUD-002, CLOUD-003
Keywords:	permission, role, access review, default deny, elevation, governance, standing access, authorization, RBAC, entitlement, privilege, access rights, segregation of duties, least privilege		
Search_Tags:	Access Control, IAM, Privilege Management, Entitlements, Security, Governance, Policy, Least Privilege, Authorization, RBAC		
Evidence_Types:	Segregation-of-duties conflict reports, Authorization policy source files, Role and permission matrices, Entitlement review sign-off records, Access approval tickets, Identity governance platform exports		

Joiner-Mover-Leaver Identity Lifecycle

Category: Identity Management

Business Objective

Identity management policies govern the full lifecycle of digital identities, from provisioning through deprovisioning, ensuring that access accurately reflects an individual's current relationship with the organization. The Joiner-Mover-Leaver Identity Lifecycle policy applies this principle specifically to joiner-mover-leaver identity lifecycle, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Identity Management must comply with the requirements defined under Joiner-Mover-Leaver Identity Lifecycle, and exceptions must be formally documented and approved by Director of Identity & Access Management.

Detailed Requirements

1. Access must be automatically adjusted when an employee changes role.
2. All accounts must be deprovisioned within a defined window following termination.
3. Service accounts must have a named human owner accountable for their use.
4. Identity records must be reconciled against the HR system on a recurring basis.
5. Dormant identities must be flagged and disabled after a defined inactivity period.
6. Identity provisioning and deprovisioning actions must be logged and auditable.
7. New identities must be provisioned only after HR or sponsoring-manager confirmation.

Indicators of Non-Compliance

- Terminated employee accounts still active
- Service accounts with no identifiable owner
- Identity attributes that do not match the HR system of record
- Manual, undocumented provisioning outside the standard workflow
- Dormant accounts with no expiration or review process

Required Evidence

- Identity lifecycle workflow configuration
- HR-to-IT provisioning integration logs
- Termination checklist records
- Service account inventory and ownership register
- Dormant account review reports

Recommended Remediation

To remediate a violation of Joiner-Mover-Leaver Identity Lifecycle, the accountable team should: (1) Assign a named accountable owner to every service account and review ownership annually. (2) Implement a recurring reconciliation job comparing identity records against HR data. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

AI Summary

This policy defines mandatory controls for joiner-mover-leaver identity lifecycle within the Identity Management domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Identity & Access Management.

Example Compliant Scenario

A system owner within Identity & Access Management implements Joiner-Mover-Leaver Identity Lifecycle in full: required controls are configured as specified, evidence such as identity lifecycle workflow configuration is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant hr-to-it provisioning integration logs without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that terminated employee accounts still active. Further investigation reveals that service accounts with no identifiable owner, and no compensating control was documented. The finding is logged against IDM-001 with a High risk rating and routed to Director of Identity & Access Management for remediation per the defined timeline.

Metadata

Policy_ID:	IDM-001	Title:	Joiner-Mover-Leaver Identity Lifecycle
Category:	Identity Management	Risk_Level:	High
Department:	Identity & Access Management	Owner:	Director of Identity & Access Management
Version:	3.7	Effective_Date:	August 4, 2025
Review_Cycle:	Semi-Annual	Priority:	High
Status:	Active	Related_Policies:	IDM-002, FW-002, EP-001
Keywords:	onboarding, system of record, identity lifecycle, provisioning, deprovisioning, joiner mover leaver, service account, identity governance, HR integration, dormant account, account ownership, offboarding		
Search_Tags:	Governance, Security, HR Integration, Identity Management, IAM, Lifecycle, Provisioning, Offboarding, Service Accounts		
Evidence_Types:	Identity lifecycle workflow configuration, HR-to-IT provisioning integration logs, Termination checklist records, Service account inventory and ownership register, Dormant account review reports		

Service Account Governance

Category: Identity Management

Business Objective

Identity management policies govern the full lifecycle of digital identities, from provisioning through deprovisioning, ensuring that access accurately reflects an individual's current relationship with the organization. The Service Account Governance policy applies this principle specifically to service account governance, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Identity Management must comply with the requirements defined under Service Account Governance, and exceptions must be formally documented and approved by Director of Identity & Access Management.

Detailed Requirements

1. Service accounts must have a named human owner accountable for their use.
2. Identity records must be reconciled against the HR system on a recurring basis.
3. Dormant identities must be flagged and disabled after a defined inactivity period.
4. Identity provisioning and deprovisioning actions must be logged and auditable.
5. New identities must be provisioned only after HR or sponsoring-manager confirmation.
6. Identity attributes must be sourced from an authoritative system of record.
7. Access must be automatically adjusted when an employee changes role.

Indicators of Non-Compliance

- Manual, undocumented provisioning outside the standard workflow
- Dormant accounts with no expiration or review process
- Terminated employee accounts still active
- Service accounts with no identifiable owner
- Identity attributes that do not match the HR system of record

Required Evidence

- Dormant account review reports
- Identity lifecycle workflow configuration
- HR-to-IT provisioning integration logs
- Termination checklist records
- Service account inventory and ownership register

Recommended Remediation

To remediate a violation of Service Account Governance, the accountable team should: (1) Implement a recurring reconciliation job comparing identity records against HR data. (2) Disable and archive dormant accounts pending formal review. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

IDM-001, LOG-001, LOG-002

AI Summary

This policy defines mandatory controls for service account governance within the Identity Management domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Identity & Access Management.

Example Compliant Scenario

A system owner within Identity & Access Management implements Service Account Governance in full: required controls are configured as specified, evidence such as dormant account review reports is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant identity lifecycle workflow configuration without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that manual, undocumented provisioning outside the standard workflow. Further investigation reveals that dormant accounts with no expiration or review process, and no compensating control was documented. The finding is logged against IDM-002 with a High risk rating and routed to Director of Identity & Access Management for remediation per the defined timeline.

Metadata

Policy_ID:	IDM-002	Title:	Service Account Governance
Category:	Identity Management	Risk_Level:	High
Department:	Identity & Access Management	Owner:	Director of Identity & Access Management
Version:	3.3	Effective_Date:	October 3, 2025
Review_Cycle :	Annual	Priority:	High
Status:	Active	Related_Policies:	IDM-001, LOG-001, LOG-002
Keywords:	identity lifecycle, provisioning, deprovisioning, joiner mover leaver, service account, identity governance, HR integration, dormant account, account ownership, offboarding, onboarding, system of record		
Search_Tags:	Identity Management, IAM, Lifecycle, Provisioning, Offboarding, Service Accounts, Governance, Security, HR Integration		
Evidence_Types:	Dormant account review reports, Identity lifecycle workflow configuration, HR-to-IT provisioning integration logs, Termination checklist records, Service account inventory and ownership register		

Minimum Password Standards

Category: Password Security

Business Objective

Password security policies reduce the likelihood that credentials can be guessed, reused, or exposed, addressing one of the most common initial access vectors in security incidents. The Minimum Password Standards policy applies this principle specifically to minimum password standards, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Password Security must comply with the requirements defined under Minimum Password Standards, and exceptions must be formally documented and approved by Director of Identity & Access Management.

Detailed Requirements

1. Passwords must be a minimum of twelve characters in length.
2. Passwords must not match any of the user's previous ten passwords.
3. Passwords must be checked against a known-breached-password list at creation time.
4. Password hashes must use a modern, salted, computationally expensive algorithm.
5. Passwords must not be stored in configuration files, source code, or documentation.
6. Forced periodic password rotation must not be used as a substitute for breach detection.

Indicators of Non-Compliance

- Password reuse permitted across sequential changes
- Hardcoded credentials found in source code or notebooks
- Passwords visible in plaintext in logs or tickets
- No breach-list screening at password creation

Required Evidence

- Password history enforcement settings
- Breach-list screening integration logs
- Password policy configuration exports
- Hashing algorithm configuration
- Source code scan results for embedded credentials

Recommended Remediation

To remediate a violation of Minimum Password Standards, the accountable team should: (1) Update the password policy configuration to enforce minimum length and history requirements. (2) Migrate stored credentials to a salted, modern hashing algorithm and force a reset for affected accounts. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

PWD-002, INC-001, INC-002

AI Summary

This policy defines mandatory controls for minimum password standards within the Password Security domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Identity & Access Management.

Example Compliant Scenario

A system owner within Identity & Access Management implements Minimum Password Standards in full: required controls are configured as specified, evidence such as password history enforcement settings is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant breach-list screening integration logs without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that password reuse permitted across sequential changes. Further investigation reveals that hardcoded credentials found in source code or notebooks, and no compensating control was documented. The finding is logged against PWD-001 with a High risk rating and routed to Director of Identity & Access Management for remediation per the defined timeline.

Metadata

Policy_ID:	PWD-001	Title:	Minimum Password Standards
Category:	Password Security	Risk_Level:	High
Department:	Identity & Access Management	Owner:	Director of Identity & Access Management
Version:	1.6	Effective_Date:	April 15, 2025
Review_Cycle :	Quarterly	Priority:	High
Status:	Active	Related_Policies:	PWD-002, INC-001, INC-002
Keywords:	salting, password reuse, breach list, password policy, password rotation, hardcoded credential, password history, credential storage, password, credential, hashing		
Search_Tags:	Hashing, Policy, Access Control, Password Security, Credentials, Authentication, IAM, Security		
Evidence_Types:	Password history enforcement settings, Breach-list screening integration logs, Password policy configuration exports, Hashing algorithm configuration, Source code scan results for embedded credentials		

Credential Reuse Prevention

Category: Password Security

Business Objective

Password security policies reduce the likelihood that credentials can be guessed, reused, or exposed, addressing one of the most common initial access vectors in security incidents. The Credential Reuse Prevention policy applies this principle specifically to credential reuse prevention, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Password Security must comply with the requirements defined under Credential Reuse Prevention, and exceptions must be formally documented and approved by Director of Identity & Access Management.

Detailed Requirements

1. Passwords must be checked against a known-breached-password list at creation time.
2. Password hashes must use a modern, salted, computationally expensive algorithm.
3. Passwords must not be stored in configuration files, source code, or documentation.
4. Forced periodic password rotation must not be used as a substitute for breach detection.
5. Password fields must be masked in all user interfaces by default.

Indicators of Non-Compliance

- No breach-list screening at password creation
- Passwords stored using reversible encryption or no hashing
- Password reuse permitted across sequential changes
- Hardcoded credentials found in source code or notebooks
- Passwords visible in plaintext in logs or tickets

Required Evidence

- Source code scan results for embedded credentials
- Password history enforcement settings
- Breach-list screening integration logs
- Password policy configuration exports
- Hashing algorithm configuration

Recommended Remediation

To remediate a violation of Credential Reuse Prevention, the accountable team should: (1) Migrate stored credentials to a salted, modern hashing algorithm and force a reset for affected accounts. (2) Revoke and rotate any credentials discovered hardcoded in source repositories. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

PWD-001, PATCH-001, PATCH-002

AI Summary

This policy defines mandatory controls for credential reuse prevention within the Password Security domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Identity & Access Management.

Example Compliant Scenario

A system owner within Identity & Access Management implements Credential Reuse Prevention in full: required controls are configured as specified, evidence such as source code scan results for embedded credentials is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant password history enforcement settings without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that no breach-list screening at password creation. Further investigation reveals that passwords stored using reversible encryption or no hashing, and no compensating control was documented. The finding is logged against PWD-002 with a Medium risk rating and routed to Director of Identity & Access Management for remediation per the defined timeline.

Metadata

Policy_ID:	PWD-002	Title:	Credential Reuse Prevention
Category:	Password Security	Risk_Level:	Medium
Department:	Identity & Access Management	Owner:	Director of Identity & Access Management
Version:	1.4	Effective_Date:	October 22, 2025
Review_Cycle :	Quarterly	Priority:	Medium
Status:	Active	Related_Policies:	PWD-001, PATCH-001, PATCH-002
Keywords:	breach list, password policy, password rotation, hardcoded credential, password history, credential storage, password, credential, hashing, salting, password reuse		
Search_Tags:	Password Security, Credentials, Authentication, IAM, Security, Hashing, Policy, Access Control		
Evidence_Types:	Source code scan results for embedded credentials, Password history enforcement settings, Breach-list screening integration logs, Password policy configuration exports, Hashing algorithm configuration		

Mandatory MFA for Administrative Access

Category: Multi-Factor Authentication

Business Objective

Multi-factor authentication reduces the risk that a single compromised credential leads to unauthorized account access by requiring an additional independent verification factor. The Mandatory MFA for Administrative Access policy applies this principle specifically to mandatory mfa for administrative access, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Multi-Factor Authentication must comply with the requirements defined under Mandatory MFA for Administrative Access, and exceptions must be formally documented and approved by Director of Identity & Access Management.

Detailed Requirements

1. All administrative and privileged accounts must have MFA enabled without exception.
2. SMS-based MFA must not be used as the sole factor for privileged accounts.
3. MFA enrollment must occur before an account is granted production access.
4. MFA bypass or exemption requests must be approved by the security team and time-limited.
5. Backup MFA methods must be reviewed to ensure they do not weaken overall assurance.
6. MFA prompts must include contextual information to reduce approval fatigue and push-bombing risk.

Indicators of Non-Compliance

- Permanent, undocumented MFA exemptions
- Repeated MFA push approvals without user verification of context
- MFA enrollment bypassed during account creation
- Administrative accounts without MFA enabled
- Reliance on SMS as the only second factor for privileged access

Required Evidence

- Identity provider MFA policy configuration
- MFA exemption approval records
- Authentication logs showing factor type used
- Push notification configuration settings
- MFA enrollment reports

Recommended Remediation

To remediate a violation of Mandatory MFA for Administrative Access, the accountable team should: (1) Migrate privileged accounts from SMS-based MFA to a phishing-resistant factor. (2) Review and time-limit all existing MFA exemptions, requiring re-approval. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

MFA-002, DB-001, DB-002

AI Summary

This policy defines mandatory controls for mandatory mfa for administrative access within the Multi-Factor Authentication domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Critical risk and applies to all in-scope systems and personnel under Identity & Access Management.

Example Compliant Scenario

A system owner within Identity & Access Management implements Mandatory MFA for Administrative Access in full: required controls are configured as specified, evidence such as identity provider mfa policy configuration is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant mfa exemption approval records without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that permanent, undocumented mfa exemptions. Further investigation reveals that repeated mfa push approvals without user verification of context, and no compensating control was documented. The finding is logged against MFA-001 with a Critical risk rating and routed to Director of Identity & Access Management for remediation per the defined timeline.

Metadata

Policy_ID:	MFA-001	Title:	Mandatory MFA for Administrative Access
Category:	Multi-Factor Authentication	Risk_Level:	Critical
Department:	Identity & Access Management	Owner:	Director of Identity & Access Management
Version:	3.3	Effective_Date:	March 15, 2025
Review_Cycle :	Semi-Annual	Priority:	Critical
Status:	Active	Related_Policies:	MFA-002, DB-001, DB-002
Keywords:	authenticator app, security key, assurance level, privileged access, MFA, multi-factor authentication, two-factor, second factor, push notification, SMS authentication, phishing-resistant		
Search_Tags:	Security, Privileged Access, Access Control, IAM, Policy, MFA, Authentication, Identity		
Evidence_Types:	Identity provider MFA policy configuration, MFA exemption approval records, Authentication logs showing factor type used, Push notification configuration settings, MFA enrollment reports		

MFA Method Assurance Levels

Category: Multi-Factor Authentication

Business Objective

Multi-factor authentication reduces the risk that a single compromised credential leads to unauthorized account access by requiring an additional independent verification factor. The MFA Method Assurance Levels policy applies this principle specifically to mfa method assurance levels, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Multi-Factor Authentication must comply with the requirements defined under MFA Method Assurance Levels, and exceptions must be formally documented and approved by Director of Identity & Access Management.

Detailed Requirements

1. MFA enrollment must occur before an account is granted production access.
2. MFA bypass or exemption requests must be approved by the security team and time-limited.
3. Backup MFA methods must be reviewed to ensure they do not weaken overall assurance.
4. MFA prompts must include contextual information to reduce approval fatigue and push-bombing risk.
5. All administrative and privileged accounts must have MFA enabled without exception.
6. SMS-based MFA must not be used as the sole factor for privileged accounts.

Indicators of Non-Compliance

- Administrative accounts without MFA enabled
- Reliance on SMS as the only second factor for privileged access
- Permanent, undocumented MFA exemptions
- Repeated MFA push approvals without user verification of context
- MFA enrollment bypassed during account creation

Required Evidence

- MFA enrollment reports
- Identity provider MFA policy configuration
- MFA exemption approval records
- Authentication logs showing factor type used
- Push notification configuration settings

Recommended Remediation

To remediate a violation of MFA Method Assurance Levels, the accountable team should: (1) Review and time-limit all existing MFA exemptions, requiring re-approval. (2) Enable number-matching or contextual prompts to reduce push-bombing susceptibility. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

MFA-001, RET-002, DISP-001

AI Summary

This policy defines mandatory controls for mfa method assurance levels within the Multi-Factor Authentication domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Identity & Access Management.

Example Compliant Scenario

A system owner within Identity & Access Management implements MFA Method Assurance Levels in full: required controls are configured as specified, evidence such as mfa enrollment reports is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant identity provider mfa policy configuration without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that administrative accounts without mfa enabled. Further investigation reveals that reliance on sms as the only second factor for privileged access, and no compensating control was documented. The finding is logged against MFA-002 with a High risk rating and routed to Director of Identity & Access Management for remediation per the defined timeline.

Metadata

Policy_ID:	MFA-002	Title:	MFA Method Assurance Levels
Category:	Multi-Factor Authentication	Risk_Level:	High
Department:	Identity & Access Management	Owner:	Director of Identity & Access Management
Version:	3.5	Effective_Date:	January 8, 2025
Review_Cycle:	Annual	Priority:	High
Status:	Active	Related_Policies:	MFA-001, RET-002, DISP-001
Keywords:	assurance level, privileged access, MFA, multi-factor authentication, two-factor, second factor, push notification, SMS authentication, phishing-resistant, authenticator app, security key		
Search_Tags:	IAM, Policy, MFA, Authentication, Identity, Security, Privileged Access, Access Control		
Evidence_Types:	MFA enrollment reports, Identity provider MFA policy configuration, MFA exemption approval records, Authentication logs showing factor type used, Push notification configuration settings		

Least Privilege Access Provisioning

Category: Access Control

Business Objective

Access control policies govern how access to systems and data is requested, granted, reviewed, and revoked, ensuring the principle of least privilege is consistently applied. The Least Privilege Access Provisioning policy applies this principle specifically to least privilege access provisioning, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Access Control must comply with the requirements defined under Least Privilege Access Provisioning, and exceptions must be formally documented and approved by Chief Information Security Officer.

Detailed Requirements

1. Access grants must be approved by the resource owner prior to provisioning.
2. Privileged sessions must be recorded or logged in detail.
3. Access recertification must occur at least every ninety days for critical systems.
4. Break-glass access must trigger immediate notification to the security team.
5. Access control lists must be reviewed after any organizational restructuring.
6. Temporary access grants must expire automatically at the end of the approved period.

Indicators of Non-Compliance

- Break-glass access used without subsequent notification or review
- Access control lists unchanged after a reorganization
- Access granted without documented business justification
- Privileged sessions with no session recording or logging
- Recertification cycles skipped or overdue

Required Evidence

- Break-glass usage audit trail
- Access request and approval tickets
- Access control list exports
- Privileged session recording logs
- Recertification campaign results

Recommended Remediation

To remediate a violation of Least Privilege Access Provisioning, the accountable team should: (1) Configure break-glass accounts to trigger real-time alerts upon use. (2) Implement a formal access request workflow requiring documented justification and owner approval. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

AC-002, AC-003, EMPPRIV-002

AI Summary

This policy defines mandatory controls for least privilege access provisioning within the Access Control domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Information Security.

Example Compliant Scenario

A system owner within Information Security implements Least Privilege Access Provisioning in full: required controls are configured as specified, evidence such as break-glass usage audit trail is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant access request and approval tickets without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that break-glass access used without subsequent notification or review. Further investigation reveals that access control lists unchanged after a reorganization, and no compensating control was documented. The finding is logged against AC-001 with a High risk rating and routed to Chief Information Security Officer for remediation per the defined timeline.

Metadata

Policy_ID:	AC-001	Title:	Least Privilege Access Provisioning
Category:	Access Control	Risk_Level:	High
Department:	Information Security	Owner:	Chief Information Security Officer
Version:	1.9	Effective_Date:	October 11, 2025
Review_Cycle:	Annual	Priority:	High
Status:	Under Review	Related_Policies:	AC-002, AC-003, EMPPRIV-002
Keywords:	access control, least privilege, access request, recertification, privileged access management, PAM, break glass, access review, authorization, resource owner, session recording		
Search_Tags:	IAM, Privileged Access, Security, Least Privilege, Governance, Policy, PAM, Access Control		
Evidence_Types:	Break-glass usage audit trail, Access request and approval tickets, Access control list exports, Privileged session recording logs, Recertification campaign results		

Periodic Access Recertification

Category: Access Control

Business Objective

Access control policies govern how access to systems and data is requested, granted, reviewed, and revoked, ensuring the principle of least privilege is consistently applied. The Periodic Access Recertification policy applies this principle specifically to periodic access recertification, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Access Control must comply with the requirements defined under Periodic Access Recertification, and exceptions must be formally documented and approved by Chief Information Security Officer.

Detailed Requirements

1. Access recertification must occur at least every ninety days for critical systems.
2. Break-glass access must trigger immediate notification to the security team.
3. Access control lists must be reviewed after any organizational restructuring.
4. Temporary access grants must expire automatically at the end of the approved period.
5. Access requests must specify a documented business justification.
6. Access grants must be approved by the resource owner prior to provisioning.

Indicators of Non-Compliance

- Privileged sessions with no session recording or logging
- Recertification cycles skipped or overdue
- Break-glass access used without subsequent notification or review
- Access control lists unchanged after a reorganization
- Access granted without documented business justification

Required Evidence

- Recertification campaign results
- Break-glass usage audit trail
- Access request and approval tickets
- Access control list exports
- Privileged session recording logs

Recommended Remediation

To remediate a violation of Periodic Access Recertification, the accountable team should: (1) Implement a formal access request workflow requiring documented justification and owner approval. (2) Enable session recording for all privileged access to sensitive systems. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

AC-001, AC-003, PHYS-002

AI Summary

This policy defines mandatory controls for periodic access recertification within the Access Control domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Information Security.

Example Compliant Scenario

A system owner within Information Security implements Periodic Access Recertification in full: required controls are configured as specified, evidence such as recertification campaign results is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant break-glass usage audit trail without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that privileged sessions with no session recording or logging. Further investigation reveals that recertification cycles skipped or overdue, and no compensating control was documented. The finding is logged against AC-002 with a Medium risk rating and routed to Chief Information Security Officer for remediation per the defined timeline.

Metadata

Policy_ID:	AC-002	Title:	Periodic Access Recertification
Category:	Access Control	Risk_Level:	Medium
Department:	Information Security	Owner:	Chief Information Security Officer
Version:	1.4	Effective_Date:	March 8, 2025
Review_Cycle:	Quarterly	Priority:	Medium
Status:	Active	Related_Policies:	AC-001, AC-003, PHYS-002
Keywords:	access request, recertification, privileged access management, PAM, break glass, access review, authorization, resource owner, session recording, access control, least privilege		
Search_Tags:	Least Privilege, Governance, Policy, PAM, Access Control, IAM, Privileged Access, Security		
Evidence_Types:	Recertification campaign results, Break-glass usage audit trail, Access request and approval tickets, Access control list exports, Privileged session recording logs		

Privileged Access Management

Category: Access Control

Business Objective

Access control policies govern how access to systems and data is requested, granted, reviewed, and revoked, ensuring the principle of least privilege is consistently applied. The Privileged Access Management policy applies this principle specifically to privileged access management, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Access Control must comply with the requirements defined under Privileged Access Management, and exceptions must be formally documented and approved by Chief Information Security Officer.

Detailed Requirements

1. Access control lists must be reviewed after any organizational restructuring.
2. Temporary access grants must expire automatically at the end of the approved period.
3. Access requests must specify a documented business justification.
4. Access grants must be approved by the resource owner prior to provisioning.
5. Privileged sessions must be recorded or logged in detail.
6. Access recertification must occur at least every ninety days for critical systems.
7. Break-glass access must trigger immediate notification to the security team.

Indicators of Non-Compliance

- Access control lists unchanged after a reorganization
- Access granted without documented business justification
- Privileged sessions with no session recording or logging
- Recertification cycles skipped or overdue
- Break-glass access used without subsequent notification or review

Required Evidence

- Privileged session recording logs
- Recertification campaign results
- Break-glass usage audit trail
- Access request and approval tickets
- Access control list exports

Recommended Remediation

To remediate a violation of Privileged Access Management, the accountable team should: (1) Enable session recording for all privileged access to sensitive systems. (2) Establish an automated recertification campaign with escalation for overdue reviews. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

AC-001, AC-002, SDLC-003

AI Summary

This policy defines mandatory controls for privileged access management within the Access Control domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Critical risk and applies to all in-scope systems and personnel under Information Security.

Example Compliant Scenario

A system owner within Information Security implements Privileged Access Management in full: required controls are configured as specified, evidence such as privileged session recording logs is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant recertification campaign results without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that access control lists unchanged after a reorganization. Further investigation reveals that access granted without documented business justification, and no compensating control was documented. The finding is logged against AC-003 with a Critical risk rating and routed to Chief Information Security Officer for remediation per the defined timeline.

Metadata

Policy_ID:	AC-003	Title:	Privileged Access Management
Category:	Access Control	Risk_Level:	Critical
Department:	Information Security	Owner:	Chief Information Security Officer
Version:	3.6	Effective_Date:	April 8, 2025
Review_Cycle :	Annual	Priority:	Critical
Status:	Under Review	Related_Policies:	AC-001, AC-002, SDLC-003
Keywords:	privileged access management, PAM, break glass, access review, authorization, resource owner, session recording, access control, least privilege, access request, recertification		
Search_Tags:	PAM, Access Control, IAM, Privileged Access, Security, Least Privilege, Governance, Policy		
Evidence_Types:	Privileged session recording logs, Recertification campaign results, Break-glass usage audit trail, Access request and approval tickets, Access control list exports		

Encryption of Data at Rest

Category: Encryption

Business Objective

Encryption policies protect the confidentiality and integrity of data by rendering it unreadable to parties without appropriate cryptographic keys, both while stored and while in transit. The Encryption of Data at Rest policy applies this principle specifically to encryption of data at rest, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Encryption must comply with the requirements defined under Encryption of Data at Rest, and exceptions must be formally documented and approved by Chief Information Security Officer.

Detailed Requirements

1. Sensitive data at rest must be encrypted using an approved algorithm.
2. All external network traffic must use current, supported transport encryption.
3. Deprecated cryptographic protocols must be disabled on all endpoints.
4. Encryption keys must be managed separately from the data they protect.
5. Certificate expiration must be monitored with automated renewal alerts.

Indicators of Non-Compliance

- Encryption keys stored alongside the encrypted data
- Expired or self-signed certificates on production endpoints
- Custom-built cryptographic routines in production code
- Sensitive data stored in plaintext in databases or file shares

Required Evidence

- TLS configuration scan results
- Certificate inventory and expiration report
- Key management system configuration
- Cryptographic library version inventory
- Database encryption configuration

Recommended Remediation

To remediate a violation of Encryption of Data at Rest, the accountable team should: (1) Migrate custom cryptographic code to a vetted, standard library. (2) Implement automated certificate renewal and expiration monitoring. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

ENC-002, ENC-003, SEC-001

AI Summary

This policy defines mandatory controls for encryption of data at rest within the Encryption domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Critical risk and

applies to all in-scope systems and personnel under Information Security.

Example Compliant Scenario

A system owner within Information Security implements Encryption of Data at Rest in full: required controls are configured as specified, evidence such as tls configuration scan results is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant certificate inventory and expiration report without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that encryption keys stored alongside the encrypted data. Further investigation reveals that expired or self-signed certificates on production endpoints, and no compensating control was documented. The finding is logged against ENC-001 with a Critical risk rating and routed to Chief Information Security Officer for remediation per the defined timeline.

Metadata

Policy_ID:	ENC-001	Title:	Encryption of Data at Rest
Category:	Encryption	Risk_Level:	Critical
Department:	Information Security	Owner:	Chief Information Security Officer
Version:	1.2	Effective_Date:	October 14, 2025
Review_Cycle :	Quarterly	Priority:	Critical
Status:	Active	Related_Policies:	ENC-002, ENC-003, SEC-001
Keywords:	key management, cipher, algorithm, encryption key, transport security, encryption, cryptography, data at rest, data in transit, TLS, certificate		
Search_Tags:	Data Protection, Security, TLS, Key Management, Policy, Confidentiality, Encryption, Cryptography		
Evidence_Types:	TLS configuration scan results, Certificate inventory and expiration report, Key management system configuration, Cryptographic library version inventory, Database encryption configuration		

Encryption of Data in Transit

Category: Encryption

Business Objective

Encryption policies protect the confidentiality and integrity of data by rendering it unreadable to parties without appropriate cryptographic keys, both while stored and while in transit. The Encryption of Data in Transit policy applies this principle specifically to encryption of data in transit, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Encryption must comply with the requirements defined under Encryption of Data in Transit, and exceptions must be formally documented and approved by Chief Information Security Officer.

Detailed Requirements

1. Deprecated cryptographic protocols must be disabled on all endpoints.
2. Encryption keys must be managed separately from the data they protect.
3. Certificate expiration must be monitored with automated renewal alerts.
4. Cryptographic implementations must rely on vetted, standard libraries rather than custom code.
5. Encrypted backups must be verified periodically for successful restoration.
6. Sensitive data at rest must be encrypted using an approved algorithm.

Indicators of Non-Compliance

- Sensitive data stored in plaintext in databases or file shares
- Use of deprecated transport protocols such as outdated TLS versions
- Encryption keys stored alongside the encrypted data
- Expired or self-signed certificates on production endpoints
- Custom-built cryptographic routines in production code

Required Evidence

- Database encryption configuration
- TLS configuration scan results
- Certificate inventory and expiration report
- Key management system configuration
- Cryptographic library version inventory

Recommended Remediation

To remediate a violation of Encryption of Data in Transit, the accountable team should: (1) Implement automated certificate renewal and expiration monitoring. (2) Enable encryption at rest for all data stores classified as sensitive or higher. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

ENC-001, ENC-003, GENAI-002

AI Summary

This policy defines mandatory controls for encryption of data in transit within the Encryption domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Critical risk and applies to all in-scope systems and personnel under Information Security.

Example Compliant Scenario

A system owner within Information Security implements Encryption of Data in Transit in full: required controls are configured as specified, evidence such as database encryption configuration is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant tls configuration scan results without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that sensitive data stored in plaintext in databases or file shares. Further investigation reveals that use of deprecated transport protocols such as outdated tls versions, and no compensating control was documented. The finding is logged against ENC-002 with a Critical risk rating and routed to Chief Information Security Officer for remediation per the defined timeline.

Metadata

Policy_ID:	ENC-002	Title:	Encryption of Data in Transit
Category:	Encryption	Risk_Level:	Critical
Department:	Information Security	Owner:	Chief Information Security Officer
Version:	3.4	Effective_Date:	August 28, 2025
Review_Cycle:	Annual	Priority:	Critical
Status:	Active	Related_Policies:	ENC-001, ENC-003, GENAI-002
Keywords:	algorithm, encryption key, transport security, encryption, cryptography, data at rest, data in transit, TLS, certificate, key management, cipher		
Search_Tags:	Key Management, Policy, Confidentiality, Encryption, Cryptography, Data Protection, Security, TLS		
Evidence_Types:	Database encryption configuration, TLS configuration scan results, Certificate inventory and expiration report, Key management system configuration, Cryptographic library version inventory		

Approved Cryptographic Algorithms

Category: Encryption

Business Objective

Encryption policies protect the confidentiality and integrity of data by rendering it unreadable to parties without appropriate cryptographic keys, both while stored and while in transit. The Approved Cryptographic Algorithms policy applies this principle specifically to approved cryptographic algorithms, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Encryption must comply with the requirements defined under Approved Cryptographic Algorithms, and exceptions must be formally documented and approved by Chief Information Security Officer.

Detailed Requirements

1. Certificate expiration must be monitored with automated renewal alerts.
2. Cryptographic implementations must rely on vetted, standard libraries rather than custom code.
3. Encrypted backups must be verified periodically for successful restoration.
4. Sensitive data at rest must be encrypted using an approved algorithm.
5. All external network traffic must use current, supported transport encryption.
6. Deprecated cryptographic protocols must be disabled on all endpoints.
7. Encryption keys must be managed separately from the data they protect.

Indicators of Non-Compliance

- Expired or self-signed certificates on production endpoints
- Custom-built cryptographic routines in production code
- Sensitive data stored in plaintext in databases or file shares
- Use of deprecated transport protocols such as outdated TLS versions
- Encryption keys stored alongside the encrypted data

Required Evidence

- Cryptographic library version inventory
- Database encryption configuration
- TLS configuration scan results
- Certificate inventory and expiration report
- Key management system configuration

Recommended Remediation

To remediate a violation of Approved Cryptographic Algorithms, the accountable team should: (1) Enable encryption at rest for all data stores classified as sensitive or higher. (2) Disable deprecated protocol versions and enforce current transport encryption standards. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

ENC-001, ENC-002, BCP-002

AI Summary

This policy defines mandatory controls for approved cryptographic algorithms within the Encryption domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Information Security.

Example Compliant Scenario

A system owner within Information Security implements Approved Cryptographic Algorithms in full: required controls are configured as specified, evidence such as cryptographic library version inventory is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant database encryption configuration without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that expired or self-signed certificates on production endpoints. Further investigation reveals that custom-built cryptographic routines in production code, and no compensating control was documented. The finding is logged against ENC-003 with a High risk rating and routed to Chief Information Security Officer for remediation per the defined timeline.

Metadata

Policy_ID:	ENC-003	Title:	Approved Cryptographic Algorithms
Category:	Encryption	Risk_Level:	High
Department:	Information Security	Owner:	Chief Information Security Officer
Version:	3.5	Effective_Date:	January 10, 2025
Review_Cycle:	Semi-Annual	Priority:	High
Status:	Active	Related_Policies:	ENC-001, ENC-002, BCP-002
Keywords:	transport security, encryption, cryptography, data at rest, data in transit, TLS, certificate, key management, cipher, algorithm, encryption key		
Search_Tags:	Encryption, Cryptography, Data Protection, Security, TLS, Key Management, Policy, Confidentiality		
Evidence_Types:	Cryptographic library version inventory, Database encryption configuration, TLS configuration scan results, Certificate inventory and expiration report, Key management system configuration		

Cryptographic Key Rotation

Category: Key Management

Business Objective

Key management policies ensure that cryptographic keys are generated, stored, rotated, and retired in a manner that preserves the protection they are intended to provide. The Cryptographic Key Rotation policy applies this principle specifically to cryptographic key rotation, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Key Management must comply with the requirements defined under Cryptographic Key Rotation, and exceptions must be formally documented and approved by Chief Information Security Officer.

Detailed Requirements

1. Compromised keys must be revoked and rotated immediately upon discovery.
2. Key usage must be logged, including which service or identity accessed the key.
3. Encryption keys must be rotated on a defined schedule appropriate to their sensitivity.
4. Root and master keys must be stored in a hardware security module or equivalent.
5. Access to key management systems must be restricted to a small, named group.
6. Key generation must use an approved cryptographically secure random source.

Indicators of Non-Compliance

- Master keys stored in general-purpose application servers
- Broad, unrestricted access to the key management system
- No logging of key access or usage
- Keys generated using a non-cryptographic random function

Required Evidence

- Key management system access logs
- Key rotation schedule and history
- HSM configuration and inventory
- Key access permission lists

Recommended Remediation

To remediate a violation of Cryptographic Key Rotation, the accountable team should: (1) Migrate root and master key storage into a hardware security module. (2) Restrict key management system access to a documented, minimal set of identities. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

KEY-002, AUTH-002, AUTH-003

AI Summary

This policy defines mandatory controls for cryptographic key rotation within the Key Management domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Information Security.

Example Compliant Scenario

A system owner within Information Security implements Cryptographic Key Rotation in full: required controls are configured as specified, evidence such as key management system access logs is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant key rotation schedule and history without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that master keys stored in general-purpose application servers. Further investigation reveals that broad, unrestricted access to the key management system, and no compensating control was documented. The finding is logged against KEY-001 with a High risk rating and routed to Chief Information Security Officer for remediation per the defined timeline.

Metadata

Policy_ID:	KEY-001	Title:	Cryptographic Key Rotation
Category:	Key Management	Risk_Level:	High
Department:	Information Security	Owner:	Chief Information Security Officer
Version:	3.2	Effective_Date:	August 4, 2025
Review_Cycle :	Quarterly	Priority:	High
Status:	Active	Related_Policies:	KEY-002, AUTH-002, AUTH-003
Keywords:	key generation, key revocation, key management, key rotation, HSM, hardware security module, cryptographic key, master key, key access		
Search_Tags:	Encryption, Security, HSM, Policy, Data Protection, Key Management, Cryptography		
Evidence_Types:	Key management system access logs, Key rotation schedule and history, HSM configuration and inventory, Key access permission lists		

Hardware Security Module Usage

Category: Key Management

Business Objective

Key management policies ensure that cryptographic keys are generated, stored, rotated, and retired in a manner that preserves the protection they are intended to provide. The Hardware Security Module Usage policy applies this principle specifically to hardware security module usage, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Key Management must comply with the requirements defined under Hardware Security Module Usage, and exceptions must be formally documented and approved by Chief Information Security Officer.

Detailed Requirements

1. Encryption keys must be rotated on a defined schedule appropriate to their sensitivity.
2. Root and master keys must be stored in a hardware security module or equivalent.
3. Access to key management systems must be restricted to a small, named group.
4. Key generation must use an approved cryptographically secure random source.
5. Compromised keys must be revoked and rotated immediately upon discovery.
6. Key usage must be logged, including which service or identity accessed the key.

Indicators of Non-Compliance

- Keys generated using a non-cryptographic random function
- Encryption keys that have never been rotated
- Master keys stored in general-purpose application servers
- Broad, unrestricted access to the key management system
- No logging of key access or usage

Required Evidence

- Key management system access logs
- Key rotation schedule and history
- HSM configuration and inventory
- Key access permission lists

Recommended Remediation

To remediate a violation of Hardware Security Module Usage, the accountable team should: (1) Restrict key management system access to a documented, minimal set of identities. (2) Enable detailed logging of all key access and usage events. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

KEY-001, IDM-002, PWD-001

AI Summary

This policy defines mandatory controls for hardware security module usage within the Key Management domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Critical risk and applies to all in-scope systems and personnel under Information Security.

Example Compliant Scenario

A system owner within Information Security implements Hardware Security Module Usage in full: required controls are configured as specified, evidence such as key management system access logs is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant key rotation schedule and history without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that keys generated using a non-cryptographic random function. Further investigation reveals that encryption keys that have never been rotated, and no compensating control was documented. The finding is logged against KEY-002 with a Critical risk rating and routed to Chief Information Security Officer for remediation per the defined timeline.

Metadata

Policy_ID:	KEY-002	Title:	Hardware Security Module Usage
Category:	Key Management	Risk_Level:	Critical
Department:	Information Security	Owner:	Chief Information Security Officer
Version:	1.5	Effective_Date:	March 18, 2025
Review_Cycle :	Quarterly	Priority:	Critical
Status:	Active	Related_Policies:	KEY-001, IDM-002, PWD-001
Keywords:	key management, key rotation, HSM, hardware security module, cryptographic key, master key, key access, key generation, key revocation		
Search_Tags:	Policy, Data Protection, Key Management, Cryptography, Encryption, Security, HSM		
Evidence_Types:	Key management system access logs, Key rotation schedule and history, HSM configuration and inventory, Key access permission lists		

API Authentication and Authorization

Category: API Security

Business Objective

API security policies protect programmatic interfaces from misuse, ensuring that only authenticated, authorized, and rate-limited requests can access backend systems and data. The API Authentication and Authorization policy applies this principle specifically to api authentication and authorization, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of API Security must comply with the requirements defined under API Authentication and Authorization, and exceptions must be formally documented and approved by Head of Application Security.

Detailed Requirements

1. API input must be validated and sanitized on the server side.
2. Deprecated API versions must be retired on a published timeline.
3. API error responses must not leak internal implementation details.
4. API access must be logged with sufficient detail to support incident investigation.
5. All API endpoints must require authentication unless explicitly designated public.
6. API keys must be scoped to the minimum required permissions.
7. APIs must enforce rate limiting to prevent abuse and denial-of-service conditions.

Indicators of Non-Compliance

- No rate limiting on public-facing API endpoints
- Verbose error messages exposing stack traces or internal paths
- Deprecated API versions still accepting production traffic
- Unauthenticated access permitted on non-public API endpoints
- Overly broad API key scopes

Required Evidence

- API key scope inventory
- Rate limiting configuration
- API access logs
- API versioning and deprecation schedule
- API gateway configuration

Recommended Remediation

To remediate a violation of API Authentication and Authorization, the accountable team should: (1) Publish and enforce a deprecation timeline for legacy API versions. (2) Enforce authentication on all non-public endpoints and audit key scopes for over-permissioning. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

API-002, AC-001, AC-002

AI Summary

This policy defines mandatory controls for api authentication and authorization within the API Security domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Application Security.

Example Compliant Scenario

A system owner within Application Security implements API Authentication and Authorization in full: required controls are configured as specified, evidence such as api key scope inventory is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant rate limiting configuration without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that no rate limiting on public-facing api endpoints. Further investigation reveals that verbose error messages exposing stack traces or internal paths, and no compensating control was documented. The finding is logged against API-001 with a High risk rating and routed to Head of Application Security for remediation per the defined timeline.

Metadata

Policy_ID:	API-001	Title:	API Authentication and Authorization
Category:	API Security	Risk_Level:	High
Department:	Application Security	Owner:	Head of Application Security
Version:	1.1	Effective_Date:	April 27, 2025
Review_Cycle:	Semi-Annual	Priority:	High
Status:	Active	Related_Policies:	API-002, AC-001, AC-002
Keywords:	abuse prevention, denial of service, API security, API key, rate limiting, authentication, authorization, API gateway, input validation, API versioning		
Search_Tags:	Application Security, Security, Access Control, Rate Limiting, Policy, Software Development, API Security		
Evidence_Types:	API key scope inventory, Rate limiting configuration, API access logs, API versioning and deprecation schedule, API gateway configuration		

API Rate Limiting and Abuse Prevention

Category: API Security

Business Objective

API security policies protect programmatic interfaces from misuse, ensuring that only authenticated, authorized, and rate-limited requests can access backend systems and data. The API Rate Limiting and Abuse Prevention policy applies this principle specifically to api rate limiting and abuse prevention, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of API Security must comply with the requirements defined under API Rate Limiting and Abuse Prevention, and exceptions must be formally documented and approved by Head of Application Security.

Detailed Requirements

1. API error responses must not leak internal implementation details.
2. API access must be logged with sufficient detail to support incident investigation.
3. All API endpoints must require authentication unless explicitly designated public.
4. API keys must be scoped to the minimum required permissions.
5. APIs must enforce rate limiting to prevent abuse and denial-of-service conditions.

Indicators of Non-Compliance

- Unauthenticated access permitted on non-public API endpoints
- Overly broad API key scopes
- No rate limiting on public-facing API endpoints
- Verbose error messages exposing stack traces or internal paths

Required Evidence

- API gateway configuration
- API key scope inventory
- Rate limiting configuration
- API access logs
- API versioning and deprecation schedule

Recommended Remediation

To remediate a violation of API Rate Limiting and Abuse Prevention, the accountable team should: (1) Enforce authentication on all non-public endpoints and audit key scopes for over-permissioning. (2) Implement rate limiting and anomaly detection at the API gateway. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

API-001, ENC-003, KEY-001

AI Summary

This policy defines mandatory controls for api rate limiting and abuse prevention within the API Security domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Application Security.

Example Compliant Scenario

A system owner within Application Security implements API Rate Limiting and Abuse Prevention in full: required controls are configured as specified, evidence such as api gateway configuration is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant api key scope inventory without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that unauthenticated access permitted on non-public api endpoints. Further investigation reveals that overly broad api key scopes, and no compensating control was documented. The finding is logged against API-002 with a Medium risk rating and routed to Head of Application Security for remediation per the defined timeline.

Metadata

Policy_ID:	API-002	Title:	API Rate Limiting and Abuse Prevention
Category:	API Security	Risk_Level:	Medium
Department:	Application Security	Owner:	Head of Application Security
Version:	1.7	Effective_Date:	January 25, 2025
Review_Cycle :	Quarterly	Priority:	Medium
Status:	Active	Related_Policies:	API-001, ENC-003, KEY-001
Keywords:	API security, API key, rate limiting, authentication, authorization, API gateway, input validation, API versioning, abuse prevention, denial of service		
Search_Tags:	Rate Limiting, Policy, Software Development, API Security, Application Security, Security, Access Control		
Evidence_Types:	API gateway configuration, API key scope inventory, Rate limiting configuration, API access logs, API versioning and deprecation schedule		

Cloud Storage Bucket Access Configuration

Category: Cloud Security

Business Objective

Cloud security policies address the shared-responsibility nature of cloud environments, ensuring that configuration, identity, and network controls are correctly applied across all cloud resources. The Cloud Storage Bucket Access Configuration policy applies this principle specifically to cloud storage bucket access configuration, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Cloud Security must comply with the requirements defined under Cloud Storage Bucket Access Configuration, and exceptions must be formally documented and approved by Director of Cloud Infrastructure.

Detailed Requirements

1. Cloud storage resources must default to private access unless explicitly justified.
2. Cloud accounts must be federated to the central identity provider rather than using local credentials.
3. Infrastructure must be provisioned through version-controlled infrastructure-as-code.
4. Cloud resources must be tagged with owner, environment, and cost center metadata.
5. Publicly exposed cloud resources must undergo a documented security review before launch.

Indicators of Non-Compliance

- Cloud resources missing ownership or environment tags
- High-severity cloud security findings left untriaged
- Storage buckets configured for public read or write access
- Cloud accounts using local credentials instead of federated identity
- Resources provisioned manually outside infrastructure-as-code

Required Evidence

- Identity federation configuration
- Cloud console configuration screenshots
- Infrastructure-as-code repository
- Cloud security posture management findings
- Resource tagging compliance report

Recommended Remediation

To remediate a violation of Cloud Storage Bucket Access Configuration, the accountable team should: (1) Federate all cloud accounts to the central identity provider and disable local credential login. (2) Enforce provisioning exclusively through reviewed infrastructure-as-code pipelines. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

CLOUD-002, CLOUD-003, NET-002

AI Summary

This policy defines mandatory controls for cloud storage bucket access configuration within the Cloud Security domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Critical risk and applies to all in-scope systems and personnel under Cloud Infrastructure.

Example Compliant Scenario

A system owner within Cloud Infrastructure implements Cloud Storage Bucket Access Configuration in full: required controls are configured as specified, evidence such as identity federation configuration is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant cloud console configuration screenshots without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that cloud resources missing ownership or environment tags. Further investigation reveals that high-severity cloud security findings left untriaged, and no compensating control was documented. The finding is logged against CLOUD-001 with a Critical risk rating and routed to Director of Cloud Infrastructure for remediation per the defined timeline.

Metadata

Policy_ID:	CLOUD-001	Title:	Cloud Storage Bucket Access Configuration
Category:	Cloud Security	Risk_Level:	Critical
Department:	Cloud Infrastructure	Owner:	Director of Cloud Infrastructure
Version:	3.2	Effective_Date:	April 17, 2025
Review_Cycle :	Quarterly	Priority:	Critical
Status:	Under Review	Related_Policies:	CLOUD-002, CLOUD-003, NET-002
Keywords:	infrastructure as code, cloud identity, federation, resource tagging, cloud posture, public exposure, cloud account, orphaned resource, cloud security, cloud storage		
Search_Tags:	Governance, Cloud Security, Infrastructure, Security, Cloud Storage, Identity Federation, Policy, IaC		
Evidence_Types:	Identity federation configuration, Cloud console configuration screenshots, Infrastructure-as-code repository, Cloud security posture management findings, Resource tagging compliance report		

Cloud Identity and Access Federation

Category: Cloud Security

Business Objective

Cloud security policies address the shared-responsibility nature of cloud environments, ensuring that configuration, identity, and network controls are correctly applied across all cloud resources. The Cloud Identity and Access Federation policy applies this principle specifically to cloud identity and access federation, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Cloud Security must comply with the requirements defined under Cloud Identity and Access Federation, and exceptions must be formally documented and approved by Director of Cloud Infrastructure.

Detailed Requirements

1. Infrastructure must be provisioned through version-controlled infrastructure-as-code.
2. Cloud resources must be tagged with owner, environment, and cost center metadata.
3. Publicly exposed cloud resources must undergo a documented security review before launch.
4. Cloud provider security findings must be triaged within a defined service level.
5. Unused or orphaned cloud resources must be identified and decommissioned periodically.

Indicators of Non-Compliance

- Cloud accounts using local credentials instead of federated identity
- Resources provisioned manually outside infrastructure-as-code
- Cloud resources missing ownership or environment tags
- High-severity cloud security findings left untriated
- Storage buckets configured for public read or write access

Required Evidence

- Resource tagging compliance report
- Identity federation configuration
- Cloud console configuration screenshots
- Infrastructure-as-code repository
- Cloud security posture management findings

Recommended Remediation

To remediate a violation of Cloud Identity and Access Federation, the accountable team should: (1) Enforce provisioning exclusively through reviewed infrastructure-as-code pipelines. (2) Implement automated tagging policies and periodic orphaned-resource cleanup. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

CLOUD-001, CLOUD-003, DEV-001

AI Summary

This policy defines mandatory controls for cloud identity and access federation within the Cloud Security domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Cloud Infrastructure.

Example Compliant Scenario

A system owner within Cloud Infrastructure implements Cloud Identity and Access Federation in full: required controls are configured as specified, evidence such as resource tagging compliance report is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant identity federation configuration without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that cloud accounts using local credentials instead of federated identity. Further investigation reveals that resources provisioned manually outside infrastructure-as-code, and no compensating control was documented. The finding is logged against CLOUD-002 with a High risk rating and routed to Director of Cloud Infrastructure for remediation per the defined timeline.

Metadata

Policy_ID:	CLOUD-002	Title:	Cloud Identity and Access Federation
Category:	Cloud Security	Risk_Level:	High
Department:	Cloud Infrastructure	Owner:	Director of Cloud Infrastructure
Version:	3.4	Effective_Date:	June 22, 2025
Review_Cycle :	Quarterly	Priority:	High
Status:	Active	Related_Policies:	CLOUD-001, CLOUD-003, DEV-001
Keywords:	federation, resource tagging, cloud posture, public exposure, cloud account, orphaned resource, cloud security, cloud storage, infrastructure as code, cloud identity		
Search_Tags:	Security, Cloud Storage, Identity Federation, Policy, IaC, Governance, Cloud Security, Infrastructure		
Evidence_Types:	Resource tagging compliance report, Identity federation configuration, Cloud console configuration screenshots, Infrastructure-as-code repository, Cloud security posture management findings		

Cloud Resource Tagging and Ownership

Category: Cloud Security

Business Objective

Cloud security policies address the shared-responsibility nature of cloud environments, ensuring that configuration, identity, and network controls are correctly applied across all cloud resources. The Cloud Resource Tagging and Ownership policy applies this principle specifically to cloud resource tagging and ownership, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Cloud Security must comply with the requirements defined under Cloud Resource Tagging and Ownership, and exceptions must be formally documented and approved by Director of Cloud Infrastructure.

Detailed Requirements

1. Publicly exposed cloud resources must undergo a documented security review before launch.
2. Cloud provider security findings must be triaged within a defined service level.
3. Unused or orphaned cloud resources must be identified and decommissioned periodically.
4. Cloud storage resources must default to private access unless explicitly justified.
5. Cloud accounts must be federated to the central identity provider rather than using local credentials.
6. Infrastructure must be provisioned through version-controlled infrastructure-as-code.

Indicators of Non-Compliance

- High-severity cloud security findings left untriated
- Storage buckets configured for public read or write access
- Cloud accounts using local credentials instead of federated identity
- Resources provisioned manually outside infrastructure-as-code
- Cloud resources missing ownership or environment tags

Required Evidence

- Cloud security posture management findings
- Resource tagging compliance report
- Identity federation configuration
- Cloud console configuration screenshots
- Infrastructure-as-code repository

Recommended Remediation

To remediate a violation of Cloud Resource Tagging and Ownership, the accountable team should: (1) Implement automated tagging policies and periodic orphaned-resource cleanup. (2) Reconfigure storage resources to default-private and require explicit justification for public exposure. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

CLOUD-001, CLOUD-002, AUD-001

AI Summary

This policy defines mandatory controls for cloud resource tagging and ownership within the Cloud Security domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Low risk and applies to all in-scope systems and personnel under Cloud Infrastructure.

Example Compliant Scenario

A system owner within Cloud Infrastructure implements Cloud Resource Tagging and Ownership in full: required controls are configured as specified, evidence such as cloud security posture management findings is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant resource tagging compliance report without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that high-severity cloud security findings left untriaged. Further investigation reveals that storage buckets configured for public read or write access, and no compensating control was documented. The finding is logged against CLOUD-003 with a Low risk rating and routed to Director of Cloud Infrastructure for remediation per the defined timeline.

Metadata

Policy_ID:	CLOUD-003	Title:	Cloud Resource Tagging and Ownership
Category:	Cloud Security	Risk_Level:	Low
Department:	Cloud Infrastructure	Owner:	Director of Cloud Infrastructure
Version:	1.3	Effective_Date:	March 3, 2025
Review_Cycle :	Semi-Annual	Priority:	Low
Status:	Active	Related_Policies:	CLOUD-001, CLOUD-002, AUD-001
Keywords:	cloud posture, public exposure, cloud account, orphaned resource, cloud security, cloud storage, infrastructure as code, cloud identity, federation, resource tagging		
Search_Tags:	Policy, IaC, Governance, Cloud Security, Infrastructure, Security, Cloud Storage, Identity Federation		
Evidence_Types:	Cloud security posture management findings, Resource tagging compliance report, Identity federation configuration, Cloud console configuration screenshots, Infrastructure-as-code repository		

Network Segmentation Standards

Category: Network Security

Business Objective

Network security policies segment, monitor, and restrict traffic flows to reduce the attack surface available to an adversary who gains a foothold within the environment. The Network Segmentation Standards policy applies this principle specifically to network segmentation standards, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Network Security must comply with the requirements defined under Network Segmentation Standards, and exceptions must be formally documented and approved by Director of Infrastructure Security.

Detailed Requirements

1. Production networks must be segmented from corporate and development networks.
2. East-west traffic between segments must be restricted by default and explicitly allowed.
3. VPN access must require MFA and be logged with session duration.
4. Network diagrams must be kept current and reviewed at least annually.
5. Unused network ports and services must be disabled on all hosts.
6. Intrusion detection systems must be deployed at key network boundaries.

Indicators of Non-Compliance

- Outdated or missing network diagrams
- Unused open ports discovered during scanning
- No intrusion detection coverage at network boundaries
- Flat network architecture with no segmentation between environments
- VPN access without MFA enforcement

Required Evidence

- Firewall and VPN configuration exports
- Port scanning results
- Intrusion detection system logs
- VPN access and session logs
- Network segmentation diagrams

Recommended Remediation

To remediate a violation of Network Segmentation Standards, the accountable team should: (1) Implement network segmentation between production, corporate, and development environments. (2) Enforce MFA on all VPN connections and enable session logging. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

NET-002, INC-002, INC-003

AI Summary

This policy defines mandatory controls for network segmentation standards within the Network Security domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Infrastructure Security.

Example Compliant Scenario

A system owner within Infrastructure Security implements Network Segmentation Standards in full: required controls are configured as specified, evidence such as firewall and vpn configuration exports is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant port scanning results without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that outdated or missing network diagrams. Further investigation reveals that unused open ports discovered during scanning, and no compensating control was documented. The finding is logged against NET-001 with a High risk rating and routed to Director of Infrastructure Security for remediation per the defined timeline.

Metadata

Policy_ID:	NET-001	Title:	Network Segmentation Standards
Category:	Network Security	Risk_Level:	High
Department:	Infrastructure Security	Owner:	Director of Infrastructure Security
Version:	3.3	Effective_Date:	January 3, 2025
Review_Cycle:	Quarterly	Priority:	High
Status:	Active	Related_Policies:	NET-002, INC-002, INC-003
Keywords:	port scanning, network boundary, network security, segmentation, VPN, firewall, intrusion detection, network diagram, east-west traffic, remote access		
Search_Tags:	Security, VPN, Segmentation, Policy, Remote Access, Network Security, Infrastructure		
Evidence_Types:	Firewall and VPN configuration exports, Port scanning results, Intrusion detection system logs, VPN access and session logs, Network segmentation diagrams		

Remote Network Access via VPN

Category: Network Security

Business Objective

Network security policies segment, monitor, and restrict traffic flows to reduce the attack surface available to an adversary who gains a foothold within the environment. The Remote Network Access via VPN policy applies this principle specifically to remote network access via vpn, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Network Security must comply with the requirements defined under Remote Network Access via VPN, and exceptions must be formally documented and approved by Director of Infrastructure Security.

Detailed Requirements

1. VPN access must require MFA and be logged with session duration.
2. Network diagrams must be kept current and reviewed at least annually.
3. Unused network ports and services must be disabled on all hosts.
4. Intrusion detection systems must be deployed at key network boundaries.
5. Production networks must be segmented from corporate and development networks.

Indicators of Non-Compliance

- Flat network architecture with no segmentation between environments
- VPN access without MFA enforcement
- Outdated or missing network diagrams
- Unused open ports discovered during scanning

Required Evidence

- Network segmentation diagrams
- Firewall and VPN configuration exports
- Port scanning results
- Intrusion detection system logs
- VPN access and session logs

Recommended Remediation

To remediate a violation of Remote Network Access via VPN, the accountable team should: (1) Enforce MFA on all VPN connections and enable session logging. (2) Disable unused ports and services identified during scanning. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

NET-001, PATCH-002, BACKUP-001

AI Summary

This policy defines mandatory controls for remote network access via vpn within the Network Security domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified

as Medium risk and applies to all in-scope systems and personnel under Infrastructure Security.

Example Compliant Scenario

A system owner within Infrastructure Security implements Remote Network Access via VPN in full: required controls are configured as specified, evidence such as network segmentation diagrams is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant firewall and vpn configuration exports without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that flat network architecture with no segmentation between environments. Further investigation reveals that vpn access without mfa enforcement, and no compensating control was documented. The finding is logged against NET-002 with a Medium risk rating and routed to Director of Infrastructure Security for remediation per the defined timeline.

Metadata

Policy_ID:	NET-002	Title:	Remote Network Access via VPN
Category:	Network Security	Risk_Level:	Medium
Department:	Infrastructure Security	Owner:	Director of Infrastructure Security
Version:	2.1	Effective_Date:	August 8, 2025
Review_Cycle :	Semi-Annual	Priority:	Medium
Status:	Under Review	Related_Policies:	NET-001, PATCH-002, BACKUP-001
Keywords:	network security, segmentation, VPN, firewall, intrusion detection, network diagram, east-west traffic, remote access, port scanning, network boundary		
Search_Tags:	Policy, Remote Access, Network Security, Infrastructure, Security, VPN, Segmentation		
Evidence_Types:	Network segmentation diagrams, Firewall and VPN configuration exports, Port scanning results, Intrusion detection system logs, VPN access and session logs		

Firewall Rule Change Management

Category: Firewall Configuration

Business Objective

Firewall configuration policies control which network traffic is permitted to traverse organizational boundaries, reducing exposure to unauthorized inbound and outbound connections. The Firewall Rule Change Management policy applies this principle specifically to firewall rule change management, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Firewall Configuration must comply with the requirements defined under Firewall Rule Change Management, and exceptions must be formally documented and approved by Director of Infrastructure Security.

Detailed Requirements

1. Firewall configuration changes must be logged with the identity of the requester.
2. Outbound traffic to known-malicious destinations must be blocked at the perimeter.
3. Firewall rules must default to deny for all inbound traffic.
4. Firewall rule changes must go through a documented approval process.
5. Overly permissive rules such as any-to-any must be prohibited without exception approval.

Indicators of Non-Compliance

- No logging of who made a given firewall change
- Outbound connections to known-malicious IP ranges not blocked
- Firewall rules permitting any-to-any traffic
- Rule changes made without an approval ticket
- Stale, unused rules remaining after system decommissioning

Required Evidence

- Firewall rule base exports
- Change management tickets for firewall modifications
- Firewall rule review reports
- Perimeter blocklist configuration

Recommended Remediation

To remediate a violation of Firewall Rule Change Management, the accountable team should: (1) Schedule recurring rule-base reviews to prune unused entries. (2) Integrate threat intelligence blocklists into perimeter firewall policy. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

FW-002, DB-002, DC-001

AI Summary

This policy defines mandatory controls for firewall rule change management within the Firewall Configuration domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Infrastructure Security.

Example Compliant Scenario

A system owner within Infrastructure Security implements Firewall Rule Change Management in full: required controls are configured as specified, evidence such as firewall rule base exports is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant change management tickets for firewall modifications without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that no logging of who made a given firewall change. Further investigation reveals that outbound connections to known-malicious ip ranges not blocked, and no compensating control was documented. The finding is logged against FW-001 with a High risk rating and routed to Director of Infrastructure Security for remediation per the defined timeline.

Metadata

Policy_ID:	FW-001	Title:	Firewall Rule Change Management
Category:	Firewall Configuration	Risk_Level:	High
Department:	Infrastructure Security	Owner:	Director of Infrastructure Security
Version:	3.9	Effective_Date:	August 16, 2025
Review_Cycle :	Annual	Priority:	High
Status:	Under Review	Related_Policies:	FW-002, DB-002, DC-001
Keywords:	change management, network policy, firewall, rule change, default deny, perimeter security, any-to-any rule, rule review, outbound filtering		
Search_Tags:	Firewall Configuration, Network Security, Security, Change Management, Policy, Perimeter Security		
Evidence_Types:	Firewall rule base exports, Change management tickets for firewall modifications, Firewall rule review reports, Perimeter blocklist configuration		

Default-Deny Firewall Baseline

Category: Firewall Configuration

Business Objective

Firewall configuration policies control which network traffic is permitted to traverse organizational boundaries, reducing exposure to unauthorized inbound and outbound connections. The Default-Deny Firewall Baseline policy applies this principle specifically to default-deny firewall baseline, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Firewall Configuration must comply with the requirements defined under Default-Deny Firewall Baseline, and exceptions must be formally documented and approved by Director of Infrastructure Security.

Detailed Requirements

1. Firewall rules must default to deny for all inbound traffic.
2. Firewall rule changes must go through a documented approval process.
3. Overly permissive rules such as any-to-any must be prohibited without exception approval.
4. Firewall rule sets must be reviewed at least semi-annually to remove unused rules.
5. Firewall configuration changes must be logged with the identity of the requester.
6. Outbound traffic to known-malicious destinations must be blocked at the perimeter.

Indicators of Non-Compliance

- Rule changes made without an approval ticket
- Stale, unused rules remaining after system decommissioning
- No logging of who made a given firewall change
- Outbound connections to known-malicious IP ranges not blocked

Required Evidence

- Firewall rule base exports
- Change management tickets for firewall modifications
- Firewall rule review reports
- Perimeter blocklist configuration

Recommended Remediation

To remediate a violation of Default-Deny Firewall Baseline, the accountable team should: (1) Integrate threat intelligence blocklists into perimeter firewall policy. (2) Remove overly permissive rules and replace them with narrowly scoped equivalents. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

FW-001, DISP-001, DISP-002

AI Summary

This policy defines mandatory controls for default-deny firewall baseline within the Firewall Configuration domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Infrastructure Security.

Example Compliant Scenario

A system owner within Infrastructure Security implements Default-Deny Firewall Baseline in full: required controls are configured as specified, evidence such as firewall rule base exports is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant change management tickets for firewall modifications without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that rule changes made without an approval ticket. Further investigation reveals that stale, unused rules remaining after system decommissioning, and no compensating control was documented. The finding is logged against FW-002 with a High risk rating and routed to Director of Infrastructure Security for remediation per the defined timeline.

Metadata

Policy_ID:	FW-002	Title:	Default-Deny Firewall Baseline
Category:	Firewall Configuration	Risk_Level:	High
Department:	Infrastructure Security	Owner:	Director of Infrastructure Security
Version:	1.6	Effective_Date:	April 14, 2025
Review_Cycle :	Semi-Annual	Priority:	High
Status:	Under Review	Related_Policies:	FW-001, DISP-001, DISP-002
Keywords:	firewall, rule change, default deny, perimeter security, any-to-any rule, rule review, outbound filtering, change management, network policy		
Search_Tags:	Change Management, Policy, Perimeter Security, Firewall Configuration, Network Security, Security		
Evidence_Types:	Firewall rule base exports, Change management tickets for firewall modifications, Firewall rule review reports, Perimeter blocklist configuration		

Endpoint Detection and Response Deployment

Category: Endpoint Protection

Business Objective

Endpoint protection policies ensure that laptops, workstations, and servers are equipped with controls to detect, prevent, and respond to malicious activity at the device level. The Endpoint Detection and Response Deployment policy applies this principle specifically to endpoint detection and response deployment, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Endpoint Protection must comply with the requirements defined under Endpoint Detection and Response Deployment, and exceptions must be formally documented and approved by Director of Infrastructure Security.

Detailed Requirements

1. Removable media must be restricted by default and enabled only with business justification.
2. Endpoints must receive security signature and engine updates automatically.
3. Endpoint isolation capability must be available to the security team for incident response.
4. Unmanaged or unenrolled devices must be blocked from accessing corporate resources.
5. All corporate endpoints must have an approved endpoint detection and response agent installed.
6. Endpoint security agents must not be disabled or removed by end users.

Indicators of Non-Compliance

- Unmanaged personal devices accessing corporate systems
- Endpoints without an active detection and response agent
- End users able to disable endpoint security software
- Removable media used without business justification

Required Evidence

- Endpoint detection and response deployment report
- Device management enrollment records
- Removable media usage logs
- Endpoint agent tamper-protection configuration

Recommended Remediation

To remediate a violation of Endpoint Detection and Response Deployment, the accountable team should: (1) Deploy the approved EDR agent to all unmanaged endpoints and enable tamper protection. (2) Restrict removable media by policy and require documented exception approval. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

EP-002, EMPPRIV-002, VENDOR-001

AI Summary

This policy defines mandatory controls for endpoint detection and response deployment within the Endpoint Protection domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Infrastructure Security.

Example Compliant Scenario

A system owner within Infrastructure Security implements Endpoint Detection and Response Deployment in full: required controls are configured as specified, evidence such as endpoint detection and response deployment report is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant device management enrollment records without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that unmanaged personal devices accessing corporate systems. Further investigation reveals that endpoints without an active detection and response agent, and no compensating control was documented. The finding is logged against EP-001 with a High risk rating and routed to Director of Infrastructure Security for remediation per the defined timeline.

Metadata

Policy_ID:	EP-001	Title:	Endpoint Detection and Response Deployment
Category:	Endpoint Protection	Risk_Level:	High
Department:	Infrastructure Security	Owner:	Director of Infrastructure Security
Version:	1.6	Effective_Date:	October 11, 2025
Review_Cycle :	Annual	Priority:	High
Status:	Active	Related_Policies:	EP-002, EMPPRIV-002, VENDOR-001
Keywords:	endpoint detection and response, removable media, device management, tamper protection, malware, unmanaged device, agent deployment, endpoint protection, EDR		
Search_Tags:	Endpoint Protection, Security, EDR, Device Management, Policy, Malware Prevention		
Evidence_Types:	Endpoint detection and response deployment report, Device management enrollment records, Removable media usage logs, Endpoint agent tamper-protection configuration		

Removable Media Restrictions

Category: Endpoint Protection

Business Objective

Endpoint protection policies ensure that laptops, workstations, and servers are equipped with controls to detect, prevent, and respond to malicious activity at the device level. The Removable Media Restrictions policy applies this principle specifically to removable media restrictions, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Endpoint Protection must comply with the requirements defined under Removable Media Restrictions, and exceptions must be formally documented and approved by Director of Infrastructure Security.

Detailed Requirements

1. Endpoint isolation capability must be available to the security team for incident response.
2. Unmanaged or unenrolled devices must be blocked from accessing corporate resources.
3. All corporate endpoints must have an approved endpoint detection and response agent installed.
4. Endpoint security agents must not be disabled or removed by end users.
5. Removable media must be restricted by default and enabled only with business justification.

Indicators of Non-Compliance

- Removable media used without business justification
- Endpoints running outdated signature definitions
- Unmanaged personal devices accessing corporate systems
- Endpoints without an active detection and response agent

Required Evidence

- Endpoint detection and response deployment report
- Device management enrollment records
- Removable media usage logs
- Endpoint agent tamper-protection configuration

Recommended Remediation

To remediate a violation of Removable Media Restrictions, the accountable team should: (1) Restrict removable media by policy and require documented exception approval. (2) Configure automatic signature and engine updates for all endpoint agents. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

EP-001, PHYS-002, REMOTE-001

AI Summary

This policy defines mandatory controls for removable media restrictions within the Endpoint Protection domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Infrastructure Security.

Example Compliant Scenario

A system owner within Infrastructure Security implements Removable Media Restrictions in full: required controls are configured as specified, evidence such as endpoint detection and response deployment report is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant device management enrollment records without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that removable media used without business justification. Further investigation reveals that endpoints running outdated signature definitions, and no compensating control was documented. The finding is logged against EP-002 with a Medium risk rating and routed to Director of Infrastructure Security for remediation per the defined timeline.

Metadata

Policy_ID:	EP-002	Title:	Removable Media Restrictions
Category:	Endpoint Protection	Risk_Level:	Medium
Department:	Infrastructure Security	Owner:	Director of Infrastructure Security
Version:	1.6	Effective_Date:	March 9, 2025
Review_Cycle :	Semi-Annual	Priority:	Medium
Status:	Active	Related_Policies:	EP-001, PHYS-002, REMOTE-001
Keywords:	device management, tamper protection, malware, unmanaged device, agent deployment, endpoint protection, EDR, endpoint detection and response, removable media		
Search_Tags:	Device Management, Policy, Malware Prevention, Endpoint Protection, Security, EDR		
Evidence_Types:	Endpoint detection and response deployment report, Device management enrollment records, Removable media usage logs, Endpoint agent tamper-protection configuration		

Mobile Device Management Enrollment

Category: Device Management

Business Objective

Device management policies ensure that corporate and employee-owned devices accessing organizational resources meet a consistent security baseline before and during use. The Mobile Device Management Enrollment policy applies this principle specifically to mobile device management enrollment, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Device Management must comply with the requirements defined under Mobile Device Management Enrollment, and exceptions must be formally documented and approved by Director of IT Operations.

Detailed Requirements

1. Devices accessing corporate email or data must be enrolled in mobile device management.
2. Devices must meet a minimum operating system version to access corporate resources.
3. Lost or stolen devices must be remotely wiped within a defined time window.
4. Personal devices must maintain separation between corporate and personal data.
5. Device encryption must be enabled prior to enrollment approval.

Indicators of Non-Compliance

- Devices accessing corporate data without MDM enrollment
- Devices running unsupported or outdated operating system versions
- No remote wipe capability configured for lost devices
- Jailbroken or rooted devices permitted network access
- Corporate and personal data not separated on BYOD devices

Required Evidence

- MDM enrollment reports
- Device compliance policy configuration
- Remote wipe activity logs
- Conditional access policy exports

Recommended Remediation

To remediate a violation of Mobile Device Management Enrollment, the accountable team should: (1) Configure and test remote wipe procedures for lost or stolen devices. (2) Deploy containerization to separate corporate and personal data on BYOD devices. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

DEV-002, SDLC-003, CHG-001

AI Summary

This policy defines mandatory controls for mobile device management enrollment within the Device Management domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under IT Operations.

Example Compliant Scenario

A system owner within IT Operations implements Mobile Device Management Enrollment in full: required controls are configured as specified, evidence such as mdm enrollment reports is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant device compliance policy configuration without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that devices accessing corporate data without mdm enrollment. Further investigation reveals that devices running unsupported or outdated operating system versions, and no compensating control was documented. The finding is logged against DEV-001 with a Medium risk rating and routed to Director of IT Operations for remediation per the defined timeline.

Metadata

Policy_ID:	DEV-001	Title:	Mobile Device Management Enrollment
Category:	Device Management	Risk_Level:	Medium
Department:	IT Operations	Owner:	Director of IT Operations
Version:	1.8	Effective_Date:	January 3, 2025
Review_Cycle :	Annual	Priority:	Medium
Status:	Active	Related_Policies:	DEV-002, SDLC-003, CHG-001
Keywords:	containerization, enrollment, conditional access, device management, MDM, BYOD, remote wipe, device compliance, jailbroken device		
Search_Tags:	Endpoint, Device Management, MDM, BYOD, Security, IT Operations, Policy		
Evidence_Types:	MDM enrollment reports, Device compliance policy configuration, Remote wipe activity logs, Conditional access policy exports		

Bring Your Own Device Standards

Category: Device Management

Business Objective

Device management policies ensure that corporate and employee-owned devices accessing organizational resources meet a consistent security baseline before and during use. The Bring Your Own Device Standards policy applies this principle specifically to bring your own device standards, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Device Management must comply with the requirements defined under Bring Your Own Device Standards, and exceptions must be formally documented and approved by Director of IT Operations.

Detailed Requirements

1. Lost or stolen devices must be remotely wiped within a defined time window.
2. Personal devices must maintain separation between corporate and personal data.
3. Device encryption must be enabled prior to enrollment approval.
4. Jailbroken or rooted devices must be blocked from corporate resource access.
5. Devices accessing corporate email or data must be enrolled in mobile device management.
6. Devices must meet a minimum operating system version to access corporate resources.

Indicators of Non-Compliance

- Jailbroken or rooted devices permitted network access
- Corporate and personal data not separated on BYOD devices
- Devices accessing corporate data without MDM enrollment
- Devices running unsupported or outdated operating system versions
- No remote wipe capability configured for lost devices

Required Evidence

- MDM enrollment reports
- Device compliance policy configuration
- Remote wipe activity logs
- Conditional access policy exports

Recommended Remediation

To remediate a violation of Bring Your Own Device Standards, the accountable team should: (1) Deploy containerization to separate corporate and personal data on BYOD devices. (2) Require MDM enrollment as a precondition for corporate resource access. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

DEV-001, SEC-001, SEC-002

AI Summary

This policy defines mandatory controls for bring your own device standards within the Device Management domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under IT Operations.

Example Compliant Scenario

A system owner within IT Operations implements Bring Your Own Device Standards in full: required controls are configured as specified, evidence such as mdm enrollment reports is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant device compliance policy configuration without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that jailbroken or rooted devices permitted network access. Further investigation reveals that corporate and personal data not separated on byod devices, and no compensating control was documented. The finding is logged against DEV-002 with a Medium risk rating and routed to Director of IT Operations for remediation per the defined timeline.

Metadata

Policy_ID:	DEV-002	Title:	Bring Your Own Device Standards
Category:	Device Management	Risk_Level:	Medium
Department:	IT Operations	Owner:	Director of IT Operations
Version:	1.6	Effective_Date:	January 6, 2025
Review_Cycle :	Semi-Annual	Priority:	Medium
Status:	Active	Related_Policies:	DEV-001, SEC-001, SEC-002
Keywords:	conditional access, device management, MDM, BYOD, remote wipe, device compliance, jailbroken device, containerization, enrollment		
Search_Tags:	BYOD, Security, IT Operations, Policy, Endpoint, Device Management, MDM		
Evidence_Types:	MDM enrollment reports, Device compliance policy configuration, Remote wipe activity logs, Conditional access policy exports		

Centralized Security Log Collection

Category: Logging & Monitoring

Business Objective

Logging and monitoring policies ensure that sufficient telemetry is captured and reviewed to detect malicious activity, support investigations, and demonstrate accountability. The Centralized Security Log Collection policy applies this principle specifically to centralized security log collection, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Logging & Monitoring must comply with the requirements defined under Centralized Security Log Collection, and exceptions must be formally documented and approved by Head of Security Operations.

Detailed Requirements

1. Logs must include sufficient detail to reconstruct the sequence of an event.
2. Log integrity must be protected against tampering or deletion by end users.
3. Critical alerts must be triaged within a defined service level, such as one hour.
4. Logging coverage must be reviewed whenever new systems are deployed.
5. Logs must be retained for a period appropriate to their sensitivity and regulatory context.
6. Access to raw log data must be restricted to authorized security personnel.

Indicators of Non-Compliance

- Logs missing timestamps, source identifiers, or outcome fields
- End users with the ability to delete or modify log data
- Critical alerts sitting untriated beyond the defined service level
- Log retention shorter than the defined policy minimum
- Systems producing no logs or logs not forwarded centrally

Required Evidence

- Log retention configuration
- Access control list for the logging platform
- Centralized logging platform configuration
- Sample log exports demonstrating required fields
- Alert triage timestamps and SLA reports

Recommended Remediation

To remediate a violation of Centralized Security Log Collection, the accountable team should: (1) Onboard the affected system to the centralized logging platform and validate field completeness. (2) Restrict log deletion and modification permissions to a small administrative group. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

LOG-002, LOG-003, MAIL-001

AI Summary

This policy defines mandatory controls for centralized security log collection within the Logging & Monitoring domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Security Operations.

Example Compliant Scenario

A system owner within Security Operations implements Centralized Security Log Collection in full: required controls are configured as specified, evidence such as log retention configuration is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant access control list for the logging platform without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that logs missing timestamps, source identifiers, or outcome fields. Further investigation reveals that end users with the ability to delete or modify log data, and no compensating control was documented. The finding is logged against LOG-001 with a High risk rating and routed to Head of Security Operations for remediation per the defined timeline.

Metadata

Policy_ID:	LOG-001	Title:	Centralized Security Log Collection
Category:	Logging & Monitoring	Risk_Level:	High
Department:	Security Operations	Owner:	Head of Security Operations
Version:	2.6	Effective_Date:	October 24, 2025
Review_Cycle :	Quarterly	Priority:	High
Status:	Under Review	Related_Policies:	LOG-002, LOG-003, MAIL-001
Keywords:	alert triage, security operations, centralized logging, log integrity, telemetry, event log, logging, monitoring, SIEM, log retention		
Search_Tags:	Detection, Incident Response, Logging, Monitoring, Security Operations, SIEM, Policy		
Evidence_Types:	Log retention configuration, Access control list for the logging platform, Centralized logging platform configuration, Sample log exports demonstrating required fields, Alert triage timestamps and SLA reports		

Security Alert Triage and Response Times

Category: Logging & Monitoring

Business Objective

Logging and monitoring policies ensure that sufficient telemetry is captured and reviewed to detect malicious activity, support investigations, and demonstrate accountability. The Security Alert Triage and Response Times policy applies this principle specifically to security alert triage and response times, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Logging & Monitoring must comply with the requirements defined under Security Alert Triage and Response Times, and exceptions must be formally documented and approved by Head of Security Operations.

Detailed Requirements

1. Critical alerts must be triaged within a defined service level, such as one hour.
2. Logging coverage must be reviewed whenever new systems are deployed.
3. Logs must be retained for a period appropriate to their sensitivity and regulatory context.
4. Access to raw log data must be restricted to authorized security personnel.
5. Security-relevant logs must be forwarded to a centralized logging platform.

Indicators of Non-Compliance

- Log retention shorter than the defined policy minimum
- Systems producing no logs or logs not forwarded centrally
- Logs missing timestamps, source identifiers, or outcome fields
- End users with the ability to delete or modify log data

Required Evidence

- Alert triage timestamps and SLA reports
- Log retention configuration
- Access control list for the logging platform
- Centralized logging platform configuration
- Sample log exports demonstrating required fields

Recommended Remediation

To remediate a violation of Security Alert Triage and Response Times, the accountable team should: (1) Restrict log deletion and modification permissions to a small administrative group. (2) Adjust alert routing and staffing to meet the defined triage service level. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

LOG-001, LOG-003, DOC-002

AI Summary

This policy defines mandatory controls for security alert triage and response times within the Logging & Monitoring domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Security Operations.

Example Compliant Scenario

A system owner within Security Operations implements Security Alert Triage and Response Times in full: required controls are configured as specified, evidence such as alert triage timestamps and sla reports is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant log retention configuration without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that log retention shorter than the defined policy minimum. Further investigation reveals that systems producing no logs or logs not forwarded centrally, and no compensating control was documented. The finding is logged against LOG-002 with a High risk rating and routed to Head of Security Operations for remediation per the defined timeline.

Metadata

Policy_ID:	LOG-002	Title:	Security Alert Triage and Response Times
Category:	Logging & Monitoring	Risk_Level:	High
Department:	Security Operations	Owner:	Head of Security Operations
Version:	1.0	Effective_Date:	August 24, 2025
Review_Cycle :	Quarterly	Priority:	High
Status:	Active	Related_Policies:	LOG-001, LOG-003, DOC-002
Keywords:	centralized logging, log integrity, telemetry, event log, logging, monitoring, SIEM, log retention, alert triage, security operations		
Search_Tags:	Monitoring, Security Operations, SIEM, Policy, Detection, Incident Response, Logging		
Evidence_Types:	Alert triage timestamps and SLA reports, Log retention configuration, Access control list for the logging platform, Centralized logging platform configuration, Sample log exports demonstrating required fields		

Log Retention Standards

Category: Logging & Monitoring

Business Objective

Logging and monitoring policies ensure that sufficient telemetry is captured and reviewed to detect malicious activity, support investigations, and demonstrate accountability. The Log Retention Standards policy applies this principle specifically to log retention standards, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Logging & Monitoring must comply with the requirements defined under Log Retention Standards, and exceptions must be formally documented and approved by Head of Security Operations.

Detailed Requirements

1. Logs must be retained for a period appropriate to their sensitivity and regulatory context.
2. Access to raw log data must be restricted to authorized security personnel.
3. Security-relevant logs must be forwarded to a centralized logging platform.
4. Logs must include sufficient detail to reconstruct the sequence of an event.
5. Log integrity must be protected against tampering or deletion by end users.
6. Critical alerts must be triaged within a defined service level, such as one hour.
7. Logging coverage must be reviewed whenever new systems are deployed.

Indicators of Non-Compliance

- End users with the ability to delete or modify log data
- Critical alerts sitting untriaged beyond the defined service level
- Log retention shorter than the defined policy minimum
- Systems producing no logs or logs not forwarded centrally
- Logs missing timestamps, source identifiers, or outcome fields

Required Evidence

- Sample log exports demonstrating required fields
- Alert triage timestamps and SLA reports
- Log retention configuration
- Access control list for the logging platform
- Centralized logging platform configuration

Recommended Remediation

To remediate a violation of Log Retention Standards, the accountable team should: (1) Adjust alert routing and staffing to meet the defined triage service level. (2) Update retention configuration to meet the policy-defined minimum period. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

LOG-001, LOG-002, AUTHZ-002

AI Summary

This policy defines mandatory controls for log retention standards within the Logging & Monitoring domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Security Operations.

Example Compliant Scenario

A system owner within Security Operations implements Log Retention Standards in full: required controls are configured as specified, evidence such as sample log exports demonstrating required fields is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant alert triage timestamps and sla reports without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that end users with the ability to delete or modify log data. Further investigation reveals that critical alerts sitting untriaged beyond the defined service level, and no compensating control was documented. The finding is logged against LOG-003 with a Medium risk rating and routed to Head of Security Operations for remediation per the defined timeline.

Metadata

Policy_ID:	LOG-003	Title:	Log Retention Standards
Category:	Logging & Monitoring	Risk_Level:	Medium
Department:	Security Operations	Owner:	Head of Security Operations
Version:	1.9	Effective_Date:	June 17, 2025
Review_Cycle :	Quarterly	Priority:	Medium
Status:	Active	Related_Policies:	LOG-001, LOG-002, AUTHZ-002
Keywords:	telemetry, event log, logging, monitoring, SIEM, log retention, alert triage, security operations, centralized logging, log integrity		
Search_Tags:	Policy, Detection, Incident Response, Logging, Monitoring, Security Operations, SIEM		
Evidence_Types:	Sample log exports demonstrating required fields, Alert triage timestamps and SLA reports, Log retention configuration, Access control list for the logging platform, Centralized logging platform configuration		

Immutable Audit Logging for Sensitive Systems

Category: Audit Trail

Business Objective

Audit trail policies ensure that actions taken within systems, particularly those involving sensitive data or privileged functions, are recorded in a manner that supports accountability and forensic review. The Immutable Audit Logging for Sensitive Systems policy applies this principle specifically to immutable audit logging for sensitive systems, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Audit Trail must comply with the requirements defined under Immutable Audit Logging for Sensitive Systems, and exceptions must be formally documented and approved by Head of Security Operations.

Detailed Requirements

1. Audit log access must itself be logged and periodically reviewed.
2. Gaps in audit coverage must be documented and risk-assessed.
3. All administrative actions on sensitive systems must generate an audit record.
4. Audit logs must be written to a destination the acting user cannot modify.
5. Audit records must capture the actor, action, target, and timestamp.

Indicators of Non-Compliance

- Administrative actions with no corresponding audit record
- Audit logs stored in a location the same user can modify
- Audit records missing actor or target identification
- No review process for who accesses audit logs
- Undocumented gaps in audit coverage

Required Evidence

- Audit log configuration and sample records
- Immutable storage configuration for audit destinations
- Audit log access review records
- Audit coverage assessment documentation

Recommended Remediation

To remediate a violation of Immutable Audit Logging for Sensitive Systems, the accountable team should: (1) Document and risk-assess any remaining audit coverage gaps. (2) Configure audit logging to write to an immutable, separately controlled destination. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

AUD-002, PWD-001, PWD-002

AI Summary

This policy defines mandatory controls for immutable audit logging for sensitive systems within the Audit Trail domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Security Operations.

Example Compliant Scenario

A system owner within Security Operations implements Immutable Audit Logging for Sensitive Systems in full: required controls are configured as specified, evidence such as audit log configuration and sample records is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant immutable storage configuration for audit destinations without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that administrative actions with no corresponding audit record. Further investigation reveals that audit logs stored in a location the same user can modify, and no compensating control was documented. The finding is logged against AUD-001 with a High risk rating and routed to Head of Security Operations for remediation per the defined timeline.

Metadata

Policy_ID:	AUD-001	Title:	Immutable Audit Logging for Sensitive Systems
Category:	Audit Trail	Risk_Level:	High
Department:	Security Operations	Owner:	Head of Security Operations
Version:	1.1	Effective_Date:	August 3, 2025
Review_Cycle :	Quarterly	Priority:	High
Status:	Active	Related_Policies:	AUD-002, PWD-001, PWD-002
Keywords:	audit coverage, actor identification, audit trail, audit log, immutable logging, administrative action, accountability, forensic review		
Search_Tags:	Policy, Logging, Governance, Audit Trail, Security Operations, Accountability		
Evidence_Types:	Audit log configuration and sample records, Immutable storage configuration for audit destinations, Audit log access review records, Audit coverage assessment documentation		

Administrative Action Audit Requirements

Category: Audit Trail

Business Objective

Audit trail policies ensure that actions taken within systems, particularly those involving sensitive data or privileged functions, are recorded in a manner that supports accountability and forensic review. The Administrative Action Audit Requirements policy applies this principle specifically to administrative action audit requirements, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Audit Trail must comply with the requirements defined under Administrative Action Audit Requirements, and exceptions must be formally documented and approved by Head of Security Operations.

Detailed Requirements

1. All administrative actions on sensitive systems must generate an audit record.
2. Audit logs must be written to a destination the acting user cannot modify.
3. Audit records must capture the actor, action, target, and timestamp.
4. Audit trails must be retained separately from application data.
5. Audit log access must itself be logged and periodically reviewed.
6. Gaps in audit coverage must be documented and risk-assessed.

Indicators of Non-Compliance

- No review process for who accesses audit logs
- Undocumented gaps in audit coverage
- Administrative actions with no corresponding audit record
- Audit logs stored in a location the same user can modify

Required Evidence

- Audit log configuration and sample records
- Immutable storage configuration for audit destinations
- Audit log access review records
- Audit coverage assessment documentation

Recommended Remediation

To remediate a violation of Administrative Action Audit Requirements, the accountable team should: (1) Configure audit logging to write to an immutable, separately controlled destination. (2) Add missing fields such as actor and target identification to audit records. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

AUD-001, AC-002, AC-003

AI Summary

This policy defines mandatory controls for administrative action audit requirements within the Audit Trail domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Security Operations.

Example Compliant Scenario

A system owner within Security Operations implements Administrative Action Audit Requirements in full: required controls are configured as specified, evidence such as audit log configuration and sample records is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant immutable storage configuration for audit destinations without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that no review process for who accesses audit logs. Further investigation reveals that undocumented gaps in audit coverage, and no compensating control was documented. The finding is logged against AUD-002 with a High risk rating and routed to Head of Security Operations for remediation per the defined timeline.

Metadata

Policy_ID:	AUD-002	Title:	Administrative Action Audit Requirements
Category:	Audit Trail	Risk_Level:	High
Department:	Security Operations	Owner:	Head of Security Operations
Version:	3.9	Effective_Date:	January 20, 2025
Review_Cycle :	Annual	Priority:	High
Status:	Under Review	Related_Policies:	AUD-001, AC-002, AC-003
Keywords:	audit trail, audit log, immutable logging, administrative action, accountability, forensic review, audit coverage, actor identification		
Search_Tags:	Audit Trail, Security Operations, Accountability, Policy, Logging, Governance		
Evidence_Types:	Audit log configuration and sample records, Immutable storage configuration for audit destinations, Audit log access review records, Audit coverage assessment documentation		

Security Incident Classification and Escalation

Category: Incident Response

Business Objective

Incident response policies define how the organization detects, contains, eradicates, and recovers from security incidents, minimizing damage and restoring normal operations quickly. The Security Incident Classification and Escalation policy applies this principle specifically to security incident classification and escalation, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Incident Response must comply with the requirements defined under Security Incident Classification and Escalation, and exceptions must be formally documented and approved by Head of Security Operations.

Detailed Requirements

1. A post-incident review must be completed within a defined period after resolution.
2. Lessons learned from incidents must be tracked to closure as action items.
3. Communication during incidents must follow a predefined internal and external protocol.
4. Incidents must be classified according to a documented severity matrix.
5. Critical incidents must trigger notification to designated leadership within a defined window.
6. An incident response plan must be tested at least annually via tabletop exercise.
7. Containment actions must be documented in real time during an active incident.

Indicators of Non-Compliance

- Leadership notification delayed beyond the defined window
- No tabletop exercise conducted within the past year
- Missing or incomplete incident timeline documentation
- Post-incident reviews not conducted or lacking tracked action items
- Incidents left unclassified or inconsistently severity-rated

Required Evidence

- Post-incident review reports and action item trackers
- Incident communication logs
- Incident response plan documentation
- Incident tickets and classification records
- Tabletop exercise reports

Recommended Remediation

To remediate a violation of Security Incident Classification and Escalation, the accountable team should: (1) Configure automated notification workflows for critical incident escalation. (2) Schedule and conduct the overdue tabletop exercise with cross-functional participants. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

INC-002, INC-003, API-001

AI Summary

This policy defines mandatory controls for security incident classification and escalation within the Incident Response domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Critical risk and applies to all in-scope systems and personnel under Security Operations.

Example Compliant Scenario

A system owner within Security Operations implements Security Incident Classification and Escalation in full: required controls are configured as specified, evidence such as post-incident review reports and action item trackers is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant incident communication logs without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that leadership notification delayed beyond the defined window. Further investigation reveals that no tabletop exercise conducted within the past year, and no compensating control was documented. The finding is logged against INC-001 with a Critical risk rating and routed to Head of Security Operations for remediation per the defined timeline.

Metadata

Policy_ID:	INC-001	Title:	Security Incident Classification and Escalation
Category:	Incident Response	Risk_Level:	Critical
Department:	Security Operations	Owner:	Head of Security Operations
Version:	2.3	Effective_Date:	October 23, 2025
Review_Cycle :	Semi-Annual	Priority:	Critical
Status:	Active	Related_Policies:	INC-002, INC-003, API-001
Keywords:	escalation, tabletop exercise, containment, post-incident review, lessons learned, security incident, notification, incident response, severity classification		
Search_Tags:	Crisis Management, Governance, Security, Incident Response, Security Operations, Policy		
Evidence_Types:	Post-incident review reports and action item trackers, Incident communication logs, Incident response plan documentation, Incident tickets and classification records, Tabletop exercise reports		

Incident Response Plan Testing

Category: Incident Response

Business Objective

Incident response policies define how the organization detects, contains, eradicates, and recovers from security incidents, minimizing damage and restoring normal operations quickly. The Incident Response Plan Testing policy applies this principle specifically to incident response plan testing, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Incident Response must comply with the requirements defined under Incident Response Plan Testing, and exceptions must be formally documented and approved by Head of Security Operations.

Detailed Requirements

1. Communication during incidents must follow a predefined internal and external protocol.
2. Incidents must be classified according to a documented severity matrix.
3. Critical incidents must trigger notification to designated leadership within a defined window.
4. An incident response plan must be tested at least annually via tabletop exercise.
5. Containment actions must be documented in real time during an active incident.
6. A post-incident review must be completed within a defined period after resolution.

Indicators of Non-Compliance

- Post-incident reviews not conducted or lacking tracked action items
- Incidents left unclassified or inconsistently severity-rated
- Leadership notification delayed beyond the defined window
- No tabletop exercise conducted within the past year
- Missing or incomplete incident timeline documentation

Required Evidence

- Tabletop exercise reports
- Post-incident review reports and action item trackers
- Incident communication logs
- Incident response plan documentation
- Incident tickets and classification records

Recommended Remediation

To remediate a violation of Incident Response Plan Testing, the accountable team should: (1) Schedule and conduct the overdue tabletop exercise with cross-functional participants. (2) Implement a standard post-incident review template with tracked action items. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

INC-001, INC-003, NET-001

AI Summary

This policy defines mandatory controls for incident response plan testing within the Incident Response domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Security Operations.

Example Compliant Scenario

A system owner within Security Operations implements Incident Response Plan Testing in full: required controls are configured as specified, evidence such as tabletop exercise reports is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant post-incident review reports and action item trackers without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that post-incident reviews not conducted or lacking tracked action items. Further investigation reveals that incidents left unclassified or inconsistently severity-rated, and no compensating control was documented. The finding is logged against INC-002 with a High risk rating and routed to Head of Security Operations for remediation per the defined timeline.

Metadata

Policy_ID:	INC-002	Title:	Incident Response Plan Testing
Category:	Incident Response	Risk_Level:	High
Department:	Security Operations	Owner:	Head of Security Operations
Version:	3.4	Effective_Date:	June 11, 2025
Review_Cycle:	Annual	Priority:	High
Status:	Active	Related_Policies:	INC-001, INC-003, NET-001
Keywords:	containment, post-incident review, lessons learned, security incident, notification, incident response, severity classification, escalation, tabletop exercise		
Search_Tags:	Incident Response, Security Operations, Policy, Crisis Management, Governance, Security		
Evidence_Types:	Tabletop exercise reports, Post-incident review reports and action item trackers, Incident communication logs, Incident response plan documentation, Incident tickets and classification records		

Post-Incident Review Requirements

Category: Incident Response

Business Objective

Incident response policies define how the organization detects, contains, eradicates, and recovers from security incidents, minimizing damage and restoring normal operations quickly. The Post-Incident Review Requirements policy applies this principle specifically to post-incident review requirements, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Incident Response must comply with the requirements defined under Post-Incident Review Requirements, and exceptions must be formally documented and approved by Head of Security Operations.

Detailed Requirements

1. Critical incidents must trigger notification to designated leadership within a defined window.
2. An incident response plan must be tested at least annually via tabletop exercise.
3. Containment actions must be documented in real time during an active incident.
4. A post-incident review must be completed within a defined period after resolution.
5. Lessons learned from incidents must be tracked to closure as action items.
6. Communication during incidents must follow a predefined internal and external protocol.

Indicators of Non-Compliance

- No tabletop exercise conducted within the past year
- Missing or incomplete incident timeline documentation
- Post-incident reviews not conducted or lacking tracked action items
- Incidents left unclassified or inconsistently severity-rated
- Leadership notification delayed beyond the defined window

Required Evidence

- Incident tickets and classification records
- Tabletop exercise reports
- Post-incident review reports and action item trackers
- Incident communication logs
- Incident response plan documentation

Recommended Remediation

To remediate a violation of Post-Incident Review Requirements, the accountable team should: (1) Implement a standard post-incident review template with tracked action items. (2) Apply the documented severity matrix consistently and retrain responders as needed. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

INC-001, INC-002, EP-002

AI Summary

This policy defines mandatory controls for post-incident review requirements within the Incident Response domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Security Operations.

Example Compliant Scenario

A system owner within Security Operations implements Post-Incident Review Requirements in full: required controls are configured as specified, evidence such as incident tickets and classification records is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant tabletop exercise reports without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that no tabletop exercise conducted within the past year. Further investigation reveals that missing or incomplete incident timeline documentation, and no compensating control was documented. The finding is logged against INC-003 with a Medium risk rating and routed to Head of Security Operations for remediation per the defined timeline.

Metadata

Policy_ID:	INC-003	Title:	Post-Incident Review Requirements
Category:	Incident Response	Risk_Level:	Medium
Department:	Security Operations	Owner:	Head of Security Operations
Version:	1.8	Effective_Date:	March 17, 2025
Review_Cycle:	Semi-Annual	Priority:	Medium
Status:	Active	Related_Policies:	INC-001, INC-002, EP-002
Keywords:	lessons learned, security incident, notification, incident response, severity classification, escalation, tabletop exercise, containment, post-incident review		
Search_Tags:	Crisis Management, Governance, Security, Incident Response, Security Operations, Policy		
Evidence_Types:	Incident tickets and classification records, Tabletop exercise reports, Post-incident review reports and action item trackers, Incident communication logs, Incident response plan documentation		

Vulnerability Scanning Cadence

Category: Vulnerability Management

Business Objective

Vulnerability management policies establish how weaknesses in systems and software are identified, prioritized, and remediated before they can be exploited by an adversary. The Vulnerability Scanning Cadence policy applies this principle specifically to vulnerability scanning cadence, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Vulnerability Management must comply with the requirements defined under Vulnerability Scanning Cadence, and exceptions must be formally documented and approved by Head of Security Operations.

Detailed Requirements

1. Critical-severity vulnerabilities must be remediated within a defined short window.
2. Vulnerability scan results must be triaged by qualified personnel, not auto-closed.
3. Compensating controls must be documented when remediation cannot occur immediately.
4. Vulnerability management metrics must be reported to leadership on a recurring basis.
5. Internet-facing systems must be scanned for vulnerabilities at least weekly.
6. Internal systems must be scanned for vulnerabilities at least monthly.

Indicators of Non-Compliance

- Internet-facing systems not scanned within the defined cadence
- Critical vulnerabilities open past the remediation deadline
- Scan findings auto-closed without human triage
- No compensating controls documented for delayed remediation

Required Evidence

- Vulnerability scan reports and schedules
- Remediation tracking tickets
- Risk acceptance and compensating control documentation
- Vulnerability management metrics dashboards

Recommended Remediation

To remediate a violation of Vulnerability Scanning Cadence, the accountable team should: (1) Restore the scanning schedule to the defined cadence and validate coverage. (2) Escalate overdue critical vulnerabilities and assign accountable remediation owners. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

VULN-002, LOG-001, LOG-002

AI Summary

This policy defines mandatory controls for vulnerability scanning cadence within the Vulnerability Management domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Security Operations.

Example Compliant Scenario

A system owner within Security Operations implements Vulnerability Scanning Cadence in full: required controls are configured as specified, evidence such as vulnerability scan reports and schedules is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant remediation tracking tickets without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that internet-facing systems not scanned within the defined cadence. Further investigation reveals that critical vulnerabilities open past the remediation deadline, and no compensating control was documented. The finding is logged against VULN-001 with a High risk rating and routed to Head of Security Operations for remediation per the defined timeline.

Metadata

Policy_ID:	VULN-001	Title:	Vulnerability Scanning Cadence
Category:	Vulnerability Management	Risk_Level:	High
Department:	Security Operations	Owner:	Head of Security Operations
Version:	2.4	Effective_Date:	March 15, 2025
Review_Cycle :	Quarterly	Priority:	High
Status:	Active	Related_Policies:	VULN-002, LOG-001, LOG-002
Keywords:	vulnerability management, vulnerability scanning, remediation timeline, patch, risk acceptance, compensating control, critical vulnerability, scan cadence		
Search_Tags:	Vulnerability Management, Security Operations, Policy, Risk Management, Security, Remediation		
Evidence_Types:	Vulnerability scan reports and schedules, Remediation tracking tickets, Risk acceptance and compensating control documentation, Vulnerability management metrics dashboards		

Critical Vulnerability Remediation Timelines

Category: Vulnerability Management

Business Objective

Vulnerability management policies establish how weaknesses in systems and software are identified, prioritized, and remediated before they can be exploited by an adversary. The Critical Vulnerability Remediation Timelines policy applies this principle specifically to critical vulnerability remediation timelines, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Vulnerability Management must comply with the requirements defined under Critical Vulnerability Remediation Timelines, and exceptions must be formally documented and approved by Head of Security Operations.

Detailed Requirements

1. Compensating controls must be documented when remediation cannot occur immediately.
2. Vulnerability management metrics must be reported to leadership on a recurring basis.
3. Internet-facing systems must be scanned for vulnerabilities at least weekly.
4. Internal systems must be scanned for vulnerabilities at least monthly.
5. Critical-severity vulnerabilities must be remediated within a defined short window.
6. Vulnerability scan results must be triaged by qualified personnel, not auto-closed.

Indicators of Non-Compliance

- No compensating controls documented for delayed remediation
- No recurring reporting of vulnerability metrics to leadership
- Internet-facing systems not scanned within the defined cadence
- Critical vulnerabilities open past the remediation deadline
- Scan findings auto-closed without human triage

Required Evidence

- Vulnerability scan reports and schedules
- Remediation tracking tickets
- Risk acceptance and compensating control documentation
- Vulnerability management metrics dashboards

Recommended Remediation

To remediate a violation of Critical Vulnerability Remediation Timelines, the accountable team should: (1) Escalate overdue critical vulnerabilities and assign accountable remediation owners. (2) Introduce mandatory human triage for all scan findings prior to closure. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

VULN-001, INC-001, INC-002

AI Summary

This policy defines mandatory controls for critical vulnerability remediation timelines within the Vulnerability Management domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Critical risk and applies to all in-scope systems and personnel under Security Operations.

Example Compliant Scenario

A system owner within Security Operations implements Critical Vulnerability Remediation Timelines in full: required controls are configured as specified, evidence such as vulnerability scan reports and schedules is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant remediation tracking tickets without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that no compensating controls documented for delayed remediation. Further investigation reveals that no recurring reporting of vulnerability metrics to leadership, and no compensating control was documented. The finding is logged against VULN-002 with a Critical risk rating and routed to Head of Security Operations for remediation per the defined timeline.

Metadata

Policy_ID:	VULN-002	Title:	Critical Vulnerability Remediation Timelines
Category:	Vulnerability Management	Risk_Level:	Critical
Department:	Security Operations	Owner:	Head of Security Operations
Version:	3.8	Effective_Date:	April 22, 2025
Review_Cycle :	Annual	Priority:	Critical
Status:	Active	Related_Policies:	VULN-001, INC-001, INC-002
Keywords:	remediation timeline, patch, risk acceptance, compensating control, critical vulnerability, scan cadence, vulnerability management, vulnerability scanning		
Search_Tags:	Risk Management, Security, Remediation, Vulnerability Management, Security Operations, Policy		
Evidence_Types:	Vulnerability scan reports and schedules, Remediation tracking tickets, Risk acceptance and compensating control documentation, Vulnerability management metrics dashboards		

Operating System Patch Deployment

Category: Patch Management

Business Objective

Patch management policies ensure that known software vulnerabilities are addressed through timely application of vendor-released updates, reducing the window of exploitability. The Operating System Patch Deployment policy applies this principle specifically to operating system patch deployment, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Patch Management must comply with the requirements defined under Operating System Patch Deployment, and exceptions must be formally documented and approved by Director of IT Operations.

Detailed Requirements

1. Critical operating system patches must be deployed within a defined short window of release.
2. Patches must be tested in a non-production environment prior to broad deployment.
3. Systems that cannot be patched must have documented compensating controls.
4. Patch deployment status must be tracked centrally across the device fleet.
5. End-of-life software must be identified and scheduled for replacement or upgrade.
6. Emergency patching procedures must exist for actively exploited vulnerabilities.

Indicators of Non-Compliance

- Patches deployed directly to production without testing
- Unpatchable systems with no documented compensating controls
- No centralized visibility into patch deployment status
- End-of-life software still running without a replacement plan

Required Evidence

- Patch management platform reports
- Patch testing records
- Compensating control documentation for unpatched systems
- Software end-of-life inventory

Recommended Remediation

To remediate a violation of Operating System Patch Deployment, the accountable team should: (1) Document compensating controls for systems that cannot be patched on schedule. (2) Build a replacement roadmap for identified end-of-life software. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

PATCH-002, BACKUP-001, BACKUP-002

AI Summary

This policy defines mandatory controls for operating system patch deployment within the Patch Management domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under IT Operations.

Example Compliant Scenario

A system owner within IT Operations implements Operating System Patch Deployment in full: required controls are configured as specified, evidence such as patch management platform reports is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant patch testing records without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that patches deployed directly to production without testing. Further investigation reveals that unpatchable systems with no documented compensating controls, and no compensating control was documented. The finding is logged against PATCH-001 with a High risk rating and routed to Director of IT Operations for remediation per the defined timeline.

Metadata

Policy_ID:	PATCH-001	Title:	Operating System Patch Deployment
Category:	Patch Management	Risk_Level:	High
Department:	IT Operations	Owner:	Director of IT Operations
Version:	3.8	Effective_Date:	March 9, 2025
Review_Cycle :	Semi-Annual	Priority:	High
Status:	Active	Related_Policies:	PATCH-002, BACKUP-001, BACKUP-002
Keywords:	emergency patch, patch testing, patch deployment, vulnerability remediation, patch management, patching, operating system update, end of life software		
Search_Tags:	Patch Management, IT Operations, Security, Policy, Vulnerability Management, Software Maintenance		
Evidence_Types:	Patch management platform reports, Patch testing records, Compensating control documentation for unpatched systems, Software end-of-life inventory		

Third-Party Software Patch Tracking

Category: Patch Management

Business Objective

Patch management policies ensure that known software vulnerabilities are addressed through timely application of vendor-released updates, reducing the window of exploitability. The Third-Party Software Patch Tracking policy applies this principle specifically to third-party software patch tracking, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Patch Management must comply with the requirements defined under Third-Party Software Patch Tracking, and exceptions must be formally documented and approved by Director of IT Operations.

Detailed Requirements

1. Systems that cannot be patched must have documented compensating controls.
2. Patch deployment status must be tracked centrally across the device fleet.
3. End-of-life software must be identified and scheduled for replacement or upgrade.
4. Emergency patching procedures must exist for actively exploited vulnerabilities.
5. Critical operating system patches must be deployed within a defined short window of release.
6. Patches must be tested in a non-production environment prior to broad deployment.

Indicators of Non-Compliance

- End-of-life software still running without a replacement plan
- Critical patches not applied within the defined window
- Patches deployed directly to production without testing
- Unpatchable systems with no documented compensating controls
- No centralized visibility into patch deployment status

Required Evidence

- Patch management platform reports
- Patch testing records
- Compensating control documentation for unpatched systems
- Software end-of-life inventory

Recommended Remediation

To remediate a violation of Third-Party Software Patch Tracking, the accountable team should: (1) Build a replacement roadmap for identified end-of-life software. (2) Accelerate patch deployment to meet the defined service level for critical updates. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

PATCH-001, DC-001, DC-002

AI Summary

This policy defines mandatory controls for third-party software patch tracking within the Patch Management domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under IT Operations.

Example Compliant Scenario

A system owner within IT Operations implements Third-Party Software Patch Tracking in full: required controls are configured as specified, evidence such as patch management platform reports is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant patch testing records without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that end-of-life software still running without a replacement plan. Further investigation reveals that critical patches not applied within the defined window, and no compensating control was documented. The finding is logged against PATCH-002 with a Medium risk rating and routed to Director of IT Operations for remediation per the defined timeline.

Metadata

Policy_ID:	PATCH-002	Title:	Third-Party Software Patch Tracking
Category:	Patch Management	Risk_Level:	Medium
Department:	IT Operations	Owner:	Director of IT Operations
Version:	3.4	Effective_Date:	August 16, 2025
Review_Cycle :	Semi-Annual	Priority:	Medium
Status:	Active	Related_Policies:	PATCH-001, DC-001, DC-002
Keywords:	patch deployment, vulnerability remediation, patch management, patching, operating system update, end of life software, emergency patch, patch testing		
Search_Tags:	Policy, Vulnerability Management, Software Maintenance, Patch Management, IT Operations, Security		
Evidence_Types:	Patch management platform reports, Patch testing records, Compensating control documentation for unpatched systems, Software end-of-life inventory		

Backup Frequency and Retention

Category: Backup & Disaster Recovery

Business Objective

Backup and disaster recovery policies ensure that critical data and systems can be restored following data loss, corruption, or a disruptive event, limiting downtime and data loss. The Backup Frequency and Retention policy applies this principle specifically to backup frequency and retention, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Backup & Disaster Recovery must comply with the requirements defined under Backup Frequency and Retention, and exceptions must be formally documented and approved by Director of IT Operations.

Detailed Requirements

1. At least one backup copy must be stored in a geographically separate location.
2. Recovery time and recovery point objectives must be documented for each critical system.
3. Backup access must be restricted to authorized operations personnel.
4. Critical system backups must run at least daily.
5. Backups must be retained according to the data retention schedule for the underlying data.

Indicators of Non-Compliance

- Backups stored unencrypted
- All backup copies stored in a single location
- No documented recovery time or recovery point objectives
- Backups running less frequently than the defined schedule
- No successful restoration test within the past quarter

Required Evidence

- Restoration test reports
- Backup encryption configuration
- Offsite storage location documentation
- Recovery objective documentation per system
- Backup job configuration and run history

Recommended Remediation

To remediate a violation of Backup Frequency and Retention, the accountable team should: (1) Restore backup frequency to the defined schedule and confirm successful completion. (2) Schedule and execute a restoration test, documenting results and any gaps found. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

BACKUP-002, BACKUP-003, EMPPRIV-001

AI Summary

This policy defines mandatory controls for backup frequency and retention within the Backup & Disaster Recovery domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under IT Operations.

Example Compliant Scenario

A system owner within IT Operations implements Backup Frequency and Retention in full: required controls are configured as specified, evidence such as restoration test reports is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant backup encryption configuration without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that backups stored unencrypted. Further investigation reveals that all backup copies stored in a single location, and no compensating control was documented. The finding is logged against BACKUP-001 with a High risk rating and routed to Director of IT Operations for remediation per the defined timeline.

Metadata

Policy_ID:	BACKUP-001	Title:	Backup Frequency and Retention
Category:	Backup & Disaster Recovery	Risk_Level:	High
Department:	IT Operations	Owner:	Director of IT Operations
Version:	2.0	Effective_Date:	January 11, 2025
Review_Cycle :	Annual	Priority:	High
Status:	Active	Related_Policies:	BACKUP-002, BACKUP-003, EMPPRIV-001
Keywords:	backup, disaster recovery, restoration testing, recovery time objective, recovery point objective, offsite storage, backup encryption, business continuity		
Search_Tags:	Backup, Disaster Recovery, Business Continuity, IT Operations, Policy, Data Protection		
Evidence_Types:	Restoration test reports, Backup encryption configuration, Offsite storage location documentation, Recovery objective documentation per system, Backup job configuration and run history		

Disaster Recovery Testing

Category: Backup & Disaster Recovery

Business Objective

Backup and disaster recovery policies ensure that critical data and systems can be restored following data loss, corruption, or a disruptive event, limiting downtime and data loss. The Disaster Recovery Testing policy applies this principle specifically to disaster recovery testing, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Backup & Disaster Recovery must comply with the requirements defined under Disaster Recovery Testing, and exceptions must be formally documented and approved by Director of IT Operations.

Detailed Requirements

1. Backup access must be restricted to authorized operations personnel.
2. Critical system backups must run at least daily.
3. Backups must be retained according to the data retention schedule for the underlying data.
4. Backup restoration must be tested at least quarterly.
5. Backups must be encrypted both in transit and at rest.

Indicators of Non-Compliance

- Backups running less frequently than the defined schedule
- No successful restoration test within the past quarter
- Backups stored unencrypted
- All backup copies stored in a single location
- No documented recovery time or recovery point objectives

Required Evidence

- Backup job configuration and run history
- Restoration test reports
- Backup encryption configuration
- Offsite storage location documentation
- Recovery objective documentation per system

Recommended Remediation

To remediate a violation of Disaster Recovery Testing, the accountable team should: (1) Schedule and execute a restoration test, documenting results and any gaps found. (2) Enable encryption for backup data both in transit and at rest. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

BACKUP-001, BACKUP-003, PHYS-001

AI Summary

This policy defines mandatory controls for disaster recovery testing within the Backup & Disaster Recovery domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under IT Operations.

Example Compliant Scenario

A system owner within IT Operations implements Disaster Recovery Testing in full: required controls are configured as specified, evidence such as backup job configuration and run history is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant restoration test reports without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that backups running less frequently than the defined schedule. Further investigation reveals that no successful restoration test within the past quarter, and no compensating control was documented. The finding is logged against BACKUP-002 with a High risk rating and routed to Director of IT Operations for remediation per the defined timeline.

Metadata

Policy_ID:	BACKUP-002	Title:	Disaster Recovery Testing
Category:	Backup & Disaster Recovery	Risk_Level:	High
Department:	IT Operations	Owner:	Director of IT Operations
Version:	3.6	Effective_Date:	August 1, 2025
Review_Cycle :	Annual	Priority:	High
Status:	Active	Related_Policies:	BACKUP-001, BACKUP-003, PHYS-001
Keywords:	restoration testing, recovery time objective, recovery point objective, offsite storage, backup encryption, business continuity, backup, disaster recovery		
Search_Tags:	IT Operations, Policy, Data Protection, Backup, Disaster Recovery, Business Continuity		
Evidence_Types:	Backup job configuration and run history, Restoration test reports, Backup encryption configuration, Offsite storage location documentation, Recovery objective documentation per system		

Backup Encryption and Offsite Storage

Category: Backup & Disaster Recovery

Business Objective

Backup and disaster recovery policies ensure that critical data and systems can be restored following data loss, corruption, or a disruptive event, limiting downtime and data loss. The Backup Encryption and Offsite Storage policy applies this principle specifically to backup encryption and offsite storage, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Backup & Disaster Recovery must comply with the requirements defined under Backup Encryption and Offsite Storage, and exceptions must be formally documented and approved by Director of IT Operations.

Detailed Requirements

1. Backups must be retained according to the data retention schedule for the underlying data.
2. Backup restoration must be tested at least quarterly.
3. Backups must be encrypted both in transit and at rest.
4. At least one backup copy must be stored in a geographically separate location.
5. Recovery time and recovery point objectives must be documented for each critical system.
6. Backup access must be restricted to authorized operations personnel.
7. Critical system backups must run at least daily.

Indicators of Non-Compliance

- All backup copies stored in a single location
- No documented recovery time or recovery point objectives
- Backups running less frequently than the defined schedule
- No successful restoration test within the past quarter

Required Evidence

- Recovery objective documentation per system
- Backup job configuration and run history
- Restoration test reports
- Backup encryption configuration
- Offsite storage location documentation

Recommended Remediation

To remediate a violation of Backup Encryption and Offsite Storage, the accountable team should: (1) Enable encryption for backup data both in transit and at rest. (2) Establish a geographically separate offsite backup location. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

BACKUP-001, BACKUP-002, SDLC-002

AI Summary

This policy defines mandatory controls for backup encryption and offsite storage within the Backup & Disaster Recovery domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under IT Operations.

Example Compliant Scenario

A system owner within IT Operations implements Backup Encryption and Offsite Storage in full: required controls are configured as specified, evidence such as recovery objective documentation per system is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant backup job configuration and run history without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that all backup copies stored in a single location. Further investigation reveals that no documented recovery time or recovery point objectives, and no compensating control was documented. The finding is logged against BACKUP-003 with a Medium risk rating and routed to Director of IT Operations for remediation per the defined timeline.

Metadata

Policy_ID:	BACKUP-003	Title:	Backup Encryption and Offsite Storage
Category:	Backup & Disaster Recovery	Risk_Level:	Medium
Department:	IT Operations	Owner:	Director of IT Operations
Version:	2.9	Effective_Date:	August 5, 2025
Review_Cycle :	Semi-Annual	Priority:	Medium
Status:	Active	Related_Policies:	BACKUP-001, BACKUP-002, SDLC-002
Keywords:	recovery point objective, offsite storage, backup encryption, business continuity, backup, disaster recovery, restoration testing, recovery time objective		
Search_Tags:	Backup, Disaster Recovery, Business Continuity, IT Operations, Policy, Data Protection		
Evidence_Types:	Recovery objective documentation per system, Backup job configuration and run history, Restoration test reports, Backup encryption configuration, Offsite storage location documentation		

Database Access Restriction and Monitoring

Category: Database Security

Business Objective

Database security policies protect the confidentiality, integrity, and availability of structured data stores that often contain the organization's most sensitive information. The Database Access Restriction and Monitoring policy applies this principle specifically to database access restriction and monitoring, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Database Security must comply with the requirements defined under Database Access Restriction and Monitoring, and exceptions must be formally documented and approved by Chief Information Security Officer.

Detailed Requirements

1. Sensitive columns must be encrypted or tokenized at the field level where feasible.
2. Database configuration must be benchmarked against an internal hardening standard.
3. Direct database access must be limited to database administrators and approved service accounts.
4. Database queries against sensitive tables must be logged.
5. Default database accounts must be disabled or have their credentials rotated.

Indicators of Non-Compliance

- No query logging on tables containing sensitive data
- Default database accounts still enabled with default credentials
- Database servers exposed directly to the internet
- Sensitive fields stored without encryption or tokenization
- Broad direct database access granted to application developers

Required Evidence

- Database access control lists
- Query audit logs
- Database hardening benchmark results
- Network exposure scan results for database servers

Recommended Remediation

To remediate a violation of Database Access Restriction and Monitoring, the accountable team should: (1) Remove public network exposure for database servers and route access through an application layer. (2) Restrict direct database access to a minimal set of administrators and service accounts. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

DB-002, CHG-001, CHG-002

AI Summary

This policy defines mandatory controls for database access restriction and monitoring within the Database Security domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Information Security.

Example Compliant Scenario

A system owner within Information Security implements Database Access Restriction and Monitoring in full: required controls are configured as specified, evidence such as database access control lists is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant query audit logs without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that no query logging on tables containing sensitive data. Further investigation reveals that default database accounts still enabled with default credentials, and no compensating control was documented. The finding is logged against DB-001 with a High risk rating and routed to Chief Information Security Officer for remediation per the defined timeline.

Metadata

Policy_ID:	DB-001	Title:	Database Access Restriction and Monitoring
Category:	Database Security	Risk_Level:	High
Department:	Information Security	Owner:	Chief Information Security Officer
Version:	1.5	Effective_Date:	March 22, 2025
Review_Cycle :	Annual	Priority:	High
Status:	Active	Related_Policies:	DB-002, CHG-001, CHG-002
Keywords:	default credentials, public exposure, database security, database access, query logging, field-level encryption, tokenization, database hardening		
Search_Tags:	Policy, Access Control, Hardening, Database Security, Data Protection, Security		
Evidence_Types:	Database access control lists, Query audit logs, Database hardening benchmark results, Network exposure scan results for database servers		

Database Configuration Hardening

Category: Database Security

Business Objective

Database security policies protect the confidentiality, integrity, and availability of structured data stores that often contain the organization's most sensitive information. The Database Configuration Hardening policy applies this principle specifically to database configuration hardening, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Database Security must comply with the requirements defined under Database Configuration Hardening, and exceptions must be formally documented and approved by Chief Information Security Officer.

Detailed Requirements

1. Direct database access must be limited to database administrators and approved service accounts.
2. Database queries against sensitive tables must be logged.
3. Default database accounts must be disabled or have their credentials rotated.
4. Database servers must not be directly reachable from the public internet.
5. Sensitive columns must be encrypted or tokenized at the field level where feasible.
6. Database configuration must be benchmarked against an internal hardening standard.

Indicators of Non-Compliance

- Sensitive fields stored without encryption or tokenization
- Broad direct database access granted to application developers
- No query logging on tables containing sensitive data
- Default database accounts still enabled with default credentials
- Database servers exposed directly to the internet

Required Evidence

- Database access control lists
- Query audit logs
- Database hardening benchmark results
- Network exposure scan results for database servers

Recommended Remediation

To remediate a violation of Database Configuration Hardening, the accountable team should: (1) Restrict direct database access to a minimal set of administrators and service accounts. (2) Enable query logging for tables classified as sensitive or higher. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

DB-001, SEC-002, AI-001

AI Summary

This policy defines mandatory controls for database configuration hardening within the Database Security domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Information Security.

Example Compliant Scenario

A system owner within Information Security implements Database Configuration Hardening in full: required controls are configured as specified, evidence such as database access control lists is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant query audit logs without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that sensitive fields stored without encryption or tokenization. Further investigation reveals that broad direct database access granted to application developers, and no compensating control was documented. The finding is logged against DB-002 with a Medium risk rating and routed to Chief Information Security Officer for remediation per the defined timeline.

Metadata

Policy_ID:	DB-002	Title:	Database Configuration Hardening
Category:	Database Security	Risk_Level:	Medium
Department:	Information Security	Owner:	Chief Information Security Officer
Version:	3.2	Effective_Date:	March 28, 2025
Review_Cycle :	Annual	Priority:	Medium
Status:	Active	Related_Policies:	DB-001, SEC-002, AI-001
Keywords:	database security, database access, query logging, field-level encryption, tokenization, database hardening, default credentials, public exposure		
Search_Tags:	Database Security, Data Protection, Security, Policy, Access Control, Hardening		
Evidence_Types:	Database access control lists, Query audit logs, Database hardening benchmark results, Network exposure scan results for database servers		

Data Classification Scheme and Labeling

Category: Data Classification

Business Objective

Data classification policies establish a consistent scheme for labeling data according to sensitivity, enabling appropriate handling, access, and protection controls to be applied. The Data Classification Scheme and Labeling policy applies this principle specifically to data classification scheme and labeling, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Data Classification must comply with the requirements defined under Data Classification Scheme and Labeling, and exceptions must be formally documented and approved by Chief Data Governance Officer.

Detailed Requirements

1. Handling requirements must scale with the assigned classification tier.
2. Reclassification must be triggered when the context or use of data changes.
3. Systems storing classified data must document which tiers they contain.
4. Classification labels must be visible in document metadata or headers where applicable.
5. All data must be classified into one of the defined sensitivity tiers.
6. Data classification must occur at the point of creation or ingestion where possible.

Indicators of Non-Compliance

- Systems with no documented inventory of the classification tiers they hold
- Classification labels missing from document metadata
- No reclassification process when data use changes
- Data stored without any classification label

Required Evidence

- Data classification policy and scheme documentation
- Data inventory with classification tags
- System data classification mapping
- Sample labeled documents

Recommended Remediation

To remediate a violation of Data Classification Scheme and Labeling, the accountable team should: (1) Align handling controls with the correct classification tier for affected data. (2) Build and maintain a data inventory mapping systems to classification tiers. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

DC-002, GENAI-003, MAIL-001

AI Summary

This policy defines mandatory controls for data classification scheme and labeling within the Data Classification domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Data Governance.

Example Compliant Scenario

A system owner within Data Governance implements Data Classification Scheme and Labeling in full: required controls are configured as specified, evidence such as data classification policy and scheme documentation is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant data inventory with classification tags without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that systems with no documented inventory of the classification tiers they hold. Further investigation reveals that classification labels missing from document metadata, and no compensating control was documented. The finding is logged against DC-001 with a Medium risk rating and routed to Chief Data Governance Officer for remediation per the defined timeline.

Metadata

Policy_ID:	DC-001	Title:	Data Classification Scheme and Labeling
Category:	Data Classification	Risk_Level:	Medium
Department:	Data Governance	Owner:	Chief Data Governance Officer
Version:	3.5	Effective_Date:	June 26, 2025
Review_Cycle :	Quarterly	Priority:	Medium
Status:	Active	Related_Policies:	DC-002, GENAI-003, MAIL-001
Keywords:	data classification, sensitivity tier, data labeling, data handling, data inventory, classification scheme, data governance		
Search_Tags:	Data Protection, Security, Compliance, Data Classification, Data Governance, Policy		
Evidence_Types:	Data classification policy and scheme documentation, Data inventory with classification tags, System data classification mapping, Sample labeled documents		

Handling Requirements by Classification Tier

Category: Data Classification

Business Objective

Data classification policies establish a consistent scheme for labeling data according to sensitivity, enabling appropriate handling, access, and protection controls to be applied. The Handling Requirements by Classification Tier policy applies this principle specifically to handling requirements by classification tier, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Data Classification must comply with the requirements defined under Handling Requirements by Classification Tier, and exceptions must be formally documented and approved by Chief Data Governance Officer.

Detailed Requirements

1. Systems storing classified data must document which tiers they contain.
2. Classification labels must be visible in document metadata or headers where applicable.
3. All data must be classified into one of the defined sensitivity tiers.
4. Data classification must occur at the point of creation or ingestion where possible.
5. Handling requirements must scale with the assigned classification tier.
6. Reclassification must be triggered when the context or use of data changes.

Indicators of Non-Compliance

- Data stored without any classification label
- Sensitive data handled using controls appropriate only for lower tiers
- Systems with no documented inventory of the classification tiers they hold
- Classification labels missing from document metadata

Required Evidence

- Data classification policy and scheme documentation
- Data inventory with classification tags
- System data classification mapping
- Sample labeled documents

Recommended Remediation

To remediate a violation of Handling Requirements by Classification Tier, the accountable team should: (1) Build and maintain a data inventory mapping systems to classification tiers. (2) Implement automated labeling at the point of data creation where feasible. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

DC-001, DOC-001, DOC-002

AI Summary

This policy defines mandatory controls for handling requirements by classification tier within the Data Classification domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Data Governance.

Example Compliant Scenario

A system owner within Data Governance implements Handling Requirements by Classification Tier in full: required controls are configured as specified, evidence such as data classification policy and scheme documentation is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant data inventory with classification tags without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that data stored without any classification label. Further investigation reveals that sensitive data handled using controls appropriate only for lower tiers, and no compensating control was documented. The finding is logged against DC-002 with a Medium risk rating and routed to Chief Data Governance Officer for remediation per the defined timeline.

Metadata

Policy_ID:	DC-002	Title:	Handling Requirements by Classification Tier
Category:	Data Classification	Risk_Level:	Medium
Department:	Data Governance	Owner:	Chief Data Governance Officer
Version:	2.0	Effective_Date:	June 8, 2025
Review_Cycle :	Annual	Priority:	Medium
Status:	Under Review	Related_Policies:	DC-001, DOC-001, DOC-002
Keywords:	data labeling, data handling, data inventory, classification scheme, data governance, data classification, sensitivity tier		
Search_Tags:	Data Classification, Data Governance, Policy, Data Protection, Security, Compliance		
Evidence_Types:	Data classification policy and scheme documentation, Data inventory with classification tags, System data classification mapping, Sample labeled documents		

Data Retention Schedule by Data Type

Category: Data Retention

Business Objective

Data retention policies define how long different categories of data must be kept and when they must be deleted, balancing operational and legal needs against unnecessary risk exposure. The Data Retention Schedule by Data Type policy applies this principle specifically to data retention schedule by data type, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Data Retention must comply with the requirements defined under Data Retention Schedule by Data Type, and exceptions must be formally documented and approved by Chief Data Governance Officer.

Detailed Requirements

1. Each data type must have a documented retention period in the retention schedule.
2. Data must be automatically flagged for deletion once its retention period expires.
3. Legal hold requests must suspend normal deletion processes for the affected data.
4. Retention schedules must be reviewed periodically for continued business or legal need.
5. Backups containing expired data must also be addressed by the retention process.
6. Retention exceptions must be documented with a business or legal justification.

Indicators of Non-Compliance

- Retention schedule not reviewed in over two years
- Backups excluded from the retention deletion process
- Data retained indefinitely with no defined retention period
- Expired data not flagged or deleted according to schedule
- Legal hold not applied when required, resulting in premature deletion

Required Evidence

- Data retention schedule documentation
- Automated deletion job logs
- Legal hold notices and tracking records
- Retention exception approval records

Recommended Remediation

To remediate a violation of Data Retention Schedule by Data Type, the accountable team should: (1) Extend retention deletion processes to cover backup copies. (2) Define and publish retention periods for any data types currently missing them. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

RET-002, AUTHZ-001, AUTHZ-002

AI Summary

This policy defines mandatory controls for data retention schedule by data type within the Data Retention domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Data Governance.

Example Compliant Scenario

A system owner within Data Governance implements Data Retention Schedule by Data Type in full: required controls are configured as specified, evidence such as data retention schedule documentation is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant automated deletion job logs without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that retention schedule not reviewed in over two years. Further investigation reveals that backups excluded from the retention deletion process, and no compensating control was documented. The finding is logged against RET-001 with a Medium risk rating and routed to Chief Data Governance Officer for remediation per the defined timeline.

Metadata

Policy_ID:	RET-001	Title:	Data Retention Schedule by Data Type
Category:	Data Retention	Risk_Level:	Medium
Department:	Data Governance	Owner:	Chief Data Governance Officer
Version:	1.0	Effective_Date:	October 7, 2025
Review_Cycle :	Semi-Annual	Priority:	Medium
Status:	Active	Related_Policies:	RET-002, AUTHZ-001, AUTHZ-002
Keywords:	retention exception, data lifecycle, data governance, data retention, retention schedule, legal hold, data deletion		
Search_Tags:	Legal, Compliance, Data Protection, Data Retention, Data Governance, Policy		
Evidence_Types:	Data retention schedule documentation, Automated deletion job logs, Legal hold notices and tracking records, Retention exception approval records		

Legal Hold Procedures

Category: Data Retention

Business Objective

Data retention policies define how long different categories of data must be kept and when they must be deleted, balancing operational and legal needs against unnecessary risk exposure. The Legal Hold Procedures policy applies this principle specifically to legal hold procedures, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Data Retention must comply with the requirements defined under Legal Hold Procedures, and exceptions must be formally documented and approved by Chief Data Governance Officer.

Detailed Requirements

1. Legal hold requests must suspend normal deletion processes for the affected data.
2. Retention schedules must be reviewed periodically for continued business or legal need.
3. Backups containing expired data must also be addressed by the retention process.
4. Retention exceptions must be documented with a business or legal justification.
5. Each data type must have a documented retention period in the retention schedule.
6. Data must be automatically flagged for deletion once its retention period expires.

Indicators of Non-Compliance

- Expired data not flagged or deleted according to schedule
- Legal hold not applied when required, resulting in premature deletion
- Retention schedule not reviewed in over two years
- Backups excluded from the retention deletion process

Required Evidence

- Data retention schedule documentation
- Automated deletion job logs
- Legal hold notices and tracking records
- Retention exception approval records

Recommended Remediation

To remediate a violation of Legal Hold Procedures, the accountable team should: (1) Define and publish retention periods for any data types currently missing them. (2) Implement automated deletion workflows tied to the retention schedule. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

RET-001, PWD-002, MFA-001

AI Summary

This policy defines mandatory controls for legal hold procedures within the Data Retention domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and

applies to all in-scope systems and personnel under Data Governance.

Example Compliant Scenario

A system owner within Data Governance implements Legal Hold Procedures in full: required controls are configured as specified, evidence such as data retention schedule documentation is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant automated deletion job logs without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that expired data not flagged or deleted according to schedule. Further investigation reveals that legal hold not applied when required, resulting in premature deletion, and no compensating control was documented. The finding is logged against RET-002 with a High risk rating and routed to Chief Data Governance Officer for remediation per the defined timeline.

Metadata

Policy_ID:	RET-002	Title:	Legal Hold Procedures
Category:	Data Retention	Risk_Level:	High
Department:	Data Governance	Owner:	Chief Data Governance Officer
Version:	2.8	Effective_Date:	June 22, 2025
Review_Cycle :	Quarterly	Priority:	High
Status:	Active	Related_Policies:	RET-001, PWD-002, MFA-001
Keywords:	data governance, data retention, retention schedule, legal hold, data deletion, retention exception, data lifecycle		
Search_Tags:	Data Retention, Data Governance, Policy, Legal, Compliance, Data Protection		
Evidence_Types:	Data retention schedule documentation, Automated deletion job logs, Legal hold notices and tracking records, Retention exception approval records		

Secure Media Sanitization

Category: Data Disposal

Business Objective

Data disposal policies ensure that data and the media on which it resides are destroyed in a manner that prevents recovery once retention obligations end or hardware reaches end of life. The Secure Media Sanitization policy applies this principle specifically to secure media sanitization, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Data Disposal must comply with the requirements defined under Secure Media Sanitization, and exceptions must be formally documented and approved by Chief Data Governance Officer.

Detailed Requirements

1. Disposal of hardware containing sensitive data must be documented with a certificate of destruction.
2. Cloud-based data deletion must be verified, not merely assumed from a delete request.
3. Disposal vendors must be contractually bound to approved sanitization standards.
4. Physical destruction must be used for media that cannot be reliably wiped.
5. Storage media must be sanitized using an approved method before reuse or disposal.

Indicators of Non-Compliance

- Media that should be physically destroyed instead resold intact
- Hardware disposed of without sanitization or destruction records
- No certificate of destruction retained for decommissioned assets
- Cloud data deletion assumed without verification

Required Evidence

- Media sanitization logs
- Certificates of destruction
- Cloud deletion verification records
- Vendor disposal contracts

Recommended Remediation

To remediate a violation of Secure Media Sanitization, the accountable team should: (1) Require and retain certificates of destruction for all decommissioned hardware. (2) Add deletion verification steps to cloud data disposal procedures. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

DISP-002, AC-003, ENC-001

AI Summary

This policy defines mandatory controls for secure media sanitization within the Data Disposal domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Data Governance.

Example Compliant Scenario

A system owner within Data Governance implements Secure Media Sanitization in full: required controls are configured as specified, evidence such as media sanitization logs is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant certificates of destruction without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that media that should be physically destroyed instead resold intact. Further investigation reveals that hardware disposed of without sanitization or destruction records, and no compensating control was documented. The finding is logged against DISP-001 with a High risk rating and routed to Chief Data Governance Officer for remediation per the defined timeline.

Metadata

Policy_ID:	DISP-001	Title:	Secure Media Sanitization
Category:	Data Disposal	Risk_Level:	High
Department:	Data Governance	Owner:	Chief Data Governance Officer
Version:	1.9	Effective_Date:	April 2, 2025
Review_Cycle :	Annual	Priority:	High
Status:	Under Review	Related_Policies:	DISP-002, AC-003, ENC-001
Keywords:	media sanitization, certificate of destruction, hardware disposal, secure erase, end of life, data destruction, data disposal		
Search_Tags:	Security, Asset Management, Compliance, Data Disposal, Data Governance, Policy		
Evidence_Types:	Media sanitization logs, Certificates of destruction, Cloud deletion verification records, Vendor disposal contracts		

End-of-Life Hardware Disposal

Category: Data Disposal

Business Objective

Data disposal policies ensure that data and the media on which it resides are destroyed in a manner that prevents recovery once retention obligations end or hardware reaches end of life. The End-of-Life Hardware Disposal policy applies this principle specifically to end-of-life hardware disposal, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Data Disposal must comply with the requirements defined under End-of-Life Hardware Disposal, and exceptions must be formally documented and approved by Chief Data Governance Officer.

Detailed Requirements

1. Disposal vendors must be contractually bound to approved sanitization standards.
2. Physical destruction must be used for media that cannot be reliably wiped.
3. Storage media must be sanitized using an approved method before reuse or disposal.
4. Disposal of hardware containing sensitive data must be documented with a certificate of destruction.
5. Cloud-based data deletion must be verified, not merely assumed from a delete request.

Indicators of Non-Compliance

- Cloud data deletion assumed without verification
- Disposal vendors without a documented sanitization standard in contract
- Media that should be physically destroyed instead resold intact
- Hardware disposed of without sanitization or destruction records
- No certificate of destruction retained for decommissioned assets

Required Evidence

- Media sanitization logs
- Certificates of destruction
- Cloud deletion verification records
- Vendor disposal contracts

Recommended Remediation

To remediate a violation of End-of-Life Hardware Disposal, the accountable team should: (1) Add deletion verification steps to cloud data disposal procedures. (2) Update vendor contracts to require an approved sanitization standard. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

DISP-001, KEY-002, API-001

AI Summary

This policy defines mandatory controls for end-of-life hardware disposal within the Data Disposal domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Data Governance.

Example Compliant Scenario

A system owner within Data Governance implements End-of-Life Hardware Disposal in full: required controls are configured as specified, evidence such as media sanitization logs is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant certificates of destruction without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that cloud data deletion assumed without verification. Further investigation reveals that disposal vendors without a documented sanitization standard in contract, and no compensating control was documented. The finding is logged against DISP-002 with a Medium risk rating and routed to Chief Data Governance Officer for remediation per the defined timeline.

Metadata

Policy_ID:	DISP-002	Title:	End-of-Life Hardware Disposal
Category:	Data Disposal	Risk_Level:	Medium
Department:	Data Governance	Owner:	Chief Data Governance Officer
Version:	2.9	Effective_Date:	August 4, 2025
Review_Cycle :	Semi-Annual	Priority:	Medium
Status:	Active	Related_Policies:	DISP-001, KEY-002, API-001
Keywords:	hardware disposal, secure erase, end of life, data destruction, data disposal, media sanitization, certificate of destruction		
Search_Tags:	Data Disposal, Data Governance, Policy, Security, Asset Management, Compliance		
Evidence_Types:	Media sanitization logs, Certificates of destruction, Cloud deletion verification records, Vendor disposal contracts		

Customer Data Collection Minimization

Category: Customer Privacy

Business Objective

Customer privacy policies govern how personal data collected from customers is used, shared, and protected, supporting trust and reducing exposure to misuse of personal information. The Customer Data Collection Minimization policy applies this principle specifically to customer data collection minimization, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Customer Privacy must comply with the requirements defined under Customer Data Collection Minimization, and exceptions must be formally documented and approved by Chief Privacy Officer.

Detailed Requirements

1. Data subject requests for access or deletion must be fulfilled within a defined window.
2. Customer data must not be shared with third parties without a documented legal basis.
3. Consent records must be maintained for any data use requiring customer consent.
4. Customer data used for analytics must be aggregated or de-identified where feasible.
5. Customer data collection must be limited to what is necessary for the stated purpose.
6. Customer-facing privacy notices must accurately describe data collection and use.

Indicators of Non-Compliance

- Collection of customer data beyond what the stated purpose requires
- Privacy notices that do not match actual data practices
- Data subject requests unresolved past the defined deadline
- Third-party data sharing without a documented legal basis

Required Evidence

- Data collection inventory
- Published privacy notice text
- Data subject request tracking log
- Third-party data sharing agreements
- Consent management records

Recommended Remediation

To remediate a violation of Customer Data Collection Minimization, the accountable team should: (1) Document a legal basis for all third-party data sharing arrangements. (2) Reduce data collection fields to those necessary for the stated purpose. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

PRIV-002, CLOUD-003, NET-001

AI Summary

This policy defines mandatory controls for customer data collection minimization within the Customer Privacy domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Privacy Office.

Example Compliant Scenario

A system owner within Privacy Office implements Customer Data Collection Minimization in full: required controls are configured as specified, evidence such as data collection inventory is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant published privacy notice text without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that collection of customer data beyond what the stated purpose requires. Further investigation reveals that privacy notices that do not match actual data practices, and no compensating control was documented. The finding is logged against PRIV-001 with a High risk rating and routed to Chief Privacy Officer for remediation per the defined timeline.

Metadata

Policy_ID:	PRIV-001	Title:	Customer Data Collection Minimization
Category:	Customer Privacy	Risk_Level:	High
Department:	Privacy Office	Owner:	Chief Privacy Officer
Version:	1.8	Effective_Date:	August 22, 2025
Review_Cycle :	Quarterly	Priority:	High
Status:	Active	Related_Policies:	PRIV-002, CLOUD-003, NET-001
Keywords:	third-party sharing, de-identification, customer privacy, personal data, data subject request, consent, privacy notice, data minimization		
Search_Tags:	Policy, Compliance, Governance, Customer Privacy, Privacy, Data Protection		
Evidence_Types:	Data collection inventory, Published privacy notice text, Data subject request tracking log, Third-party data sharing agreements, Consent management records		

Customer Data Subject Request Handling

Category: Customer Privacy

Business Objective

Customer privacy policies govern how personal data collected from customers is used, shared, and protected, supporting trust and reducing exposure to misuse of personal information. The Customer Data Subject Request Handling policy applies this principle specifically to customer data subject request handling, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Customer Privacy must comply with the requirements defined under Customer Data Subject Request Handling, and exceptions must be formally documented and approved by Chief Privacy Officer.

Detailed Requirements

1. Consent records must be maintained for any data use requiring customer consent.
2. Customer data used for analytics must be aggregated or de-identified where feasible.
3. Customer data collection must be limited to what is necessary for the stated purpose.
4. Customer-facing privacy notices must accurately describe data collection and use.
5. Data subject requests for access or deletion must be fulfilled within a defined window.
6. Customer data must not be shared with third parties without a documented legal basis.

Indicators of Non-Compliance

- Third-party data sharing without a documented legal basis
- No consent records for data uses requiring consent
- Collection of customer data beyond what the stated purpose requires
- Privacy notices that do not match actual data practices
- Data subject requests unresolved past the defined deadline

Required Evidence

- Consent management records
- Data collection inventory
- Published privacy notice text
- Data subject request tracking log
- Third-party data sharing agreements

Recommended Remediation

To remediate a violation of Customer Data Subject Request Handling, the accountable team should: (1) Reduce data collection fields to those necessary for the stated purpose. (2) Update privacy notices to accurately reflect current data practices. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

PRIV-001, EP-001, EP-002

AI Summary

This policy defines mandatory controls for customer data subject request handling within the Customer Privacy domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Privacy Office.

Example Compliant Scenario

A system owner within Privacy Office implements Customer Data Subject Request Handling in full: required controls are configured as specified, evidence such as consent management records is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant data collection inventory without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that third-party data sharing without a documented legal basis. Further investigation reveals that no consent records for data uses requiring consent, and no compensating control was documented. The finding is logged against PRIV-002 with a High risk rating and routed to Chief Privacy Officer for remediation per the defined timeline.

Metadata

Policy_ID:	PRIV-002	Title:	Customer Data Subject Request Handling
Category:	Customer Privacy	Risk_Level:	High
Department:	Privacy Office	Owner:	Chief Privacy Officer
Version:	3.5	Effective_Date:	August 11, 2025
Review_Cycle :	Quarterly	Priority:	High
Status:	Active	Related_Policies:	PRIV-001, EP-001, EP-002
Keywords:	customer privacy, personal data, data subject request, consent, privacy notice, data minimization, third-party sharing, de-identification		
Search_Tags:	Customer Privacy, Privacy, Data Protection, Policy, Compliance, Governance		
Evidence_Types:	Consent management records, Data collection inventory, Published privacy notice text, Data subject request tracking log, Third-party data sharing agreements		

Workplace Monitoring Disclosure

Category: Employee Privacy

Business Objective

Employee privacy policies balance the organization's legitimate business needs, such as security monitoring, against employees' reasonable expectations of privacy in the workplace. The Workplace Monitoring Disclosure policy applies this principle specifically to workplace monitoring disclosure, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Employee Privacy must comply with the requirements defined under Workplace Monitoring Disclosure, and exceptions must be formally documented and approved by VP of Human Resources.

Detailed Requirements

1. Requests from employees to access their own personal data must be honored within a defined window.
2. Employees must be notified of any workplace monitoring practices before they begin.
3. Access to employee personal data must be restricted to personnel with a business need.
4. Employee monitoring data must be used only for the disclosed purpose.
5. Employee personal data must follow the same classification and handling rules as customer data of equivalent sensitivity.

Indicators of Non-Compliance

- Broad access to HR or personal employee data beyond business need
- Monitoring data used for purposes beyond what was disclosed
- Employee personal data handled with weaker controls than equivalent customer data
- Employee data access requests ignored or delayed indefinitely
- Monitoring conducted without prior employee notification

Required Evidence

- Employee monitoring disclosure notices
- HR system access control lists
- Monitoring data usage logs
- Employee data access request records

Recommended Remediation

To remediate a violation of Workplace Monitoring Disclosure, the accountable team should: (1) Restrict HR and personal data system access to roles with a documented business need. (2) Align employee personal data handling controls with the applicable classification tier. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

EMPPRIV-002, LOG-002, LOG-003

AI Summary

This policy defines mandatory controls for workplace monitoring disclosure within the Employee Privacy domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Human Resources.

Example Compliant Scenario

A system owner within Human Resources implements Workplace Monitoring Disclosure in full: required controls are configured as specified, evidence such as employee monitoring disclosure notices is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant hr system access control lists without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that broad access to hr or personal employee data beyond business need. Further investigation reveals that monitoring data used for purposes beyond what was disclosed, and no compensating control was documented. The finding is logged against EMPPRIV-001 with a Medium risk rating and routed to VP of Human Resources for remediation per the defined timeline.

Metadata

Policy_ID:	EMPPRIV-001	Title:	Workplace Monitoring Disclosure
Category:	Employee Privacy	Risk_Level:	Medium
Department:	Human Resources	Owner:	VP of Human Resources
Version:	3.6	Effective_Date:	April 13, 2025
Review_Cycle :	Quarterly	Priority:	Medium
Status:	Active	Related_Policies:	EMPPRIV-002, LOG-002, LOG-003
Keywords:	HR data, personal data, disclosure notice, access request, employee data handling, employee privacy, workplace monitoring		
Search_Tags:	Policy, Data Protection, Compliance, Employee Privacy, Human Resources, Privacy		
Evidence_Types:	Employee monitoring disclosure notices, HR system access control lists, Monitoring data usage logs, Employee data access request records		

Employee Personal Data Handling

Category: Employee Privacy

Business Objective

Employee privacy policies balance the organization's legitimate business needs, such as security monitoring, against employees' reasonable expectations of privacy in the workplace. The Employee Personal Data Handling policy applies this principle specifically to employee personal data handling, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Employee Privacy must comply with the requirements defined under Employee Personal Data Handling, and exceptions must be formally documented and approved by VP of Human Resources.

Detailed Requirements

1. Access to employee personal data must be restricted to personnel with a business need.
2. Employee monitoring data must be used only for the disclosed purpose.
3. Employee personal data must follow the same classification and handling rules as customer data of equivalent sensitivity.
4. Requests from employees to access their own personal data must be honored within a defined window.
5. Employees must be notified of any workplace monitoring practices before they begin.

Indicators of Non-Compliance

- Employee data access requests ignored or delayed indefinitely
- Monitoring conducted without prior employee notification
- Broad access to HR or personal employee data beyond business need
- Monitoring data used for purposes beyond what was disclosed

Required Evidence

- Employee monitoring disclosure notices
- HR system access control lists
- Monitoring data usage logs
- Employee data access request records

Recommended Remediation

To remediate a violation of Employee Personal Data Handling, the accountable team should: (1) Align employee personal data handling controls with the applicable classification tier. (2) Establish a tracked process for employee personal data access requests. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

EMPPRIV-001, INC-002, INC-003

AI Summary

This policy defines mandatory controls for employee personal data handling within the Employee Privacy domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified

as Medium risk and applies to all in-scope systems and personnel under Human Resources.

Example Compliant Scenario

A system owner within Human Resources implements Employee Personal Data Handling in full: required controls are configured as specified, evidence such as employee monitoring disclosure notices is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant hr system access control lists without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that employee data access requests ignored or delayed indefinitely. Further investigation reveals that monitoring conducted without prior employee notification, and no compensating control was documented. The finding is logged against EMPPRIV-002 with a Medium risk rating and routed to VP of Human Resources for remediation per the defined timeline.

Metadata

Policy_ID:	EMPPRIV-002	Title:	Employee Personal Data Handling
Category:	Employee Privacy	Risk_Level:	Medium
Department:	Human Resources	Owner:	VP of Human Resources
Version:	2.6	Effective_Date:	October 24, 2025
Review_Cycle :	Annual	Priority:	Medium
Status:	Active	Related_Policies:	EMPPRIV-001, INC-002, INC-003
Keywords:	disclosure notice, access request, employee data handling, employee privacy, workplace monitoring, HR data, personal data		
Search_Tags:	Employee Privacy, Human Resources, Privacy, Policy, Data Protection, Compliance		
Evidence_Types:	Employee monitoring disclosure notices, HR system access control lists, Monitoring data usage logs, Employee data access request records		

Vendor Security Risk Assessment

Category: Third-Party Vendors

Business Objective

Third-party vendor policies extend the organization's security expectations to external parties that process data or provide services, reducing risk introduced through the supply chain. The Vendor Security Risk Assessment policy applies this principle specifically to vendor security risk assessment, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Third-Party Vendors must comply with the requirements defined under Vendor Security Risk Assessment, and exceptions must be formally documented and approved by Head of Vendor Risk Management.

Detailed Requirements

1. Vendor access to internal systems must be reviewed and time-limited.
2. Vendor offboarding must include revocation of all granted access.
3. Vendors handling sensitive data must complete a security risk assessment before onboarding.
4. Vendor contracts must include defined security and breach notification requirements.
5. High-risk vendors must be reassessed on a recurring basis.
6. Vendors must disclose their use of subcontractors that will process organizational data.

Indicators of Non-Compliance

- High-risk vendors not reassessed within the defined cycle
- Subcontractor use undisclosed by a primary vendor
- Vendor access not revoked after contract termination
- Vendors onboarded without a completed security risk assessment
- Vendor contracts missing security or breach notification clauses

Required Evidence

- Vendor contract security clauses
- Vendor reassessment schedule and records
- Subcontractor disclosure documentation
- Vendor access revocation records
- Vendor risk assessment questionnaires and results

Recommended Remediation

To remediate a violation of Vendor Security Risk Assessment, the accountable team should: (1) Require vendors to disclose and obtain approval for subcontractor use. (2) Complete a retroactive security risk assessment for vendors onboarded without one. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

VENDOR-002, VENDOR-003, BACKUP-003

AI Summary

This policy defines mandatory controls for vendor security risk assessment within the Third-Party Vendors domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Vendor Risk Management.

Example Compliant Scenario

A system owner within Vendor Risk Management implements Vendor Security Risk Assessment in full: required controls are configured as specified, evidence such as vendor contract security clauses is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant vendor reassessment schedule and records without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that high-risk vendors not reassessed within the defined cycle. Further investigation reveals that subcontractor use undisclosed by a primary vendor, and no compensating control was documented. The finding is logged against VENDOR-001 with a High risk rating and routed to Head of Vendor Risk Management for remediation per the defined timeline.

Metadata

Policy_ID:	VENDOR-001	Title:	Vendor Security Risk Assessment
Category:	Third-Party Vendors	Risk_Level:	High
Department:	Vendor Risk Management	Owner:	Head of Vendor Risk Management
Version:	2.4	Effective_Date:	March 14, 2025
Review_Cycle :	Quarterly	Priority:	High
Status:	Active	Related_Policies:	VENDOR-002, VENDOR-003, BACKUP-003
Keywords:	breach notification, vendor offboarding, vendor risk, third-party risk, subcontractor, vendor assessment, supply chain, vendor contract		
Search_Tags:	Security, Governance, Supply Chain, Third-Party Risk, Vendor Management, Policy		
Evidence_Types:	Vendor contract security clauses, Vendor reassessment schedule and records, Subcontractor disclosure documentation, Vendor access revocation records, Vendor risk assessment questionnaires and results		

Vendor Contractual Security Requirements

Category: Third-Party Vendors

Business Objective

Third-party vendor policies extend the organization's security expectations to external parties that process data or provide services, reducing risk introduced through the supply chain. The Vendor Contractual Security Requirements policy applies this principle specifically to vendor contractual security requirements, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Third-Party Vendors must comply with the requirements defined under Vendor Contractual Security Requirements, and exceptions must be formally documented and approved by Head of Vendor Risk Management.

Detailed Requirements

1. Vendors handling sensitive data must complete a security risk assessment before onboarding.
2. Vendor contracts must include defined security and breach notification requirements.
3. High-risk vendors must be reassessed on a recurring basis.
4. Vendors must disclose their use of subcontractors that will process organizational data.
5. Vendor access to internal systems must be reviewed and time-limited.
6. Vendor offboarding must include revocation of all granted access.

Indicators of Non-Compliance

- Vendors onboarded without a completed security risk assessment
- Vendor contracts missing security or breach notification clauses
- High-risk vendors not reassessed within the defined cycle
- Subcontractor use undisclosed by a primary vendor
- Vendor access not revoked after contract termination

Required Evidence

- Vendor risk assessment questionnaires and results
- Vendor contract security clauses
- Vendor reassessment schedule and records
- Subcontractor disclosure documentation
- Vendor access revocation records

Recommended Remediation

To remediate a violation of Vendor Contractual Security Requirements, the accountable team should: (1) Complete a retroactive security risk assessment for vendors onboarded without one. (2) Amend vendor contracts to include required security and breach notification clauses. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

VENDOR-001, VENDOR-003, RET-001

AI Summary

This policy defines mandatory controls for vendor contractual security requirements within the Third-Party Vendors domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Vendor Risk Management.

Example Compliant Scenario

A system owner within Vendor Risk Management implements Vendor Contractual Security Requirements in full: required controls are configured as specified, evidence such as vendor risk assessment questionnaires and results is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant vendor contract security clauses without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that vendors onboarded without a completed security risk assessment. Further investigation reveals that vendor contracts missing security or breach notification clauses, and no compensating control was documented. The finding is logged against VENDOR-002 with a Medium risk rating and routed to Head of Vendor Risk Management for remediation per the defined timeline.

Metadata

Policy_ID:	VENDOR-002	Title:	Vendor Contractual Security Requirements
Category:	Third-Party Vendors	Risk_Level:	Medium
Department:	Vendor Risk Management	Owner:	Head of Vendor Risk Management
Version:	3.3	Effective_Date:	August 16, 2025
Review_Cycle:	Quarterly	Priority:	Medium
Status:	Active	Related_Policies:	VENDOR-001, VENDOR-003, RET-001
Keywords:	vendor risk, third-party risk, subcontractor, vendor assessment, supply chain, vendor contract, breach notification, vendor offboarding		
Search_Tags:	Third-Party Risk, Vendor Management, Policy, Security, Governance, Supply Chain		
Evidence_Types:	Vendor risk assessment questionnaires and results, Vendor contract security clauses, Vendor reassessment schedule and records, Subcontractor disclosure documentation, Vendor access revocation records		

Fourth-Party Subcontractor Oversight

Category: Third-Party Vendors

Business Objective

Third-party vendor policies extend the organization's security expectations to external parties that process data or provide services, reducing risk introduced through the supply chain. The Fourth-Party Subcontractor Oversight policy applies this principle specifically to fourth-party subcontractor oversight, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Third-Party Vendors must comply with the requirements defined under Fourth-Party Subcontractor Oversight, and exceptions must be formally documented and approved by Head of Vendor Risk Management.

Detailed Requirements

1. High-risk vendors must be reassessed on a recurring basis.
2. Vendors must disclose their use of subcontractors that will process organizational data.
3. Vendor access to internal systems must be reviewed and time-limited.
4. Vendor offboarding must include revocation of all granted access.
5. Vendors handling sensitive data must complete a security risk assessment before onboarding.
6. Vendor contracts must include defined security and breach notification requirements.

Indicators of Non-Compliance

- Subcontractor use undisclosed by a primary vendor
- Vendor access not revoked after contract termination
- Vendors onboarded without a completed security risk assessment
- Vendor contracts missing security or breach notification clauses

Required Evidence

- Vendor access revocation records
- Vendor risk assessment questionnaires and results
- Vendor contract security clauses
- Vendor reassessment schedule and records
- Subcontractor disclosure documentation

Recommended Remediation

To remediate a violation of Fourth-Party Subcontractor Oversight, the accountable team should: (1) Amend vendor contracts to include required security and breach notification clauses. (2) Establish a recurring reassessment cycle for high-risk vendors. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

VENDOR-001, VENDOR-002, PRIV-002

AI Summary

This policy defines mandatory controls for fourth-party subcontractor oversight within the Third-Party Vendors domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Vendor Risk Management.

Example Compliant Scenario

A system owner within Vendor Risk Management implements Fourth-Party Subcontractor Oversight in full: required controls are configured as specified, evidence such as vendor access revocation records is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant vendor risk assessment questionnaires and results without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that subcontractor use undisclosed by a primary vendor. Further investigation reveals that vendor access not revoked after contract termination, and no compensating control was documented. The finding is logged against VENDOR-003 with a Medium risk rating and routed to Head of Vendor Risk Management for remediation per the defined timeline.

Metadata

Policy_ID:	VENDOR-003	Title:	Fourth-Party Subcontractor Oversight
Category:	Third-Party Vendors	Risk_Level:	Medium
Department:	Vendor Risk Management	Owner:	Head of Vendor Risk Management
Version:	3.9	Effective_Date:	April 3, 2025
Review_Cycle :	Annual	Priority:	Medium
Status:	Active	Related_Policies:	VENDOR-001, VENDOR-002, PRIV-002
Keywords:	subcontractor, vendor assessment, supply chain, vendor contract, breach notification, vendor offboarding, vendor risk, third-party risk		
Search_Tags:	Security, Governance, Supply Chain, Third-Party Risk, Vendor Management, Policy		
Evidence_Types:	Vendor access revocation records, Vendor risk assessment questionnaires and results, Vendor contract security clauses, Vendor reassessment schedule and records, Subcontractor disclosure documentation		

Data Center Physical Access Control

Category: Physical Security

Business Objective

Physical security policies protect facilities, equipment, and personnel from unauthorized physical access, theft, and environmental hazards that could compromise information security. The Data Center Physical Access Control policy applies this principle specifically to data center physical access control, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Physical Security must comply with the requirements defined under Data Center Physical Access Control, and exceptions must be formally documented and approved by Director of Corporate Security.

Detailed Requirements

1. Server room access logs must be retained and reviewed periodically.
2. Environmental controls such as fire suppression must be tested annually.
3. Data center access must require multi-factor physical authentication such as badge and biometric.
4. Visitor access to secure areas must be logged and escorted at all times.
5. Badge access rights must be reviewed and revoked promptly upon termination.

Indicators of Non-Compliance

- Visitors in secure areas without an escort or access log
- Terminated employees retaining active badge access
- Blind spots in camera coverage at critical entry points
- Server room access logs not reviewed

Required Evidence

- Badge access system configuration and logs
- Visitor log records
- Camera coverage maps
- Environmental control testing records

Recommended Remediation

To remediate a violation of Data Center Physical Access Control, the accountable team should: (1) Integrate badge revocation into the termination workflow for immediate effect. (2) Close camera coverage gaps identified at critical entry and exit points. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

PHYS-002, EMPPRIV-002, VENDOR-001

AI Summary

This policy defines mandatory controls for data center physical access control within the Physical Security domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Corporate Security.

Example Compliant Scenario

A system owner within Corporate Security implements Data Center Physical Access Control in full: required controls are configured as specified, evidence such as badge access system configuration and logs is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant visitor log records without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that visitors in secure areas without an escort or access log. Further investigation reveals that terminated employees retaining active badge access, and no compensating control was documented. The finding is logged against PHYS-001 with a High risk rating and routed to Director of Corporate Security for remediation per the defined timeline.

Metadata

Policy_ID:	PHYS-001	Title:	Data Center Physical Access Control
Category:	Physical Security	Risk_Level:	High
Department:	Corporate Security	Owner:	Director of Corporate Security
Version:	1.0	Effective_Date:	March 16, 2025
Review_Cycle :	Quarterly	Priority:	High
Status:	Active	Related_Policies:	PHYS-002, EMPPRIV-002, VENDOR-001
Keywords:	camera coverage, environmental controls, physical security, badge access, data center security, visitor log, biometric access		
Search_Tags:	Physical Security, Corporate Security, Policy, Data Center, Access Control, Facilities		
Evidence_Types:	Badge access system configuration and logs, Visitor log records, Camera coverage maps, Environmental control testing records		

Office Badge Access Management

Category: Physical Security

Business Objective

Physical security policies protect facilities, equipment, and personnel from unauthorized physical access, theft, and environmental hazards that could compromise information security. The Office Badge Access Management policy applies this principle specifically to office badge access management, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Physical Security must comply with the requirements defined under Office Badge Access Management, and exceptions must be formally documented and approved by Director of Corporate Security.

Detailed Requirements

1. Data center access must require multi-factor physical authentication such as badge and biometric.
2. Visitor access to secure areas must be logged and escorted at all times.
3. Badge access rights must be reviewed and revoked promptly upon termination.
4. Physical security cameras must cover all critical entry and exit points.
5. Server room access logs must be retained and reviewed periodically.
6. Environmental controls such as fire suppression must be tested annually.

Indicators of Non-Compliance

- Server room access logs not reviewed
- Data center access granted with only a single physical factor
- Visitors in secure areas without an escort or access log
- Terminated employees retaining active badge access
- Blind spots in camera coverage at critical entry points

Required Evidence

- Badge access system configuration and logs
- Visitor log records
- Camera coverage maps
- Environmental control testing records

Recommended Remediation

To remediate a violation of Office Badge Access Management, the accountable team should: (1) Close camera coverage gaps identified at critical entry and exit points. (2) Implement multi-factor physical authentication at all data center entry points. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

PHYS-001, REMOTE-002, SDLC-001

AI Summary

This policy defines mandatory controls for office badge access management within the Physical Security domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Corporate Security.

Example Compliant Scenario

A system owner within Corporate Security implements Office Badge Access Management in full: required controls are configured as specified, evidence such as badge access system configuration and logs is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant visitor log records without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that server room access logs not reviewed. Further investigation reveals that data center access granted with only a single physical factor, and no compensating control was documented. The finding is logged against PHYS-002 with a Medium risk rating and routed to Director of Corporate Security for remediation per the defined timeline.

Metadata

Policy_ID:	PHYS-002	Title:	Office Badge Access Management
Category:	Physical Security	Risk_Level:	Medium
Department:	Corporate Security	Owner:	Director of Corporate Security
Version:	3.6	Effective_Date:	June 13, 2025
Review_Cycle :	Annual	Priority:	Medium
Status:	Active	Related_Policies:	PHYS-001, REMOTE-002, SDLC-001
Keywords:	physical security, badge access, data center security, visitor log, biometric access, camera coverage, environmental controls		
Search_Tags:	Data Center, Access Control, Facilities, Physical Security, Corporate Security, Policy		
Evidence_Types:	Badge access system configuration and logs, Visitor log records, Camera coverage maps, Environmental control testing records		

Secure Remote Access Requirements

Category: Remote Work

Business Objective

Remote work policies extend appropriate security controls to employees working outside traditional office environments, addressing the expanded attack surface introduced by distributed work. The Secure Remote Access Requirements policy applies this principle specifically to secure remote access requirements, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Remote Work must comply with the requirements defined under Secure Remote Access Requirements, and exceptions must be formally documented and approved by Director of IT Operations.

Detailed Requirements

1. Remote work agreements must document security expectations for the employee.
2. Screen locks must be enforced after a short period of inactivity on remote devices.
3. Remote access to corporate systems must occur only through approved, encrypted channels.
4. Remote workers must use company-managed devices for accessing sensitive systems.
5. Public Wi-Fi use for sensitive work must require a VPN connection.

Indicators of Non-Compliance

- Sensitive work performed on public Wi-Fi without a VPN
- No documented remote work security agreement on file
- Screen lock policies not enforced on remote devices
- Remote access occurring over unencrypted or unapproved channels
- Personal, unmanaged devices used to access sensitive systems remotely

Required Evidence

- Device management compliance reports
- VPN usage logs
- Signed remote work agreements
- Screen lock policy configuration
- Remote access connection logs

Recommended Remediation

To remediate a violation of Secure Remote Access Requirements, the accountable team should: (1) Restrict remote access to approved, encrypted connection methods only. (2) Require company-managed devices for access to sensitive systems remotely. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

REMOTE-002, CHG-002, SCM-001

AI Summary

This policy defines mandatory controls for secure remote access requirements within the Remote Work domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under IT Operations.

Example Compliant Scenario

A system owner within IT Operations implements Secure Remote Access Requirements in full: required controls are configured as specified, evidence such as device management compliance reports is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant vpn usage logs without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that sensitive work performed on public wi-fi without a vpn. Further investigation reveals that no documented remote work security agreement on file, and no compensating control was documented. The finding is logged against REMOTE-001 with a Medium risk rating and routed to Director of IT Operations for remediation per the defined timeline.

Metadata

Policy_ID:	REMOTE-001	Title:	Secure Remote Access Requirements
Category:	Remote Work	Risk_Level:	Medium
Department:	IT Operations	Owner:	Director of IT Operations
Version:	1.6	Effective_Date:	March 6, 2025
Review_Cycle :	Quarterly	Priority:	Medium
Status:	Under Review	Related_Policies:	REMOTE-002, CHG-002, SCM-001
Keywords:	remote access, home office, managed device, screen lock, distributed workforce, remote work, VPN		
Search_Tags:	Remote Work, IT Operations, Security, Policy, Access Control, VPN		
Evidence_Types:	Device management compliance reports, VPN usage logs, Signed remote work agreements, Screen lock policy configuration, Remote access connection logs		

Home Office Security Baseline

Category: Remote Work

Business Objective

Remote work policies extend appropriate security controls to employees working outside traditional office environments, addressing the expanded attack surface introduced by distributed work. The Home Office Security Baseline policy applies this principle specifically to home office security baseline, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Remote Work must comply with the requirements defined under Home Office Security Baseline, and exceptions must be formally documented and approved by Director of IT Operations.

Detailed Requirements

1. Remote access to corporate systems must occur only through approved, encrypted channels.
2. Remote workers must use company-managed devices for accessing sensitive systems.
3. Public Wi-Fi use for sensitive work must require a VPN connection.
4. Remote work agreements must document security expectations for the employee.
5. Screen locks must be enforced after a short period of inactivity on remote devices.

Indicators of Non-Compliance

- Remote access occurring over unencrypted or unapproved channels
- Personal, unmanaged devices used to access sensitive systems remotely
- Sensitive work performed on public Wi-Fi without a VPN
- No documented remote work security agreement on file
- Screen lock policies not enforced on remote devices

Required Evidence

- Remote access connection logs
- Device management compliance reports
- VPN usage logs
- Signed remote work agreements
- Screen lock policy configuration

Recommended Remediation

To remediate a violation of Home Office Security Baseline, the accountable team should: (1) Require company-managed devices for access to sensitive systems remotely. (2) Enforce mandatory VPN use when connecting over untrusted networks. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

REMOTE-001, AI-001, AI-002

AI Summary

This policy defines mandatory controls for home office security baseline within the Remote Work domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Low risk and applies to all in-scope systems and personnel under IT Operations.

Example Compliant Scenario

A system owner within IT Operations implements Home Office Security Baseline in full: required controls are configured as specified, evidence such as remote access connection logs is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant device management compliance reports without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that remote access occurring over unencrypted or unapproved channels. Further investigation reveals that personal, unmanaged devices used to access sensitive systems remotely, and no compensating control was documented. The finding is logged against REMOTE-002 with a Low risk rating and routed to Director of IT Operations for remediation per the defined timeline.

Metadata

Policy_ID:	REMOTE-002	Title:	Home Office Security Baseline
Category:	Remote Work	Risk_Level:	Low
Department:	IT Operations	Owner:	Director of IT Operations
Version:	1.7	Effective_Date:	March 26, 2025
Review_Cycle :	Semi-Annual	Priority:	Low
Status:	Active	Related_Policies:	REMOTE-001, AI-001, AI-002
Keywords:	managed device, screen lock, distributed workforce, remote work, VPN, remote access, home office		
Search_Tags:	Policy, Access Control, VPN, Remote Work, IT Operations, Security		
Evidence_Types:	Remote access connection logs, Device management compliance reports, VPN usage logs, Signed remote work agreements, Screen lock policy configuration		

Secure Code Review Requirements

Category: Secure Software Development

Business Objective

Secure software development policies embed security practices throughout the development lifecycle, reducing the likelihood that vulnerabilities are introduced into production software. The Secure Code Review Requirements policy applies this principle specifically to secure code review requirements, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Secure Software Development must comply with the requirements defined under Secure Code Review Requirements, and exceptions must be formally documented and approved by Head of Application Security.

Detailed Requirements

1. High-severity findings from security testing must block release until resolved or accepted.
2. All code changes must undergo peer review before merging to the main branch.
3. Static application security testing must run as part of the build pipeline.
4. Dynamic application security testing must occur prior to major releases.
5. Third-party dependencies must be scanned for known vulnerabilities before use.
6. Security requirements must be defined during the design phase, not after implementation.

Indicators of Non-Compliance

- Security requirements absent from design documentation
- High-severity findings ignored and shipped to production
- Code merged without peer review
- No static or dynamic application security testing in the pipeline
- Third-party dependencies with known critical vulnerabilities in use

Required Evidence

- Release gate configuration
- Code review records or pull request history
- Static and dynamic application security testing reports
- Software composition analysis reports
- Secure coding training completion records

Recommended Remediation

To remediate a violation of Secure Code Review Requirements, the accountable team should: (1) Remediate or replace third-party dependencies with known critical vulnerabilities. (2) Add a release gate that blocks deployment on unresolved high-severity findings. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

SDLC-002, SDLC-003, DOC-001

AI Summary

This policy defines mandatory controls for secure code review requirements within the Secure Software Development domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Application Security.

Example Compliant Scenario

A system owner within Application Security implements Secure Code Review Requirements in full: required controls are configured as specified, evidence such as release gate configuration is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant code review records or pull request history without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that security requirements absent from design documentation. Further investigation reveals that high-severity findings ignored and shipped to production, and no compensating control was documented. The finding is logged against SDLC-001 with a High risk rating and routed to Head of Application Security for remediation per the defined timeline.

Metadata

Policy_ID:	SDLC-001	Title:	Secure Code Review Requirements
Category:	Secure Software Development	Risk_Level:	High
Department:	Application Security	Owner:	Head of Application Security
Version:	3.7	Effective_Date:	March 24, 2025
Review_Cycle:	Semi-Annual	Priority:	High
Status:	Under Review	Related_Policies:	SDLC-002, SDLC-003, DOC-001
Keywords:	code review, SAST, DAST, dependency scanning, software composition analysis, CI/CD, security testing, secure coding, secure development, SDLC		
Search_Tags:	Secure Development, Application Security, SDLC, Policy, Software Development, Security Testing		
Evidence_Types:	Release gate configuration, Code review records or pull request history, Static and dynamic application security testing reports, Software composition analysis reports, Secure coding training completion records		

Static and Dynamic Application Security Testing

Category: Secure Software Development

Business Objective

Secure software development policies embed security practices throughout the development lifecycle, reducing the likelihood that vulnerabilities are introduced into production software. The Static and Dynamic Application Security Testing policy applies this principle specifically to static and dynamic application security testing, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Secure Software Development must comply with the requirements defined under Static and Dynamic Application Security Testing, and exceptions must be formally documented and approved by Head of Application Security.

Detailed Requirements

1. Static application security testing must run as part of the build pipeline.
2. Dynamic application security testing must occur prior to major releases.
3. Third-party dependencies must be scanned for known vulnerabilities before use.
4. Security requirements must be defined during the design phase, not after implementation.
5. Developers must complete secure coding training on a recurring basis.
6. High-severity findings from security testing must block release until resolved or accepted.

Indicators of Non-Compliance

- No static or dynamic application security testing in the pipeline
- Third-party dependencies with known critical vulnerabilities in use
- Security requirements absent from design documentation
- High-severity findings ignored and shipped to production

Required Evidence

- Secure coding training completion records
- Release gate configuration
- Code review records or pull request history
- Static and dynamic application security testing reports
- Software composition analysis reports

Recommended Remediation

To remediate a violation of Static and Dynamic Application Security Testing, the accountable team should: (1) Add a release gate that blocks deployment on unresolved high-severity findings. (2) Enforce mandatory peer review for all code changes via branch protection rules. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

SDLC-001, SDLC-003, AUTHZ-001

AI Summary

This policy defines mandatory controls for static and dynamic application security testing within the Secure Software Development domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Application Security.

Example Compliant Scenario

A system owner within Application Security implements Static and Dynamic Application Security Testing in full: required controls are configured as specified, evidence such as secure coding training completion records is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant release gate configuration without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that no static or dynamic application security testing in the pipeline. Further investigation reveals that third-party dependencies with known critical vulnerabilities in use, and no compensating control was documented. The finding is logged against SDLC-002 with a High risk rating and routed to Head of Application Security for remediation per the defined timeline.

Metadata

Policy_ID:	SDLC-002	Title:	Static and Dynamic Application Security Testing
Category:	Secure Software Development	Risk_Level:	High
Department:	Application Security	Owner:	Head of Application Security
Version:	3.7	Effective_Date:	October 8, 2025
Review_Cycle :	Semi-Annual	Priority:	High
Status:	Under Review	Related_Policies:	SDLC-001, SDLC-003, AUTHZ-001
Keywords:	DAST, dependency scanning, software composition analysis, CI/CD, security testing, secure coding, secure development, SDLC, code review, SAST		
Search_Tags:	Policy, Software Development, Security Testing, Secure Development, Application Security, SDLC		
Evidence_Types:	Secure coding training completion records, Release gate configuration, Code review records or pull request history, Static and dynamic application security testing reports, Software composition analysis reports		

Third-Party Library Dependency Management

Category: Secure Software Development

Business Objective

Secure software development policies embed security practices throughout the development lifecycle, reducing the likelihood that vulnerabilities are introduced into production software. The Third-Party Library Dependency Management policy applies this principle specifically to third-party library dependency management, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Secure Software Development must comply with the requirements defined under Third-Party Library Dependency Management, and exceptions must be formally documented and approved by Head of Application Security.

Detailed Requirements

1. Third-party dependencies must be scanned for known vulnerabilities before use.
2. Security requirements must be defined during the design phase, not after implementation.
3. Developers must complete secure coding training on a recurring basis.
4. High-severity findings from security testing must block release until resolved or accepted.
5. All code changes must undergo peer review before merging to the main branch.

Indicators of Non-Compliance

- High-severity findings ignored and shipped to production
- Code merged without peer review
- No static or dynamic application security testing in the pipeline
- Third-party dependencies with known critical vulnerabilities in use
- Security requirements absent from design documentation

Required Evidence

- Software composition analysis reports
- Secure coding training completion records
- Release gate configuration
- Code review records or pull request history
- Static and dynamic application security testing reports

Recommended Remediation

To remediate a violation of Third-Party Library Dependency Management, the accountable team should: (1) Enforce mandatory peer review for all code changes via branch protection rules. (2) Integrate static and dynamic application security testing into the CI/CD pipeline. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

SDLC-001, SDLC-002, PWD-002

AI Summary

This policy defines mandatory controls for third-party library dependency management within the Secure Software Development domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Application Security.

Example Compliant Scenario

A system owner within Application Security implements Third-Party Library Dependency Management in full: required controls are configured as specified, evidence such as software composition analysis reports is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant secure coding training completion records without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that high-severity findings ignored and shipped to production. Further investigation reveals that code merged without peer review, and no compensating control was documented. The finding is logged against SDLC-003 with a Medium risk rating and routed to Head of Application Security for remediation per the defined timeline.

Metadata

Policy_ID:	SDLC-003	Title:	Third-Party Library Dependency Management
Category:	Secure Software Development	Risk_Level:	Medium
Department:	Application Security	Owner:	Head of Application Security
Version:	1.4	Effective_Date:	April 11, 2025
Review_Cycle :	Quarterly	Priority:	Medium
Status:	Active	Related_Policies:	SDLC-001, SDLC-002, PWD-002
Keywords:	software composition analysis, CI/CD, security testing, secure coding, secure development, SDLC, code review, SAST, DAST, dependency scanning		
Search_Tags:	Secure Development, Application Security, SDLC, Policy, Software Development, Security Testing		
Evidence_Types:	Software composition analysis reports, Secure coding training completion records, Release gate configuration, Code review records or pull request history, Static and dynamic application security testing reports		

Production Change Approval Process

Category: Change Management

Business Objective

Change management policies ensure that modifications to production systems are reviewed, tested, and approved in a controlled manner, reducing the risk of outages or security regressions. The Production Change Approval Process policy applies this principle specifically to production change approval process, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Change Management must comply with the requirements defined under Production Change Approval Process, and exceptions must be formally documented and approved by Director of IT Operations.

Detailed Requirements

1. Production changes must be documented in a change ticket prior to implementation.
2. Changes must be tested in a non-production environment before deployment where feasible.
3. Significant changes must be approved by a designated change advisory function.
4. Emergency changes must be documented retroactively within a short defined window.
5. Rollback procedures must be defined before implementing a production change.

Indicators of Non-Compliance

- Significant changes lacking change advisory approval
- Emergency changes never documented after the fact
- No rollback plan defined before a production change
- Production changes made without a corresponding change ticket

Required Evidence

- Change advisory board approval records
- Test results for pre-production validation
- Emergency change retroactive documentation
- Rollback procedure documentation
- Change management tickets

Recommended Remediation

To remediate a violation of Production Change Approval Process, the accountable team should: (1) Introduce mandatory non-production testing prior to deployment. (2) Establish a change advisory review step for significant changes. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

CHG-002, MFA-001, MFA-002

AI Summary

This policy defines mandatory controls for production change approval process within the Change Management domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under IT Operations.

Example Compliant Scenario

A system owner within IT Operations implements Production Change Approval Process in full: required controls are configured as specified, evidence such as change advisory board approval records is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant test results for pre-production validation without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that significant changes lacking change advisory approval. Further investigation reveals that emergency changes never documented after the fact, and no compensating control was documented. The finding is logged against CHG-001 with a Medium risk rating and routed to Director of IT Operations for remediation per the defined timeline.

Metadata

Policy_ID:	CHG-001	Title:	Production Change Approval Process
Category:	Change Management	Risk_Level:	Medium
Department:	IT Operations	Owner:	Director of IT Operations
Version:	2.2	Effective_Date:	October 7, 2025
Review_Cycle :	Annual	Priority:	Medium
Status:	Under Review	Related_Policies:	CHG-002, MFA-001, MFA-002
Keywords:	production change, deployment approval, change management, change ticket, change advisory board, emergency change, rollback		
Search_Tags:	Governance, Security, Software Development, Change Management, IT Operations, Policy		
Evidence_Types:	Change advisory board approval records, Test results for pre-production validation, Emergency change retroactive documentation, Rollback procedure documentation, Change management tickets		

Emergency Change Procedures

Category: Change Management

Business Objective

Change management policies ensure that modifications to production systems are reviewed, tested, and approved in a controlled manner, reducing the risk of outages or security regressions. The Emergency Change Procedures policy applies this principle specifically to emergency change procedures, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Change Management must comply with the requirements defined under Emergency Change Procedures, and exceptions must be formally documented and approved by Director of IT Operations.

Detailed Requirements

1. Significant changes must be approved by a designated change advisory function.
2. Emergency changes must be documented retroactively within a short defined window.
3. Rollback procedures must be defined before implementing a production change.
4. Change success or failure must be recorded and reviewed for recurring changes.
5. Production changes must be documented in a change ticket prior to implementation.
6. Changes must be tested in a non-production environment before deployment where feasible.

Indicators of Non-Compliance

- Production changes made without a corresponding change ticket
- Changes deployed directly to production without prior testing
- Significant changes lacking change advisory approval
- Emergency changes never documented after the fact
- No rollback plan defined before a production change

Required Evidence

- Change management tickets
- Change advisory board approval records
- Test results for pre-production validation
- Emergency change retroactive documentation
- Rollback procedure documentation

Recommended Remediation

To remediate a violation of Emergency Change Procedures, the accountable team should: (1) Establish a change advisory review step for significant changes. (2) Set a firm deadline for retroactive documentation of emergency changes. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

CHG-001, ENC-001, ENC-002

AI Summary

This policy defines mandatory controls for emergency change procedures within the Change Management domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under IT Operations.

Example Compliant Scenario

A system owner within IT Operations implements Emergency Change Procedures in full: required controls are configured as specified, evidence such as change management tickets is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant change advisory board approval records without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that production changes made without a corresponding change ticket. Further investigation reveals that changes deployed directly to production without prior testing, and no compensating control was documented. The finding is logged against CHG-002 with a Medium risk rating and routed to Director of IT Operations for remediation per the defined timeline.

Metadata

Policy_ID:	CHG-002	Title:	Emergency Change Procedures
Category:	Change Management	Risk_Level:	Medium
Department:	IT Operations	Owner:	Director of IT Operations
Version:	2.0	Effective_Date:	March 27, 2025
Review_Cycle:	Semi-Annual	Priority:	Medium
Status:	Under Review	Related_Policies:	CHG-001, ENC-001, ENC-002
Keywords:	change management, change ticket, change advisory board, emergency change, rollback, production change, deployment approval		
Search_Tags:	Change Management, IT Operations, Policy, Governance, Security, Software Development		
Evidence_Types:	Change management tickets, Change advisory board approval records, Test results for pre-production validation, Emergency change retroactive documentation, Rollback procedure documentation		

Source Code Repository Access Control

Category: Source Code Management

Business Objective

Source code management policies protect the integrity and confidentiality of the organization's codebase, which represents both intellectual property and a potential attack surface if mishandled. The Source Code Repository Access Control policy applies this principle specifically to source code repository access control, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Source Code Management must comply with the requirements defined under Source Code Repository Access Control, and exceptions must be formally documented and approved by Head of Application Security.

Detailed Requirements

1. Repository access must be revoked promptly when an individual changes teams or leaves.
2. Commit signing must be enabled for repositories containing production code.
3. Access to source code repositories must be restricted based on team membership.
4. Production branches must be protected against direct, unreviewed pushes.
5. Commit history must not be rewritten on shared branches without exception approval.
6. Secrets must never be committed to source code repositories.

Indicators of Non-Compliance

- Former team members retaining repository access
- No commit signing enabled on production repositories
- Repository access broader than the team actually working on the project
- Direct pushes to production branches without review
- Secrets or credentials found committed in repository history

Required Evidence

- Commit signing configuration
- Repository access permission lists
- Branch protection rule configuration
- Secret scanning results
- Repository access revocation records

Recommended Remediation

To remediate a violation of Source Code Repository Access Control, the accountable team should: (1) Enable commit signing for all repositories containing production code. (2) Right-size repository access to reflect current team membership. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

SCM-002, API-001, API-002

AI Summary

This policy defines mandatory controls for source code repository access control within the Source Code Management domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Application Security.

Example Compliant Scenario

A system owner within Application Security implements Source Code Repository Access Control in full: required controls are configured as specified, evidence such as commit signing configuration is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant repository access permission lists without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that former team members retaining repository access. Further investigation reveals that no commit signing enabled on production repositories, and no compensating control was documented. The finding is logged against SCM-001 with a High risk rating and routed to Head of Application Security for remediation per the defined timeline.

Metadata

Policy_ID:	SCM-001	Title:	Source Code Repository Access Control
Category:	Source Code Management	Risk_Level:	High
Department:	Application Security	Owner:	Head of Application Security
Version:	3.6	Effective_Date:	June 1, 2025
Review_Cycle:	Semi-Annual	Priority:	High
Status:	Active	Related_Policies:	SCM-002, API-001, API-002
Keywords:	branch protection, commit signing, secret scanning, version control, code repository, source code management, repository access		
Search_Tags:	Version Control, Security, SDLC, Source Code Management, Application Security, Policy		
Evidence_Types:	Commit signing configuration, Repository access permission lists, Branch protection rule configuration, Secret scanning results, Repository access revocation records		

Branch Protection and Commit Signing

Category: Source Code Management

Business Objective

Source code management policies protect the integrity and confidentiality of the organization's codebase, which represents both intellectual property and a potential attack surface if mishandled. The Branch Protection and Commit Signing policy applies this principle specifically to branch protection and commit signing, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Source Code Management must comply with the requirements defined under Branch Protection and Commit Signing, and exceptions must be formally documented and approved by Head of Application Security.

Detailed Requirements

1. Access to source code repositories must be restricted based on team membership.
2. Production branches must be protected against direct, unreviewed pushes.
3. Commit history must not be rewritten on shared branches without exception approval.
4. Secrets must never be committed to source code repositories.
5. Repository access must be revoked promptly when an individual changes teams or leaves.
6. Commit signing must be enabled for repositories containing production code.

Indicators of Non-Compliance

- Direct pushes to production branches without review
- Secrets or credentials found committed in repository history
- Former team members retaining repository access
- No commit signing enabled on production repositories
- Repository access broader than the team actually working on the project

Required Evidence

- Repository access revocation records
- Commit signing configuration
- Repository access permission lists
- Branch protection rule configuration
- Secret scanning results

Recommended Remediation

To remediate a violation of Branch Protection and Commit Signing, the accountable team should: (1) Right-size repository access to reflect current team membership. (2) Enable branch protection rules requiring review before merge on production branches. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

SCM-001, NET-001, NET-002

AI Summary

This policy defines mandatory controls for branch protection and commit signing within the Source Code Management domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Application Security.

Example Compliant Scenario

A system owner within Application Security implements Branch Protection and Commit Signing in full: required controls are configured as specified, evidence such as repository access revocation records is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant commit signing configuration without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that direct pushes to production branches without review. Further investigation reveals that secrets or credentials found committed in repository history, and no compensating control was documented. The finding is logged against SCM-002 with a Medium risk rating and routed to Head of Application Security for remediation per the defined timeline.

Metadata

Policy_ID:	SCM-002	Title:	Branch Protection and Commit Signing
Category:	Source Code Management	Risk_Level:	Medium
Department:	Application Security	Owner:	Head of Application Security
Version:	2.3	Effective_Date:	April 14, 2025
Review_Cycle:	Semi-Annual	Priority:	Medium
Status:	Active	Related_Policies:	SCM-001, NET-001, NET-002
Keywords:	secret scanning, version control, code repository, source code management, repository access, branch protection, commit signing		
Search_Tags:	Source Code Management, Application Security, Policy, Version Control, Security, SDLC		
Evidence_Types:	Repository access revocation records, Commit signing configuration, Repository access permission lists, Branch protection rule configuration, Secret scanning results		

Centralized Secrets Storage

Category: Secrets Management

Business Objective

Secrets management policies govern how credentials, API keys, and other sensitive configuration values are stored, accessed, and rotated, preventing their exposure through code or configuration. The Centralized Secrets Storage policy applies this principle specifically to centralized secrets storage, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Secrets Management must comply with the requirements defined under Centralized Secrets Storage, and exceptions must be formally documented and approved by Head of Application Security.

Detailed Requirements

1. Secrets must be rotated on a defined schedule appropriate to their sensitivity.
2. Access to the secrets management system must be logged and reviewed.
3. Exposed secrets must be revoked and rotated immediately upon discovery.
4. Applications must retrieve secrets at runtime rather than embedding them at build time.
5. Application secrets must be stored in an approved centralized secrets management system.
6. Secrets must never be hardcoded in source code, configuration files, or container images.

Indicators of Non-Compliance

- Exposed secrets left active after discovery
- Secrets hardcoded in application source code
- API keys embedded directly in container images
- Secrets that have never been rotated since creation
- No logging of access to the secrets management system

Required Evidence

- Secrets management system configuration
- Secret scanning results across repositories and images
- Secret rotation schedule and history
- Secrets management access logs

Recommended Remediation

To remediate a violation of Centralized Secrets Storage, the accountable team should: (1) Implement automated secret rotation on a schedule matched to sensitivity. (2) Enable logging and periodic review of secrets management system access. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

SEC-002, EP-002, DEV-001

AI Summary

This policy defines mandatory controls for centralized secrets storage within the Secrets Management domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Critical risk and applies to all in-scope systems and personnel under Application Security.

Example Compliant Scenario

A system owner within Application Security implements Centralized Secrets Storage in full: required controls are configured as specified, evidence such as secrets management system configuration is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant secret scanning results across repositories and images without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that exposed secrets left active after discovery. Further investigation reveals that secrets hardcoded in application source code, and no compensating control was documented. The finding is logged against SEC-001 with a Critical risk rating and routed to Head of Application Security for remediation per the defined timeline.

Metadata

Policy_ID:	SEC-001	Title:	Centralized Secrets Storage
Category:	Secrets Management	Risk_Level:	Critical
Department:	Application Security	Owner:	Head of Application Security
Version:	3.2	Effective_Date:	June 5, 2025
Review_Cycle :	Quarterly	Priority:	Critical
Status:	Active	Related_Policies:	SEC-002, EP-002, DEV-001
Keywords:	hardcoded secret, secret rotation, secret revocation, vault, credential storage, runtime secret retrieval, secrets management, API key		
Search_Tags:	Security, Credentials, DevSecOps, Secrets Management, Application Security, Policy		
Evidence_Types:	Secrets management system configuration, Secret scanning results across repositories and images, Secret rotation schedule and history, Secrets management access logs		

Secret Rotation and Revocation

Category: Secrets Management

Business Objective

Secrets management policies govern how credentials, API keys, and other sensitive configuration values are stored, accessed, and rotated, preventing their exposure through code or configuration. The Secret Rotation and Revocation policy applies this principle specifically to secret rotation and revocation, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Secrets Management must comply with the requirements defined under Secret Rotation and Revocation, and exceptions must be formally documented and approved by Head of Application Security.

Detailed Requirements

1. Exposed secrets must be revoked and rotated immediately upon discovery.
2. Applications must retrieve secrets at runtime rather than embedding them at build time.
3. Application secrets must be stored in an approved centralized secrets management system.
4. Secrets must never be hardcoded in source code, configuration files, or container images.
5. Secrets must be rotated on a defined schedule appropriate to their sensitivity.
6. Access to the secrets management system must be logged and reviewed.

Indicators of Non-Compliance

- Secrets that have never been rotated since creation
- No logging of access to the secrets management system
- Exposed secrets left active after discovery
- Secrets hardcoded in application source code
- API keys embedded directly in container images

Required Evidence

- Secrets management system configuration
- Secret scanning results across repositories and images
- Secret rotation schedule and history
- Secrets management access logs

Recommended Remediation

To remediate a violation of Secret Rotation and Revocation, the accountable team should: (1) Enable logging and periodic review of secrets management system access. (2) Establish an immediate revoke-and-rotate procedure for any exposed secret. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

SEC-001, LOG-003, AUD-001

AI Summary

This policy defines mandatory controls for secret rotation and revocation within the Secrets Management domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Application Security.

Example Compliant Scenario

A system owner within Application Security implements Secret Rotation and Revocation in full: required controls are configured as specified, evidence such as secrets management system configuration is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant secret scanning results across repositories and images without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that secrets that have never been rotated since creation. Further investigation reveals that no logging of access to the secrets management system, and no compensating control was documented. The finding is logged against SEC-002 with a High risk rating and routed to Head of Application Security for remediation per the defined timeline.

Metadata

Policy_ID:	SEC-002	Title:	Secret Rotation and Revocation
Category:	Secrets Management	Risk_Level:	High
Department:	Application Security	Owner:	Head of Application Security
Version:	1.6	Effective_Date:	March 28, 2025
Review_Cycle :	Semi-Annual	Priority:	High
Status:	Active	Related_Policies:	SEC-001, LOG-003, AUD-001
Keywords:	secret revocation, vault, credential storage, runtime secret retrieval, secrets management, API key, hardcoded secret, secret rotation		
Search_Tags:	Secrets Management, Application Security, Policy, Security, Credentials, DevSecOps		
Evidence_Types:	Secrets management system configuration, Secret scanning results across repositories and images, Secret rotation schedule and history, Secrets management access logs		

Approved AI Tool Usage

Category: AI Usage

Business Objective

AI usage policies govern how employees may use artificial intelligence tools in the course of their work, addressing risks related to data exposure, accuracy, and appropriate reliance on AI-generated output. The Approved AI Tool Usage policy applies this principle specifically to approved ai tool usage, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of AI Usage must comply with the requirements defined under Approved AI Tool Usage, and exceptions must be formally documented and approved by Head of AI Governance.

Detailed Requirements

1. Employees must use only AI tools that have completed a security and privacy review.
2. Sensitive or confidential data must not be entered into unapproved AI tools.
3. AI-generated output used in business decisions must be reviewed by a qualified human.
4. AI tool usage must comply with the organization's data classification policy.
5. Employees must disclose material use of AI-generated content where required by internal policy.

Indicators of Non-Compliance

- Confidential data entered into an unapproved public AI tool
- AI-generated output used in decisions without human review
- AI tools adopted without completing a security review
- No disclosure of AI-generated content where policy requires it
- AI tool access granted outside standard identity management controls

Required Evidence

- AI tool approval and review records
- Data loss prevention logs for AI tool usage
- AI output review sign-off records
- AI tool access provisioning records

Recommended Remediation

To remediate a violation of Approved AI Tool Usage, the accountable team should: (1) Bring AI tool provisioning under standard identity and access management processes. (2) Restrict use of unapproved AI tools and route requests through the AI tool review process. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

AI-002, INC-003, VULN-001

AI Summary

This policy defines mandatory controls for approved ai tool usage within the AI Usage domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and

applies to all in-scope systems and personnel under AI Governance.

Example Compliant Scenario

A system owner within AI Governance implements Approved AI Tool Usage in full: required controls are configured as specified, evidence such as ai tool approval and review records is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant data loss prevention logs for ai tool usage without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that confidential data entered into an unapproved public ai tool. Further investigation reveals that ai-generated output used in decisions without human review, and no compensating control was documented. The finding is logged against AI-001 with a Medium risk rating and routed to Head of AI Governance for remediation per the defined timeline.

Metadata

Policy_ID:	AI-001	Title:	Approved AI Tool Usage
Category:	AI Usage	Risk_Level:	Medium
Department:	AI Governance	Owner:	Head of AI Governance
Version:	2.3	Effective_Date:	June 11, 2025
Review_Cycle :	Semi-Annual	Priority:	Medium
Status:	Under Review	Related_Policies:	AI-002, INC-003, VULN-001
Keywords:	AI review, responsible AI, AI usage, artificial intelligence, AI governance, human oversight, data exposure, AI tool approval		
Search_Tags:	Data Protection, Security, Emerging Technology, AI Usage, AI Governance, Policy		
Evidence_Types:	AI tool approval and review records, Data loss prevention logs for AI tool usage, AI output review sign-off records, AI tool access provisioning records		

AI Output Review and Human Oversight

Category: AI Usage

Business Objective

AI usage policies govern how employees may use artificial intelligence tools in the course of their work, addressing risks related to data exposure, accuracy, and appropriate reliance on AI-generated output. The AI Output Review and Human Oversight policy applies this principle specifically to ai output review and human oversight, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of AI Usage must comply with the requirements defined under AI Output Review and Human Oversight, and exceptions must be formally documented and approved by Head of AI Governance.

Detailed Requirements

1. AI-generated output used in business decisions must be reviewed by a qualified human.
2. AI tool usage must comply with the organization's data classification policy.
3. Employees must disclose material use of AI-generated content where required by internal policy.
4. AI tool access must follow the same identity and access management controls as other systems.
5. Employees must use only AI tools that have completed a security and privacy review.
6. Sensitive or confidential data must not be entered into unapproved AI tools.

Indicators of Non-Compliance

- No disclosure of AI-generated content where policy requires it
- AI tool access granted outside standard identity management controls
- Confidential data entered into an unapproved public AI tool
- AI-generated output used in decisions without human review
- AI tools adopted without completing a security review

Required Evidence

- AI tool approval and review records
- Data loss prevention logs for AI tool usage
- AI output review sign-off records
- AI tool access provisioning records

Recommended Remediation

To remediate a violation of AI Output Review and Human Oversight, the accountable team should: (1) Restrict use of unapproved AI tools and route requests through the AI tool review process. (2) Deploy data loss prevention controls to flag sensitive data entered into AI tools. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

AI-001, BACKUP-001, BACKUP-002

AI Summary

This policy defines mandatory controls for ai output review and human oversight within the AI Usage domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under AI Governance.

Example Compliant Scenario

A system owner within AI Governance implements AI Output Review and Human Oversight in full: required controls are configured as specified, evidence such as ai tool approval and review records is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant data loss prevention logs for ai tool usage without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that no disclosure of ai-generated content where policy requires it. Further investigation reveals that ai tool access granted outside standard identity management controls, and no compensating control was documented. The finding is logged against AI-002 with a Medium risk rating and routed to Head of AI Governance for remediation per the defined timeline.

Metadata

Policy_ID:	AI-002	Title:	AI Output Review and Human Oversight
Category:	AI Usage	Risk_Level:	Medium
Department:	AI Governance	Owner:	Head of AI Governance
Version:	1.7	Effective_Date:	January 24, 2025
Review_Cycle :	Quarterly	Priority:	Medium
Status:	Active	Related_Policies:	AI-001, BACKUP-001, BACKUP-002
Keywords:	AI usage, artificial intelligence, AI governance, human oversight, data exposure, AI tool approval, AI review, responsible AI		
Search_Tags:	AI Usage, AI Governance, Policy, Data Protection, Security, Emerging Technology		
Evidence_Types:	AI tool approval and review records, Data loss prevention logs for AI tool usage, AI output review sign-off records, AI tool access provisioning records		

Generative AI Prompt Data Handling

Category: Generative AI

Business Objective

Generative AI policies address the specific risks introduced by large language models and other generative systems, including hallucination, data leakage through prompts, and intellectual property concerns. The Generative AI Prompt Data Handling policy applies this principle specifically to generative ai prompt data handling, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Generative AI must comply with the requirements defined under Generative AI Prompt Data Handling, and exceptions must be formally documented and approved by Head of AI Governance.

Detailed Requirements

1. Logs of generative AI prompts and outputs must be retained according to the retention policy.
2. Employees must be trained on the limitations and risks of generative AI output.
3. Prompts submitted to generative AI systems must not contain regulated or highly sensitive data.
4. Generative AI vendors must be reviewed for their data retention and training-use practices.
5. Outputs from generative AI systems must be fact-checked before use in customer-facing material.
6. Generative AI systems integrated into products must undergo a security and safety review.

Indicators of Non-Compliance

- Vendor data retention and training-use practices not reviewed before adoption
- Unverified generative AI output published directly to customers
- Generative AI features integrated into products without a security review
- No employee training on generative AI limitations

Required Evidence

- Generative AI training completion records
- Security review documentation for AI-integrated features
- Generative AI vendor review documentation
- Prompt and output logging configuration
- Data loss prevention rules covering AI prompt submission

Recommended Remediation

To remediate a violation of Generative AI Prompt Data Handling, the accountable team should: (1) Complete vendor reviews covering data retention and training-use practices before renewal. (2) Introduce a fact-checking step before generative AI output reaches customers. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

GENAI-002, GENAI-003, DISP-001

AI Summary

This policy defines mandatory controls for generative ai prompt data handling within the Generative AI domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under AI Governance.

Example Compliant Scenario

A system owner within AI Governance implements Generative AI Prompt Data Handling in full: required controls are configured as specified, evidence such as generative ai training completion records is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant security review documentation for ai-integrated features without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that vendor data retention and training-use practices not reviewed before adoption. Further investigation reveals that unverified generative ai output published directly to customers, and no compensating control was documented. The finding is logged against GENAI-001 with a High risk rating and routed to Head of AI Governance for remediation per the defined timeline.

Metadata

Policy_ID:	GENAI-001	Title:	Generative AI Prompt Data Handling
Category:	Generative AI	Risk_Level:	High
Department:	AI Governance	Owner:	Head of AI Governance
Version:	3.0	Effective_Date:	January 8, 2025
Review_Cycle :	Annual	Priority:	High
Status:	Active	Related_Policies:	GENAI-002, GENAI-003, DISP-001
Keywords:	prompt data, hallucination, AI vendor review, model output validation, LLM, AI training data, generative AI, large language model		
Search_Tags:	Data Protection, Security, Emerging Technology, Generative AI, AI Governance, Policy		
Evidence_Types:	Generative AI training completion records, Security review documentation for AI-integrated features, Generative AI vendor review documentation, Prompt and output logging configuration, Data loss prevention rules covering AI prompt submission		

Generative AI Model Output Validation

Category: Generative AI

Business Objective

Generative AI policies address the specific risks introduced by large language models and other generative systems, including hallucination, data leakage through prompts, and intellectual property concerns. The Generative AI Model Output Validation policy applies this principle specifically to generative ai model output validation, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Generative AI must comply with the requirements defined under Generative AI Model Output Validation, and exceptions must be formally documented and approved by Head of AI Governance.

Detailed Requirements

1. Prompts submitted to generative AI systems must not contain regulated or highly sensitive data.
2. Generative AI vendors must be reviewed for their data retention and training-use practices.
3. Outputs from generative AI systems must be fact-checked before use in customer-facing material.
4. Generative AI systems integrated into products must undergo a security and safety review.
5. Logs of generative AI prompts and outputs must be retained according to the retention policy.
6. Employees must be trained on the limitations and risks of generative AI output.

Indicators of Non-Compliance

- No employee training on generative AI limitations
- Highly sensitive data submitted as part of a generative AI prompt
- Vendor data retention and training-use practices not reviewed before adoption
- Unverified generative AI output published directly to customers

Required Evidence

- Data loss prevention rules covering AI prompt submission
- Generative AI training completion records
- Security review documentation for AI-integrated features
- Generative AI vendor review documentation
- Prompt and output logging configuration

Recommended Remediation

To remediate a violation of Generative AI Model Output Validation, the accountable team should: (1) Introduce a fact-checking step before generative AI output reaches customers. (2) Require a security and safety review before integrating generative AI into products. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

GENAI-001, GENAI-003, EMPPRIV-002

AI Summary

This policy defines mandatory controls for generative ai model output validation within the Generative AI domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under AI Governance.

Example Compliant Scenario

A system owner within AI Governance implements Generative AI Model Output Validation in full: required controls are configured as specified, evidence such as data loss prevention rules covering ai prompt submission is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant generative ai training completion records without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that no employee training on generative ai limitations. Further investigation reveals that highly sensitive data submitted as part of a generative ai prompt, and no compensating control was documented. The finding is logged against GENAI-002 with a Medium risk rating and routed to Head of AI Governance for remediation per the defined timeline.

Metadata

Policy_ID:	GENAI-002	Title:	Generative AI Model Output Validation
Category:	Generative AI	Risk_Level:	Medium
Department:	AI Governance	Owner:	Head of AI Governance
Version:	1.7	Effective_Date:	October 4, 2025
Review_Cycle :	Quarterly	Priority:	Medium
Status:	Active	Related_Policies:	GENAI-001, GENAI-003, EMPPRIV-002
Keywords:	AI vendor review, model output validation, LLM, AI training data, generative AI, large language model, prompt data, hallucination		
Search_Tags:	Generative AI, AI Governance, Policy, Data Protection, Security, Emerging Technology		
Evidence_Types:	Data loss prevention rules covering AI prompt submission, Generative AI training completion records, Security review documentation for AI-integrated features, Generative AI vendor review documentation, Prompt and output logging configuration		

Third-Party Generative AI Vendor Review

Category: Generative AI

Business Objective

Generative AI policies address the specific risks introduced by large language models and other generative systems, including hallucination, data leakage through prompts, and intellectual property concerns. The Third-Party Generative AI Vendor Review policy applies this principle specifically to third-party generative ai vendor review, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Generative AI must comply with the requirements defined under Third-Party Generative AI Vendor Review, and exceptions must be formally documented and approved by Head of AI Governance.

Detailed Requirements

1. Outputs from generative AI systems must be fact-checked before use in customer-facing material.
2. Generative AI systems integrated into products must undergo a security and safety review.
3. Logs of generative AI prompts and outputs must be retained according to the retention policy.
4. Employees must be trained on the limitations and risks of generative AI output.
5. Prompts submitted to generative AI systems must not contain regulated or highly sensitive data.
6. Generative AI vendors must be reviewed for their data retention and training-use practices.

Indicators of Non-Compliance

- Unverified generative AI output published directly to customers
- Generative AI features integrated into products without a security review
- No employee training on generative AI limitations
- Highly sensitive data submitted as part of a generative AI prompt
- Vendor data retention and training-use practices not reviewed before adoption

Required Evidence

- Prompt and output logging configuration
- Data loss prevention rules covering AI prompt submission
- Generative AI training completion records
- Security review documentation for AI-integrated features
- Generative AI vendor review documentation

Recommended Remediation

To remediate a violation of Third-Party Generative AI Vendor Review, the accountable team should: (1) Require a security and safety review before integrating generative AI into products. (2) Implement data loss prevention controls to block sensitive data in AI prompts. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

GENAI-001, GENAI-002, PHYS-002

AI Summary

This policy defines mandatory controls for third-party generative ai vendor review within the Generative AI domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under AI Governance.

Example Compliant Scenario

A system owner within AI Governance implements Third-Party Generative AI Vendor Review in full: required controls are configured as specified, evidence such as prompt and output logging configuration is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant data loss prevention rules covering ai prompt submission without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that unverified generative ai output published directly to customers. Further investigation reveals that generative ai features integrated into products without a security review, and no compensating control was documented. The finding is logged against GENAI-003 with a Medium risk rating and routed to Head of AI Governance for remediation per the defined timeline.

Metadata

Policy_ID:	GENAI-003	Title:	Third-Party Generative AI Vendor Review
Category:	Generative AI	Risk_Level:	Medium
Department:	AI Governance	Owner:	Head of AI Governance
Version:	2.2	Effective_Date:	August 20, 2025
Review_Cycle:	Quarterly	Priority:	Medium
Status:	Active	Related_Policies:	GENAI-001, GENAI-002, PHYS-002
Keywords:	LLM, AI training data, generative AI, large language model, prompt data, hallucination, AI vendor review, model output validation		
Search_Tags:	Data Protection, Security, Emerging Technology, Generative AI, AI Governance, Policy		
Evidence_Types:	Prompt and output logging configuration, Data loss prevention rules covering AI prompt submission, Generative AI training completion records, Security review documentation for AI-integrated features, Generative AI vendor review documentation		

Email Authentication Standards (SPF, DKIM, DMARC)

Category: Email Security

Business Objective

Email security policies protect against phishing, spoofing, and data leakage conducted through the organization's email systems, which remain a primary vector for initial compromise. The Email Authentication Standards (SPF, DKIM, DMARC) policy applies this principle specifically to email authentication standards (spf, dkim, dmarc), establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Email Security must comply with the requirements defined under Email Authentication Standards (SPF, DKIM, DMARC), and exceptions must be formally documented and approved by Director of Infrastructure Security.

Detailed Requirements

1. Simulated phishing exercises must be conducted periodically with results tracked.
2. External email must be visually flagged to alert recipients.
3. Outbound email domains must publish SPF, DKIM, and DMARC records.
4. DMARC policy must be enforced at a quarantine or reject level, not monitor-only.
5. Inbound email must be scanned for malicious attachments and links.

Indicators of Non-Compliance

- Email domains missing SPF, DKIM, or DMARC records
- DMARC policy set to monitor-only indefinitely
- Inbound email not scanned for malicious content
- No phishing awareness training completed by staff
- Repeated phishing simulation failures with no follow-up training

Required Evidence

- DNS records showing SPF, DKIM, and DMARC configuration
- Email gateway scanning configuration
- Phishing training completion records
- Phishing simulation results and trend reports

Recommended Remediation

To remediate a violation of Email Authentication Standards (SPF, DKIM, DMARC), the accountable team should: (1) Publish and correctly configure SPF, DKIM, and DMARC records for all sending domains. (2) Move DMARC enforcement from monitor-only to quarantine or reject. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

MAIL-002, REMOTE-001, REMOTE-002

AI Summary

This policy defines mandatory controls for email authentication standards (spf, dkim, dmarc) within the Email Security domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as High risk and applies to all in-scope systems and personnel under Infrastructure Security.

Example Compliant Scenario

A system owner within Infrastructure Security implements Email Authentication Standards (SPF, DKIM, DMARC) in full: required controls are configured as specified, evidence such as dns records showing spf, dkim, and dmarc configuration is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant email gateway scanning configuration without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that email domains missing spf, dkim, or dmarc records. Further investigation reveals that dmarc policy set to monitor-only indefinitely, and no compensating control was documented. The finding is logged against MAIL-001 with a High risk rating and routed to Director of Infrastructure Security for remediation per the defined timeline.

Metadata

Policy_ID:	MAIL-001	Title:	Email Authentication Standards (SPF, DKIM, DMARC)
Category:	Email Security	Risk_Level:	High
Department:	Infrastructure Security	Owner:	Director of Infrastructure Security
Version:	3.0	Effective_Date:	April 19, 2025
Review_Cycle :	Quarterly	Priority:	High
Status:	Under Review	Related_Policies:	MAIL-002, REMOTE-001, REMOTE-002
Keywords:	email gateway, awareness training, email security, phishing, SPF, DKIM, DMARC, email spoofing, phishing simulation		
Search_Tags:	Email Security, Phishing, Security, Policy, Awareness Training, Infrastructure Security		
Evidence_Types:	DNS records showing SPF, DKIM, and DMARC configuration, Email gateway scanning configuration, Phishing training completion records, Phishing simulation results and trend reports		

Phishing Simulation and Awareness Training

Category: Email Security

Business Objective

Email security policies protect against phishing, spoofing, and data leakage conducted through the organization's email systems, which remain a primary vector for initial compromise. The Phishing Simulation and Awareness Training policy applies this principle specifically to phishing simulation and awareness training, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Email Security must comply with the requirements defined under Phishing Simulation and Awareness Training, and exceptions must be formally documented and approved by Director of Infrastructure Security.

Detailed Requirements

1. Outbound email domains must publish SPF, DKIM, and DMARC records.
2. DMARC policy must be enforced at a quarantine or reject level, not monitor-only.
3. Inbound email must be scanned for malicious attachments and links.
4. Employees must complete phishing awareness training on a recurring basis.
5. Simulated phishing exercises must be conducted periodically with results tracked.
6. External email must be visually flagged to alert recipients.

Indicators of Non-Compliance

- No phishing awareness training completed by staff
- Repeated phishing simulation failures with no follow-up training
- Email domains missing SPF, DKIM, or DMARC records
- DMARC policy set to monitor-only indefinitely
- Inbound email not scanned for malicious content

Required Evidence

- DNS records showing SPF, DKIM, and DMARC configuration
- Email gateway scanning configuration
- Phishing training completion records
- Phishing simulation results and trend reports

Recommended Remediation

To remediate a violation of Phishing Simulation and Awareness Training, the accountable team should: (1) Move DMARC enforcement from monitor-only to quarantine or reject. (2) Enable attachment and link scanning at the email gateway. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

MAIL-001, CHG-001, CHG-002

AI Summary

This policy defines mandatory controls for phishing simulation and awareness training within the Email Security domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Infrastructure Security.

Example Compliant Scenario

A system owner within Infrastructure Security implements Phishing Simulation and Awareness Training in full: required controls are configured as specified, evidence such as dns records showing spf, dkim, and dmarc configuration is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant email gateway scanning configuration without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that no phishing awareness training completed by staff. Further investigation reveals that repeated phishing simulation failures with no follow-up training, and no compensating control was documented. The finding is logged against MAIL-002 with a Medium risk rating and routed to Director of Infrastructure Security for remediation per the defined timeline.

Metadata

Policy_ID:	MAIL-002	Title:	Phishing Simulation and Awareness Training
Category:	Email Security	Risk_Level:	Medium
Department:	Infrastructure Security	Owner:	Director of Infrastructure Security
Version:	1.9	Effective_Date:	October 27, 2025
Review_Cycle :	Quarterly	Priority:	Medium
Status:	Active	Related_Policies:	MAIL-001, CHG-001, CHG-002
Keywords:	email security, phishing, SPF, DKIM, DMARC, email spoofing, phishing simulation, email gateway, awareness training		
Search_Tags:	Policy, Awareness Training, Infrastructure Security, Email Security, Phishing, Security		
Evidence_Types:	DNS records showing SPF, DKIM, and DMARC configuration, Email gateway scanning configuration, Phishing training completion records, Phishing simulation results and trend reports		

Business Continuity Plan Maintenance

Category: Business Continuity

Business Objective

Business continuity policies ensure that critical business functions can continue or be quickly restored following a disruptive event, minimizing operational and financial impact. The Business Continuity Plan Maintenance policy applies this principle specifically to business continuity plan maintenance, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Business Continuity must comply with the requirements defined under Business Continuity Plan Maintenance, and exceptions must be formally documented and approved by Director of Business Continuity.

Detailed Requirements

1. Dependencies between critical functions and supporting systems must be mapped.
2. Business continuity exercises must be conducted to validate plan effectiveness.
3. Alternate work arrangements must be defined for scenarios preventing facility access.
4. Business continuity plan ownership must be assigned to a named individual per function.
5. A business continuity plan must exist for each function classified as critical.

Indicators of Non-Compliance

- Continuity plans not reviewed within the past year
- No documented mapping of dependencies for a critical function
- No continuity exercise conducted to validate the plan
- Continuity plans with no assigned owner
- Critical business functions with no documented continuity plan

Required Evidence

- Business continuity plan documents
- Dependency mapping diagrams
- Continuity exercise reports
- Plan ownership assignment records

Recommended Remediation

To remediate a violation of Business Continuity Plan Maintenance, the accountable team should: (1) Complete dependency mapping for critical functions lacking documentation. (2) Conduct a continuity exercise and update the plan based on findings. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

BCP-002, SEC-002, AI-001

AI Summary

This policy defines mandatory controls for business continuity plan maintenance within the Business Continuity domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Business Continuity Office.

Example Compliant Scenario

A system owner within Business Continuity Office implements Business Continuity Plan Maintenance in full: required controls are configured as specified, evidence such as business continuity plan documents is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant dependency mapping diagrams without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that continuity plans not reviewed within the past year. Further investigation reveals that no documented mapping of dependencies for a critical function, and no compensating control was documented. The finding is logged against BCP-001 with a Medium risk rating and routed to Director of Business Continuity for remediation per the defined timeline.

Metadata

Policy_ID:	BCP-001	Title:	Business Continuity Plan Maintenance
Category:	Business Continuity	Risk_Level:	Medium
Department:	Business Continuity Office	Owner:	Director of Business Continuity
Version:	3.9	Effective_Date:	January 26, 2025
Review_Cycle :	Quarterly	Priority:	Medium
Status:	Active	Related_Policies:	BCP-002, SEC-002, AI-001
Keywords:	continuity exercise, critical function, resilience, alternate work arrangement, business continuity, continuity plan, dependency mapping		
Search_Tags:	Resilience, Policy, Governance, Risk Management, Business Continuity		
Evidence_Types:	Business continuity plan documents, Dependency mapping diagrams, Continuity exercise reports, Plan ownership assignment records		

Critical Function Dependency Mapping

Category: Business Continuity

Business Objective

Business continuity policies ensure that critical business functions can continue or be quickly restored following a disruptive event, minimizing operational and financial impact. The Critical Function Dependency Mapping policy applies this principle specifically to critical function dependency mapping, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Business Continuity must comply with the requirements defined under Critical Function Dependency Mapping, and exceptions must be formally documented and approved by Director of Business Continuity.

Detailed Requirements

1. Alternate work arrangements must be defined for scenarios preventing facility access.
2. Business continuity plan ownership must be assigned to a named individual per function.
3. A business continuity plan must exist for each function classified as critical.
4. Business continuity plans must be reviewed and updated at least annually.
5. Dependencies between critical functions and supporting systems must be mapped.
6. Business continuity exercises must be conducted to validate plan effectiveness.

Indicators of Non-Compliance

- Continuity plans with no assigned owner
- Critical business functions with no documented continuity plan
- Continuity plans not reviewed within the past year
- No documented mapping of dependencies for a critical function
- No continuity exercise conducted to validate the plan

Required Evidence

- Business continuity plan documents
- Dependency mapping diagrams
- Continuity exercise reports
- Plan ownership assignment records

Recommended Remediation

To remediate a violation of Critical Function Dependency Mapping, the accountable team should: (1) Conduct a continuity exercise and update the plan based on findings. (2) Develop a documented continuity plan for any critical function currently without one. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

BCP-001, GENAI-003, MAIL-001

AI Summary

This policy defines mandatory controls for critical function dependency mapping within the Business Continuity domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Business Continuity Office.

Example Compliant Scenario

A system owner within Business Continuity Office implements Critical Function Dependency Mapping in full: required controls are configured as specified, evidence such as business continuity plan documents is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant dependency mapping diagrams without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that continuity plans with no assigned owner. Further investigation reveals that critical business functions with no documented continuity plan, and no compensating control was documented. The finding is logged against BCP-002 with a Medium risk rating and routed to Director of Business Continuity for remediation per the defined timeline.

Metadata

Policy_ID:	BCP-002	Title:	Critical Function Dependency Mapping
Category:	Business Continuity	Risk_Level:	Medium
Department:	Business Continuity Office	Owner:	Director of Business Continuity
Version:	3.5	Effective_Date:	January 17, 2025
Review_Cycle :	Quarterly	Priority:	Medium
Status:	Active	Related_Policies:	BCP-001, GENAI-003, MAIL-001
Keywords:	resilience, alternate work arrangement, business continuity, continuity plan, dependency mapping, continuity exercise, critical function		
Search_Tags:	Risk Management, Business Continuity, Resilience, Policy, Governance		
Evidence_Types:	Business continuity plan documents, Dependency mapping diagrams, Continuity exercise reports, Plan ownership assignment records		

Policy Lifecycle and Version Control

Category: Compliance Documentation

Business Objective

Compliance documentation policies ensure that policies, procedures, and control evidence are consistently maintained, version-controlled, and accessible to support audits and internal governance. The Policy Lifecycle and Version Control policy applies this principle specifically to policy lifecycle and version control, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Compliance Documentation must comply with the requirements defined under Policy Lifecycle and Version Control, and exceptions must be formally documented and approved by Head of Governance, Risk & Compliance.

Detailed Requirements

1. All policies must have a designated owner accountable for accuracy and review.
2. Policies must be reviewed and re-approved on a defined cycle, at minimum annually.
3. Policy version history must be retained to show the evolution of requirements.
4. Control evidence must be stored in a centralized, access-controlled repository.
5. Superseded policy versions must be clearly marked and archived, not deleted.

Indicators of Non-Compliance

- No retained version history for a policy
- Control evidence scattered across untracked personal drives
- Policy changes made without stakeholder communication
- Policies with no assigned owner
- Policies not reviewed within the defined cycle

Required Evidence

- Policy management system records
- Policy review and approval history
- Control evidence repository access logs
- Stakeholder communication records for policy changes

Recommended Remediation

To remediate a violation of Policy Lifecycle and Version Control, the accountable team should: (1) Assign a documented owner to every policy lacking one. (2) Establish and enforce a recurring policy review and re-approval cycle. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

DOC-002, AUTH-001, AUTH-002

AI Summary

This policy defines mandatory controls for policy lifecycle and version control within the Compliance Documentation domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Low risk and applies to all in-scope systems and personnel under Governance, Risk & Compliance.

Example Compliant Scenario

A system owner within Governance, Risk & Compliance implements Policy Lifecycle and Version Control in full: required controls are configured as specified, evidence such as policy management system records is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant policy review and approval history without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that no retained version history for a policy. Further investigation reveals that control evidence scattered across untracked personal drives, and no compensating control was documented. The finding is logged against DOC-001 with a Low risk rating and routed to Head of Governance, Risk & Compliance for remediation per the defined timeline.

Metadata

Policy_ID:	DOC-001	Title:	Policy Lifecycle and Version Control
Category:	Compliance Documentation	Risk_Level:	Low
Department:	Governance, Risk & Compliance	Owner:	Head of Governance, Risk & Compliance
Version:	1.6	Effective_Date:	April 21, 2025
Review_Cycle :	Semi-Annual	Priority:	Low
Status:	Active	Related_Policies:	DOC-002, AUTH-001, AUTH-002
Keywords:	compliance documentation, policy management, version control, control evidence, policy review, policy owner, governance		
Search_Tags:	Compliance Documentation, Governance, Policy, GRC, Risk Management, Audit		
Evidence_Types:	Policy management system records, Policy review and approval history, Control evidence repository access logs, Stakeholder communication records for policy changes		

Control Evidence Repository Management

Category: Compliance Documentation

Business Objective

Compliance documentation policies ensure that policies, procedures, and control evidence are consistently maintained, version-controlled, and accessible to support audits and internal governance. The Control Evidence Repository Management policy applies this principle specifically to control evidence repository management, establishing a clear, auditable baseline that reduces the likelihood of a preventable security or compliance failure in this area.

Policy Statement

All systems, personnel, and processes within scope of Compliance Documentation must comply with the requirements defined under Control Evidence Repository Management, and exceptions must be formally documented and approved by Head of Governance, Risk & Compliance.

Detailed Requirements

1. Policy version history must be retained to show the evolution of requirements.
2. Control evidence must be stored in a centralized, access-controlled repository.
3. Superseded policy versions must be clearly marked and archived, not deleted.
4. Policy changes must be communicated to affected stakeholders upon approval.
5. All policies must have a designated owner accountable for accuracy and review.
6. Policies must be reviewed and re-approved on a defined cycle, at minimum annually.

Indicators of Non-Compliance

- Policies with no assigned owner
- Policies not reviewed within the defined cycle
- No retained version history for a policy
- Control evidence scattered across untracked personal drives

Required Evidence

- Policy management system records
- Policy review and approval history
- Control evidence repository access logs
- Stakeholder communication records for policy changes

Recommended Remediation

To remediate a violation of Control Evidence Repository Management, the accountable team should: (1) Establish and enforce a recurring policy review and re-approval cycle. (2) Migrate control evidence into a centralized, access-controlled repository. Remediation actions must be tracked to closure and verified by an independent reviewer before the associated finding is closed.

Related Policies

DOC-001, IDM-001, IDM-002

AI Summary

This policy defines mandatory controls for control evidence repository management within the Compliance Documentation domain, specifying required safeguards, common failure indicators, and evidence auditors should expect to see. It is classified as Medium risk and applies to all in-scope systems and personnel under Governance, Risk & Compliance.

Example Compliant Scenario

A system owner within Governance, Risk & Compliance implements Control Evidence Repository Management in full: required controls are configured as specified, evidence such as policy management system records is retained and current, and the most recent internal review confirmed no open findings against this policy. When queried during an audit, the team produces the relevant policy review and approval history without delay.

Example Non-Compliant Scenario

During a routine review, an auditor discovers that policies with no assigned owner. Further investigation reveals that policies not reviewed within the defined cycle, and no compensating control was documented. The finding is logged against DOC-002 with a Medium risk rating and routed to Head of Governance, Risk & Compliance for remediation per the defined timeline.

Metadata

Policy_ID:	DOC-002	Title:	Control Evidence Repository Management
Category:	Compliance Documentation	Risk_Level:	Medium
Department:	Governance, Risk & Compliance	Owner:	Head of Governance, Risk & Compliance
Version:	3.8	Effective_Date:	June 15, 2025
Review_Cycle :	Semi-Annual	Priority:	Medium
Status:	Active	Related_Policies:	DOC-001, IDM-001, IDM-002
Keywords:	version control, control evidence, policy review, policy owner, governance, compliance documentation, policy management		
Search_Tags:	GRC, Risk Management, Audit, Compliance Documentation, Governance, Policy		
Evidence_Types:	Policy management system records, Policy review and approval history, Control evidence repository access logs, Stakeholder communication records for policy changes		

Appendix A: Category Index

This appendix lists every fictional policy category included in this manual, the corresponding ID prefix, and the number of policies defined within it. This index is provided to support metadata filtering and category-level retrieval in downstream AI and search systems.

Category	ID Prefix	Department	# Policies
Authentication	AUTH	Identity & Access Management	3
Authorization	AUTHZ	Identity & Access Management	2
Identity Management	IDM	Identity & Access Management	2
Password Security	PWD	Identity & Access Management	2
Multi-Factor Authentication	MFA	Identity & Access Management	2
Access Control	AC	Information Security	3
Encryption	ENC	Information Security	3
Key Management	KEY	Information Security	2
API Security	API	Application Security	2
Cloud Security	CLOUD	Cloud Infrastructure	3
Network Security	NET	Infrastructure Security	2
Firewall Configuration	FW	Infrastructure Security	2
Endpoint Protection	EP	Infrastructure Security	2
Device Management	DEV	IT Operations	2
Logging & Monitoring	LOG	Security Operations	3
Audit Trail	AUD	Security Operations	2
Incident Response	INC	Security Operations	3
Vulnerability Management	VULN	Security Operations	2
Patch Management	PATCH	IT Operations	2
Backup & Disaster Recovery	BACKUP	IT Operations	3
Database Security	DB	Information Security	2
Data Classification	DC	Data Governance	2
Data Retention	RET	Data Governance	2
Data Disposal	DISP	Data Governance	2
Customer Privacy	PRIV	Privacy Office	2
Employee Privacy	EMPPRIV	Human Resources	2
Third-Party Vendors	VENDOR	Vendor Risk Management	3

Category	ID Prefix	Department	# Policies
Physical Security	PHYS	Corporate Security	2
Remote Work	REMOTE	IT Operations	2
Secure Software Development	SDLC	Application Security	3
Change Management	CHG	IT Operations	2
Source Code Management	SCM	Application Security	2
Secrets Management	SEC	Application Security	2
AI Usage	AI	AI Governance	2
Generative AI	GENAI	AI Governance	3
Email Security	MAIL	Infrastructure Security	2
Business Continuity	BCP	Business Continuity Office	2
Compliance Documentation	DOC	Governance, Risk & Compliance	2